Bosch IdP Onboarding Process

Docupedia Export

Author:FIXED-TERM ZHANG Yaolong (HRL-CN)
Date:20-Oct-2026 07:22

Invented for life

Table of Contents

1 Precheck 8

2 Process Overview 9

3 Help and Consulting 11

4 SAML Configuration (via Self-Service) 12

4.1 How to request new SAML Application 12

4.2 Additional Information around our Self-Service 13

4.2.1 SAML self-service Portal Overview 13

4.2.2 Self-Service rules 14

4.2.3 Multifactor Authentication (MFA) 16

4.2.3.1 How to enroll for MFA 16

4.2.3.2 Change MFA behavior 16

4.3 Change SAML Assertion Consumer URL 16

4.4 Change SAML Signing Certificate 17

4.4.1 How to change the Certificates? Common Issues E-Mail: SAML-SelfService: Signing certificate lifetime exceeded E-Mail: SAML-SelfService: Signing certificate expiring soon/ expired The button "+ new Certificate" is greyed out 17

4.4.2 How to change the Certificates? 17

4.4.3 Common Issues 21

4.4.3.1 E-Mail: SAML-SelfService: Signing certificate lifetime exceeded 21

4.4.3.2 E-Mail: SAML-SelfService: Signing certificate expiring soon/ expired 22

4.4.3.3 The button "+ new Certificate" is greyed out 22

4.5 NameIdentifier formats 22

4.6 Request new SAML application via Self-Service | Part 1 - IAP portal 24

4.6.1 Step 2 | Start the request 25

4.6.2 Step 3 | Waiting for approval 28

4.6.3 Step 4 | Change SAML settings for your application 32

4.6.3.1 Overview 33

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4.6.3.2 Configured assertion consumer URLs 33
4.6.3.3 Requests related to this application 34
4.7 Request new SAML application via Self-Service | Part 2 - EntraID 34
4.7.1 Open Application Config in Azure 35
4.7.2 Manage Owners 35
4.7.3 Single Sign-On settings 37
4.7.3.1 Basic SAML Configuration 38
4.7.3.1.1 Upload Federation Metadata 40
4.7.3.2 Attributes and Claims 41
4.7.3.3 Limit user by groups assignment 41
4.7.3.4 SAML Certificates 43
4.8 SAML Configuration | Part 3 - Application 44
4.8.1 Get the information to configure your application 44
4.8.1.1 Federation Metadata XML file 45
4.8.1.2 SSO-Endpoints and Certificates 45
4.9 SAML Request Decline use cases 46
4.9.1 Decline use cases 46
4.9.1.1 Cloud Onboarding 46
4.9.1.1.1 No or wrong Cloud Onboarding workon number provided 46
4.9.1.1.2 Cloud onboarding process not yet approved or finished 46
4.9.1.1.3 Cloud onboarding request declined 47
4.9.1.1.4 Personal-related data set to "No" in Cloud Onboarding 47
5 OIDC Configuration 48
5.1 Step 1: Identity Provider Configuration 48
5.1.1 Initial OAUTH/OIDC App registration 48
5.1.2 App registration: Basic Settings 50
5.1.2.1 Configuration of secrets for confidential clients 51
5.1.2.2 Configuration of Redirect URIs 53
5.1.3 Manage Owners of the application 56

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.1.4 Additional Claims 58
5.1.5 Scopes 58
5.1.6 Authentication Context and MFA 59
5.1.7 Further information 59
5.2 Step 2: Application Configuration 60
5.3 Step 3: Admin Consent Approval 60
5.4 Configure Claims in Token 60
5.4.1 How to configure 61
5.4.2 Offered Claims 62
5.4.3 View Token 62
5.4.4 Common Problems 62
5.5 Entra ID Endpoint for P4S permissions 62
5.5.1 Proxy4Server (P4S) Access 62
5.5.2 Further information 63
5.5.3 Standard Case: Back-end server communication from restricted network zones 63
5.5.4 Special Case: Interactive sign-in / user access from restricted network zones 63
5.6 Exception: OIDC with RB-Admin 64
5.6.1 Create Application (Identity Provider side) 65
5.6.2 Configure Application (Identity Provider side) 66
5.6.2.1 Owners 66
5.6.2.2 Reply URLs 66
5.6.2.3 Claim Assignments 66
5.6.2.4 Secrets 69
5.6.2.5 Scope Grant Management 69
5.6.2.6 Deletion 70
5.7 OIDC Scopes and Permissions 70
5.7.1 OIDC Standard Scopes 70
5.7.2 OIDC Authentication Request 70

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.7.3 OIDC Consent and API permissions 71
6 Terms and Conditions 78
6.1 General 78
6.2 Assurances 78
6.3 Preconditions 78
6.4 Out of our Service Scope 78
6.5 Customer repsonsibility 79
6.6 Additional rules for SAML self-service 79
6.7 Terms and Conditions V1.1 - OUTDATED 79
6.8 Terms and Conditions V 1.0 - OUTDATED 80
7 Application Development 82
7.1 If you are developing a new application and need support with integrating SSO we have some tips for you: 82
8 Multi Factor (MFA) with applications using modern Auth (SAML/OIDC) 83
9 Bosch Attributes and Claims 85
10 Groups and Authorization 87
10.1 Restrictions for nested Groups 87
10.2 Usecase 1a: Restrict Access to Specific Groups 87
10.3 Usecase 1b: Send Assigned Groups in Token 88
10.4 Usecase 2: Send Roles in Token 90
10.5 Usecase 3: Send Filtered Groups in Token 92
10.6 Usecase 4: Grant Application Permission to another App 95
10.7 Usecase 5: SCIM Provisioning 96
10.8 Common Problems 96
10.9 How to configure PowerShell for Microsoft.Graph 96
10.9.1 Setting up a local proxy with PX 96
10.9.2 Setting up the PowerShell Profile(s) 97

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

10.9.3 Installing the Microsoft.Graph modules 97
10.10 How to create App-roles/ AD-group-Mapping scripted 97
10.10.1 Technical Prerequisites Upload Roles and Groups Prepare .CSV File Run the script Upload Groups only 97
10.10.2 Technical Prerequisites 97
10.10.3 Upload Roles and Groups 98
10.10.3.1 Prepare .CSV File 98
10.10.3.2 Run the script 98
10.10.4 Upload Groups only 102
10.11 SCIM - Authorization via SCIM interface 102
10.11.1 What is SCIM? 102
10.11.2 Onboarding 103

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The SSO Configuration Process differs depending on the supported SSO-protocol (SAML or OIDC). In both cases it is a simple 3 step process and implementation takes usually about 5 working days. There are no additional costs for this service.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

1 Precheck

Is the Application provided by an external company?
Please check with your provider about their SSO process.

- Supported SSO-Protocol? SAML 2.0 or OIDC (OpenID Connect)/ OAuth 2.0
- Instructions for configuration available?
- Special Case: Multitenant Sign-in offered?

Is the Application developed by your team?
If not already given / implemented, please check how to integrate automatic handling of SSO flows. This is a requirement before starting the configuration. We have more details how to integrate e.g. MSAL library here

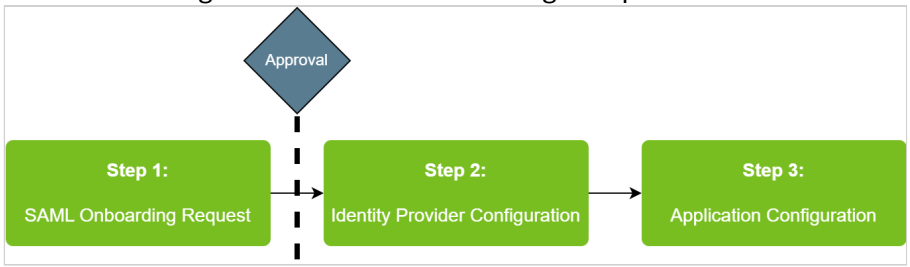
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

2 Process Overview

Depending on the supported SSO protocol we have a different process:

SAML Configuration

The SAML Configuration contains the following 3 steps:



Step 1: SAML Onboarding: Request via RB-IAP portal

Open the link below and request a new SAML configuration via our self-service.

Onboard a SAML application to Entra ID (former Azure AD):	https://rb-iap.bosch.com/new/entraID/applications/saml

Step 2: Identity Provider Configuration

After a successful approval, the Idp configuration will be handed over to the owners. All settings like claims and EntitiyID can be configured as needed for the specific application.

Step 3: Application Configuration

Configure SSO on Application side. This is totally different for each application and we cannot support here, but we are providing some basic instuctions.

More details

OIDC Configuration

The OIDC (OpenID Connect / OAuth 2.0) Configuration contains the following 3 steps:



Step 1: Identity Provider Configuration

Create an App Registration in Azure Portal. We are providing some basic instuctions

Step 2: Application Configuration

Configure SSO on Application side. This is totally different for each application and we cannot support here, but we are providing some basic instructions

Step 3: Admin Consent Approval

Please be aware that with the first authentication request a popup shows up. Fill out its dialog for requesting the admin consent. The request will be automatically forwarded to the responsible team. This step will take some time so please be patient and wait for the answer. For more details about the process feel free to check our our Admin Consent Documentation.

More details

Exception: If you need RB-Admin as Identity Provider: Please configure it on IAP-Portal as described here

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Exception: If you need RB-Admin as Identity Provider: Please fill out our SAML Onboarding Documentation for RB-Admin here
Federation Metadata XML file for RB-Admin only: https://stfs.bosch-org.com/federationmetadata/2007-06/federationmetadata.xml

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

3 Help and Consulting

You are lost? You need consulting? You have questions about SAML Onboarding?
Please send an E-Mail to ***Onboarding.Bosch-Idp@de.bosch.com*** and we can have a clarification meeting together.

In case you need any assistance and support in terms of troubleshooting or settings on the SAML configuration need to be changed **after the onboarding,** please open a **Service Desk ticket** as described here:
https://inside-docupedia.bosch.com/confluence/x/FyoLZg

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4 SAML Configuration (via Self-Service)

We are happy to provide the new Self-Service for SAML based authentication for applications. With this Self-Service we enable you to request and maintain your SAML IdP configuration mostly without our support. To ensure the validity of security settings and processes, some of the changes need to be done via the IAP site and approved from our team.
Here you can find a step-by-step guide how to use the self-service, learn what is possible and what not and how to read and handle the status of our processor which is processing and monitoring your requests and application settings.

- How to request new SAML Application
- Additional Information around our Self-Service
  - SAML self-service Portal Overview
  - Self-Service rules
  - Multifactor Authentication (MFA)
    - How to enroll for MFA
    - Change MFA behavior

4.1 How to request new SAML Application

To request a new SAML application, please follow our **step-by-step guide,** just **click** on the Step you want to jump to:



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

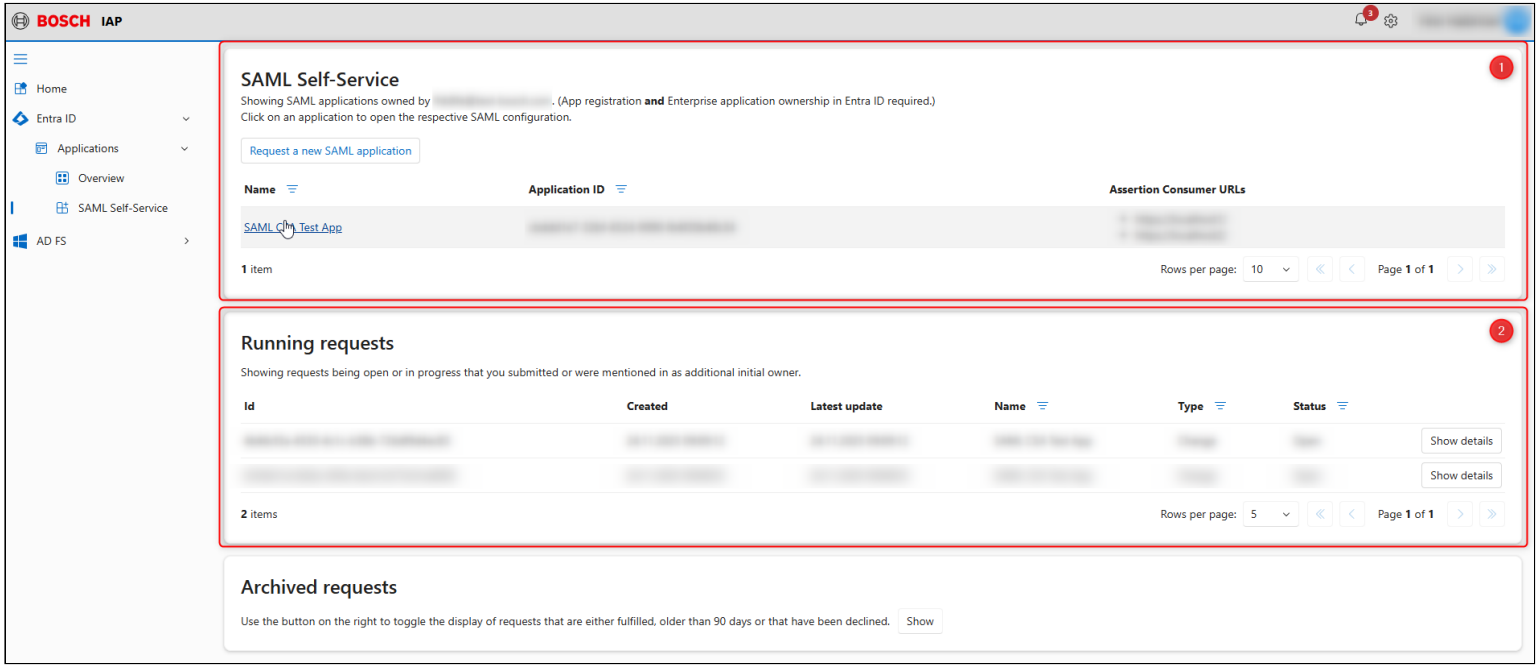
4.2 Additional Information around our Self-Service

4.2.1 SAML self-service Portal Overview

The SAML self-service is based on our IAP environment. You can find the site by navigating to

BCD (*.bosch.com)	https://rb-iap.bosch.com/new/entraID/applications/saml
Test Environment: **Q9 (*.q9-bcd-bosch.test-bosch.com)**	Login with Q9 User Account is required: https://rb-iap.test-bosch.com/new/entraID/applications/saml

Dashboard



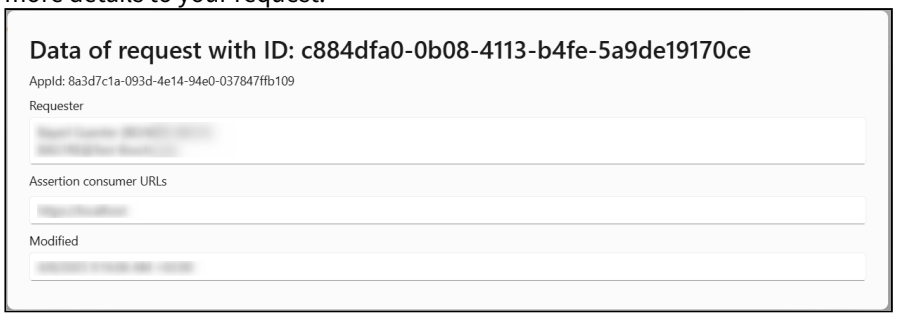
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

1) SAML Self-Service

In this section you will find all SAML configurations, which are completely onboarded and you are owner of. You can find more details by clicking on their name.

2) Running requests

In this section you will find all of your requests (e.g. new applications or change of assertion consumer URL) and that are being processed. With the Show details button you get more details to your request.



To filter the requests, you can use the blue filter icon right beside the column header 

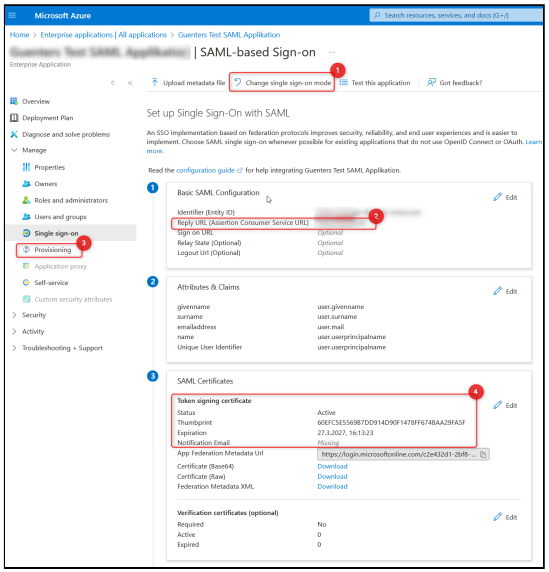
Below, at "Archived requests" you will find all requests of the past.

4.2.2 Self-Service rules

After a the SAML application was successfully onboarded, you are owner of the Enterprise Application and as well the App registration. Therefore you have full access permission to all settings of the
application. Due to security and process regulations, not all possible settings are allowed to be done. Which rules are important for you, you can find in the below list.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

1	**Change single sign-on mode**	The single sign-on mode **must** always be SAML and mustn't be changed to any other setting due to security reasons. While the creation process, SAML will be set as the authentication method. We will monitor this setting and reset this to the initial and correct value. Further you and our team will receive a notification email, once the setting has been changed. If this will be changed on a regular basis, we will remove ownership and disable the self-service for your application.
2	**Reply URL/ (Assertion Consumer Service URL)**	The reply or Assertion consumer service URL is the endpoint of your application, the token will be issued to. A change of this setting must be done in IAP and approved by our team (https://inside-docupedia.bosch.com/confluence/x/YJoQWAE). We monitor this attribute and overwrite it to the correct setting, stored in IAP. The onboarding team will be alarmed. It will be changed more often or on regular basis, we will remove the ownership and disable the self-service for your application.
3	**Provisioning (SCIM)**	**SCIM (System for Cross-domain Identity Management)** is an open standard designed to facilitate the automation of user identity management across different systems and domains. SCIM aims to simplify the process of managing and exchanging identity data such as user profiles, roles, and permissions between cloud services, applications, and IT systems. More information can be found here: https://rb-oneidm-help.bosch.com/en/data/scim.html Order SCIM integration *SCIM is part of the IDM service at Bosch and will be provided by the responsible team.* *To get consulting and start the SCIM onboarding process, please **contact the IDM integration mailbox** Mailbox.IdMIntegration@bosch.com*



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4	**Token signing certificate**	As application owner you are responsible to keep the token signing certificate up-to-date. Please setup a valid email address in the Notification Email setting to ensure getting a notification before the token signing certificate expires and renew the certificate accordingly. Please ensure to follow our security guidelines (EISA) in terms of certificate validity period and all other settings.

All security and process relevant settings will be monitored by our team and reset once the change will be done directly in Entra ID. You and our team will be notified via Email.

Please keep in mind, that we reserve the right to revoke ownership for the configuration and deactivate self-service for your application if attempts are made to circumvent these rules.

4.2.3 Multifactor Authentication (MFA)

When creating a new app, the Bosch default policy will be applied automatically and has following settings:

- No MFA is required when accessing the application from a Bosch internal network (local LAN or RB VPN connection)
- MFA is required when accessing the application from outside the Bosch network (Internet or mobile connection like e.g. 5G or LTE

4.2.3.1 How to enroll for MFA

In case you do not have yet enrolled for MFA, you can do this by following the described process here: https://connect.bosch.com/blogs/fc29ba88-808b-49d7-9439-4f1735f3c0f5/entry/Enrolling_for_Multi_Factor_Authentication_MFA_got_easier_and_more_secure?lang=de_de.
This is required for editing your application in the Azure Portal!

4.2.3.2 Change MFA behavior

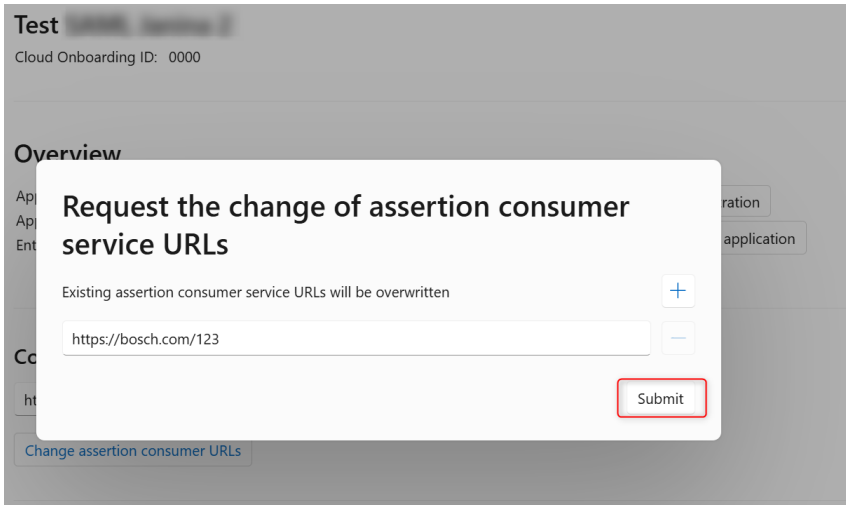
To increase the security you can e.g. order the requirement for your application to get a MFA call as well when accessing the application from the intranet. More information can be found here: Multi Factor (MFA) with applications using modern Auth (SAML/OIDC) - Directory Services - Docupedia

4.3 Change SAML Assertion Consumer URL

The reply or Assertion consumer service URL (Reply URL) is the endpoint of your application, the token will be issued to. **A change of this setting must be done in IAP and approved by our team.**
We monitor this attribute and overwrite it to the correct setting, stored in IAP. The onboarding team will be alarmed!

1. In order to change it for your existing application, please start a request here: SAML - IAP. Open the Application Settings and click "Change assertion consumer URLs". There you can adapt the URLs and Submit the Request

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



2. We will check if your request is valid and approve it.
3. Afterwards the Reply URL will be set automatically in your Application in the Azure Portal. You will get an E-Mail that the change was implemented

Recommendation:
For time critical changes it is recommended to request two Reply URLs: The old and the new one.
The old one can be removed with a second change request after the application is running with the new URL.

4.4 Change SAML Signing Certificate

SAML Signing Certificates must be exchanged regularly (at least every two years). They are used to sign the SAML Token (Response) to your application.

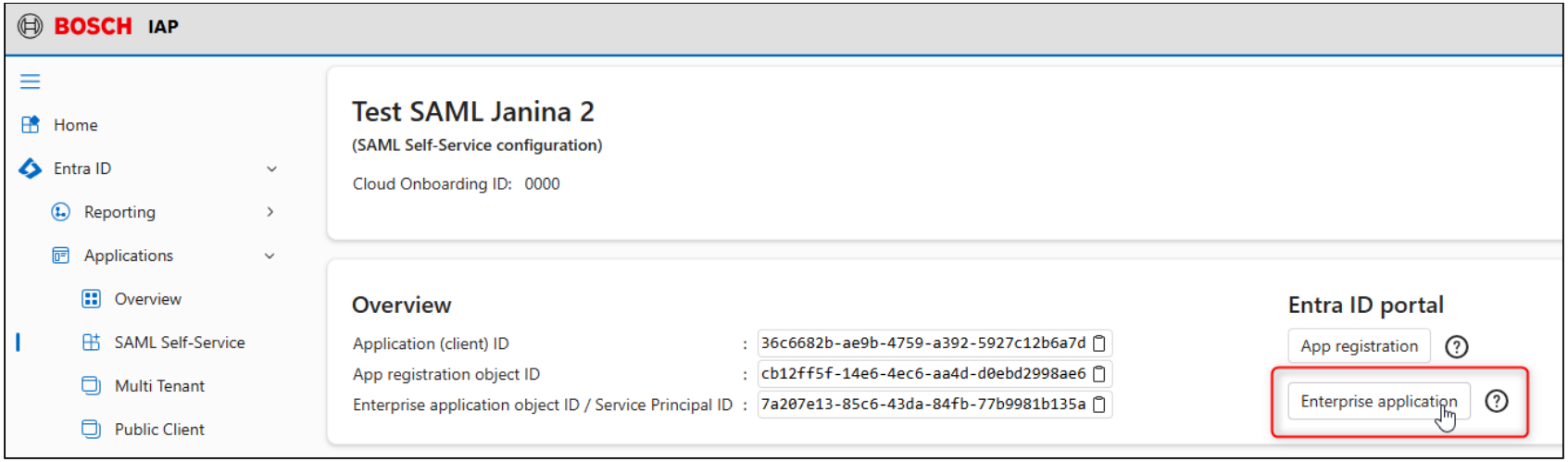
Please update your certificates in time to avoid a service downtime of your SAML application. This page describes the process with all the required steps!

4.4.1

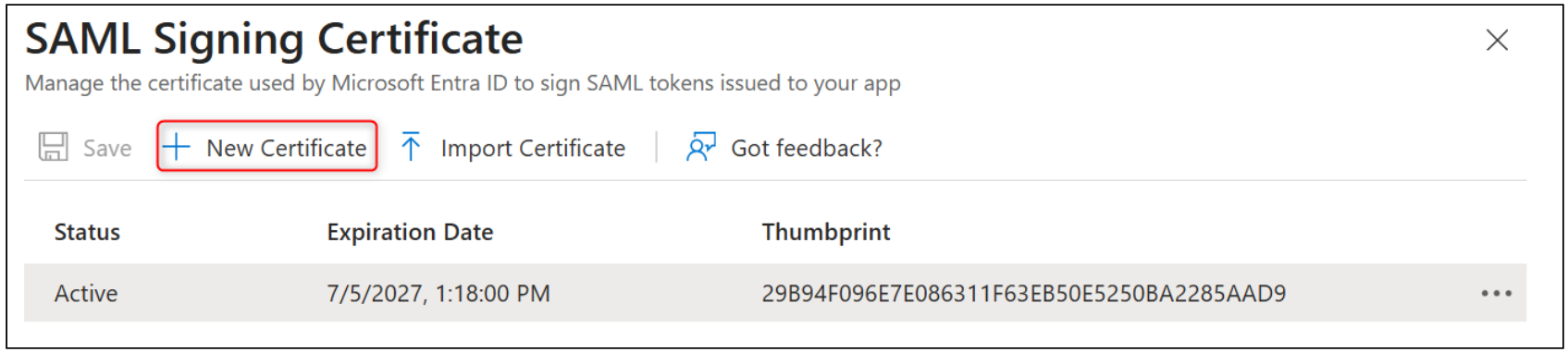
- How to change the Certificates?
- Common Issues
  - E-Mail: SAML-SelfService: Signing certificate lifetime exceeded
  - E-Mail: SAML-SelfService: Signing certificate expiring soon/ expired
  - The button "+ new Certificate" is greyed out

4.4.2 How to change the Certificates?

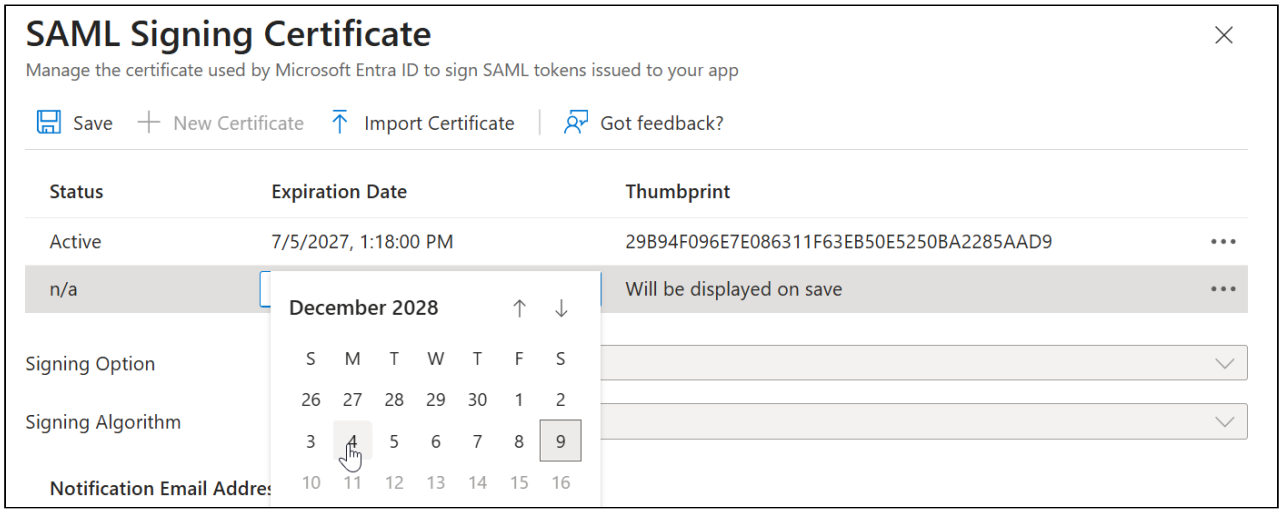
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
0 - Open Enterprise Application	Open your "Enterprise Application" in the Azure Portal, e.g. over IAP Portal: https://rb-iap.bosch.com:  *You will see all SAML applications where you are Owner - this is a prerequisite to be able to change the SAML certificates*

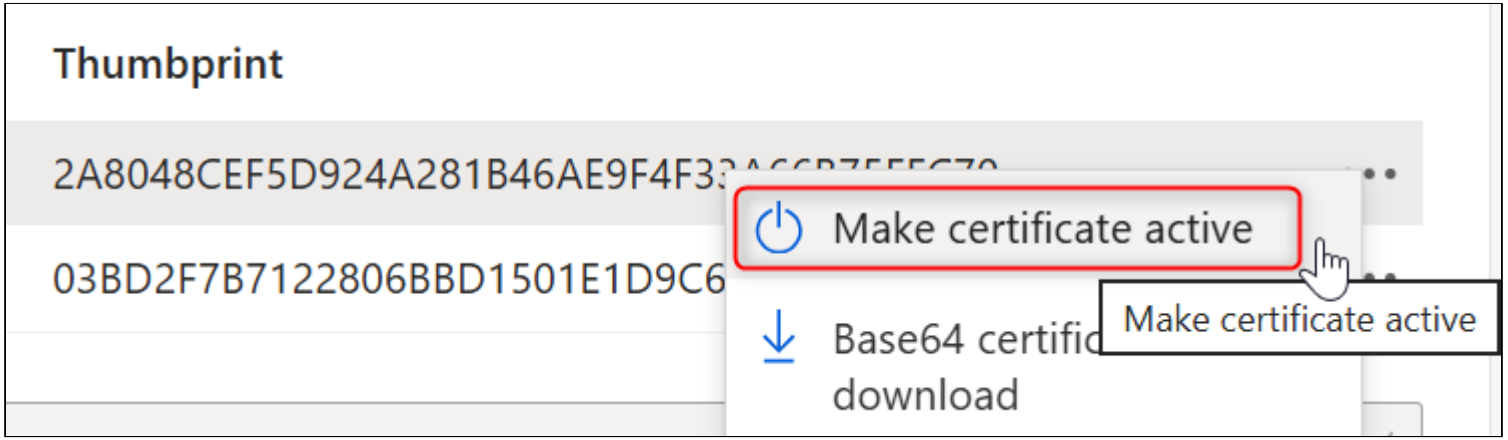
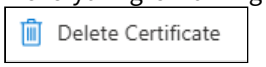
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
1 - Create new Certificate	In your Enterprise Application jump to Manage > Single sign-on  In the Section 3 "SAML Certificates" you can manage the Signing Certificate for your SAML configuration. Click "Edit" and then "New Certificate"  *If you want to import an existing SAML signing certificate, click the button "Import Certificate" and follow the instructions in the Browser. You need to upload a certificate with a private key! This setup is only used in very rare cases.*

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
2 - Configure Expiration Date	A new certificate will be added directly as you can see in the following screen. After setting the correct expiration time **(less then 2 years)** to meet the EISA security guidelines, please click Save to finally store the new certificate.  There is no possibility afterwards to change the certificate expiration. You need to delete and create a new one to set expiration dates! *For more information regarding the security guidelines and contact persons, you can find in the EISA (**EISA-CRY-107.6 - Standards for Asymmetric Cryptographic Key Material):*** https://www.intranet.bosch.com/doku/eisa/EISA-CRY-107.html#ctl$EISA-CRY-107$impl-reqs$6
3a - Configure Application	The new Certificate needs to be added in the SSO configuration of your application. For this step your vendor should be able to support you as this step different for every application. The certificate might be uploaded in a SSO-Settings Admin GUI of the application or it is automatically retrieved by loading the IDP Federation Metadata

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
3b - Activate Certificate	The new certificate is still Inactive. To activate the certificate, please click the **...** at the very right and select " Make certificate active"  As there can be only one certificate active, the old one will be set to inactive immediately and the new one activated. You are able to switch between the certificates, as long both are still valid and not expired.
3c - Test SSO	Login to your application to see if SSO is still working by using a private / incognito Browser.
4 - Delete old Certificate	If everything is working as expected, please delete your old certificate: Go to the old inactive certificate, click the **...** at the very right and select 

4.4.3 Common Issues

4.4.3.1 E-Mail: SAML-SelfService: Signing certificate lifetime exceeded

- Why did I get this E-Mail? The total lifetime of the certificate needs to be considered, not the remaining validity. Yours is longer then two years which is not compliant with EISA regulations.
- How can this be solved?
  - Replace the existing active Certificate as explained above.
  - In case there is an inactive certificate with lifetime exceeded you can simply delete it (Step 4)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4.4.3.2 E-Mail: SAML-SelfService: Signing certificate expiring soon/ expired

- Why did I get this E-Mail?
  - If you haven't replaced your current (active) certificate **or**
  - If you haven`t deleted your inactive certificate
- How can this be solved?
  - Active Certificate: Replace the current Certificate as explained above
  - Inactive Certificate: You can simply delete it (Step 4)

My application is not in use anymore

- In this case the deletion of your SAML-SSO-Configuration is still missing:
  - Please open your "Enterprise application" as explained in the instruction above
  - On the Properties Tab there is a "Delete" button at the bottom of the page
- After you deleted the SAML-SSO-Configuration, there will be no further mails

4.4.3.3 The button "+ new Certificate" is greyed out

- Only Owners are allowed to change the certificate!
- Please check if you are Owner or ask the current Owners to add you

4.5 NameIdentifier formats

NameID format	Description
unspecified urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified	The interpretation of the content of the element is left to individual implementations.
email address urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress	Indicates that the content of the element is in the form of an email address, An addr-spec has the form **local-part@domain**. Note that an addr-spec has no phrase (such as a common name) before it, has no comment (text surrounded in parentheses) after it, and is not surrounded by "<" and ">".

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

NameID format	Description
persistent urn:oasis:names:tc:SAML:2.0:nameid-format:persistent	Indicates that the content of the element is a persistent opaque identifier for a principal that is specific to an identity provider and a service provider or affiliation of service providers. Persistent name identifiers generated by identity providers MUST be constructed using pseudo-random values that have no discernible correspondence with the subject's actual identifier (for example, username). The intent is to create a non-public, pair-wise pseudonym to prevent the discovery of the subject's identity or activities. Persistent name identifier values MUST NOT exceed a length of 256 characters. The element's NameQualifier attribute, if present, MUST contain the unique identifier of the identity provider that generated the identifier. It MAY be omitted if the value can be derived from the context of the message containing the element, such as the issuer of a protocol message or an assertion containing the identifier in its subject. Note that a different system entity might later issue its own protocol message or assertion containing the identifier; the NameQualifier attribute does not change in this case, but MUST continue to identify the entity that originally created the identifier (and MUST NOT be omitted in such a case). The element's SPNameQualifier attribute, if present, MUST contain the unique identifier of the service provider or affiliation of providers for whom the identifier was generated. It MAY beomitted if the element is contained in a message intended only for consumption directly by the service provider, and the value would be the unique identifier of that service provider. The element's SPProvidedID attribute MUST contain the alternative identifier of the principal most recently set by the service provider or affiliation, if any (see Section 3.6). If no such identifier has been established, then the attribute MUST be omitted. Persistent identifiers are intended as a privacy protection mechanism; as such they MUST NOT be shared in clear text with providers other than the providers that have established the shared identifier. Furthermore, they MUST NOT appear in log files or similar locations without appropriate controls and protections. Deployments without such requirements are free to use other kinds of identifiers in their SAML exchanges, but MUST NOT overload this format with persistent but non-opaque values

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

NameID format	Description
	Note also that while persistent identifiers are typically used to reflect an account linking relationship between a pair of providers, a service provider is not obligated to recognize or make use of the long term nature of the persistent identifier or establish such a link. Such a "one-sided" relationship is not discernibly different and does not affect the behavior of the identity provider or any processing rules specific to persistent identifiers in the protocols defined in this specification. Finally, note that the NameQualifier and SPNameQualifier attributes indicate directionality of creation, but not of use. If a persistent identifier is created by a particular identity provider, the NameQualifier attribute value is permanently established at that time. If a service provider that receives such an identifier takes on the role of an identity provider and issues its own assertion containing that identifier, the NameQualifier attribute value does not change (and would of course not be omitted). It might alternatively choose to create its own persistent identifier to represent the principal and link the two values. This is a deployment decision.
transient urn:oasis:names:tc:SAML:2.0:nameid-format:transient	Indicates that the content of the element is an identifier with transient semantics and SHOULD be treated as an opaque and temporary value by the relying party. Transient identifier values MUST be generated in accordance with the rules for SAML identifiers, and MUST NOT exceed a length of 256 characters. The NameQualifier and SPNameQualifier attributes MAY be used to signify that the identifier represents a transient and temporary pair-wise identifier.

4.6 Request new SAML application via Self-Service | Part 1 - IAP portal

Step 1: SAML Onboarding Request

To request a new SAML configuation you need to follow the below steps. Please read as well our terms and conditions, which you can find here. This guide describes the needed steps in detail and provides more important information.
Please read the instructions in detail. If you have any futher question, please contact us via our onboarding mailbox at Onboarding.Bosch-Idp@de.bosch.com.

Step 1 | Open IAP website

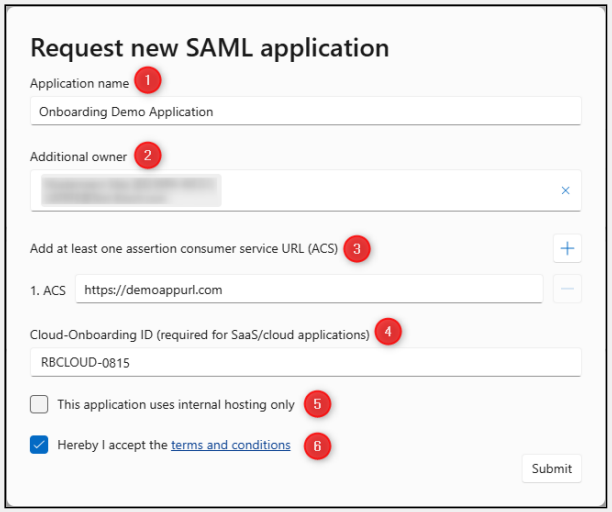
The first step is to open the IAP website to start the request from the displayed dashboard. via

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

BCD (*.bosch.com)	https://rb-iap.bosch.com/new/entraID/applications/saml
Q9 (*.test-bosch.com)	https://rb-iap.test-bosch.com/new/entraID/applications/saml

4.6.1 Step 2 | Start the request

1. Click the button Request new SAML application on the dashboard. The following screen appears:



1	**Application Name** Please choose a short speaking but meaningful name for your application (max. 120 characters). There is no technical impact.
2	**Additional owner** We need at least 2 owners for the application as contacts and as responsible persons for the configuration. In the initial request you can only add one additional owner. Later in the Entra ID enterprise application configuration you can add more owners if you need.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	3	**Assertion Consumer URLs** These are the endpoints, to which the IdP sends the issued SAML token. This value can only be changed via IAP and is a required field during the request. Based on this URL we can see if this is an internal or cloud hosted application. Based on that value we can also check the need of the cloud onboarding. More Assertion Consumer Service URL can be added or removed by clicking the **+** or **-** button on the right side. Assertion Consumer Service URL with parameter In case you have parameters in your Assertion Consumer Service URL, as for example https://www.myurl.com?parameter=abc then it is important that you: • add a / in front of the ? if the parameter is directly after the root domain, like e.g. https://myurl.com/?*parameter=abc* • it is not allowed to have the "?" in the root domain URL

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- you can add the ? without a / if the parameter is not directly after the root domain, like e.g. https://myurl.com/somethingels?*parameter=abc*

Assertion Consumer Service URL from federation metadata xml file

In case you have a federation metadata xml file provided from your vendor/application, please ensure to use the correct one from the file. You can find the right value in the xml file as follows und the tag "AssertionConsumerService" within the "Location="" property:



If this is not the case, your reply URL imported later on to the EntraID configuration will be overwritten with the one, you configured while the onboarding.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	4	**Cloud-Onboarding ID (for SaaS applications only)** In case your application is hosted outside of Bosch datacenters or Bosch managed cloud environments like AWS or Azure (like e. g. typically SaaS applications) you need an approved and finished Cloud onboarding Workon process. To enable us to check the status of this process, please provide the valid RBCLOUD-xxxx workon number. If you have not started or finished the cloud onboarding, please stop here the request and first do the cloud onboarding process. You can find more information on the docupedia page of the owned service: https://inside-docupedia.bosch.com/confluence/x/e9PVo If the cloud onboarding is not valid, finished or approved or you did not provide a correct number, we need to decline your request. A declined request cannot be updated later on. The request must be restarted from scratch.
	5	**Internal hosting** In case you have an **internal hosted application** without need of cloud onboarding, please mark this checkbox accordingly. This removes any Cloud-Onboarding ID that was provided before and checks the configured assertion consumer URLs against a whitelist for internal hostings on submit.
	6	**Terms and Condition** To submit the request, Terms and conditions need to be accepted after reading.

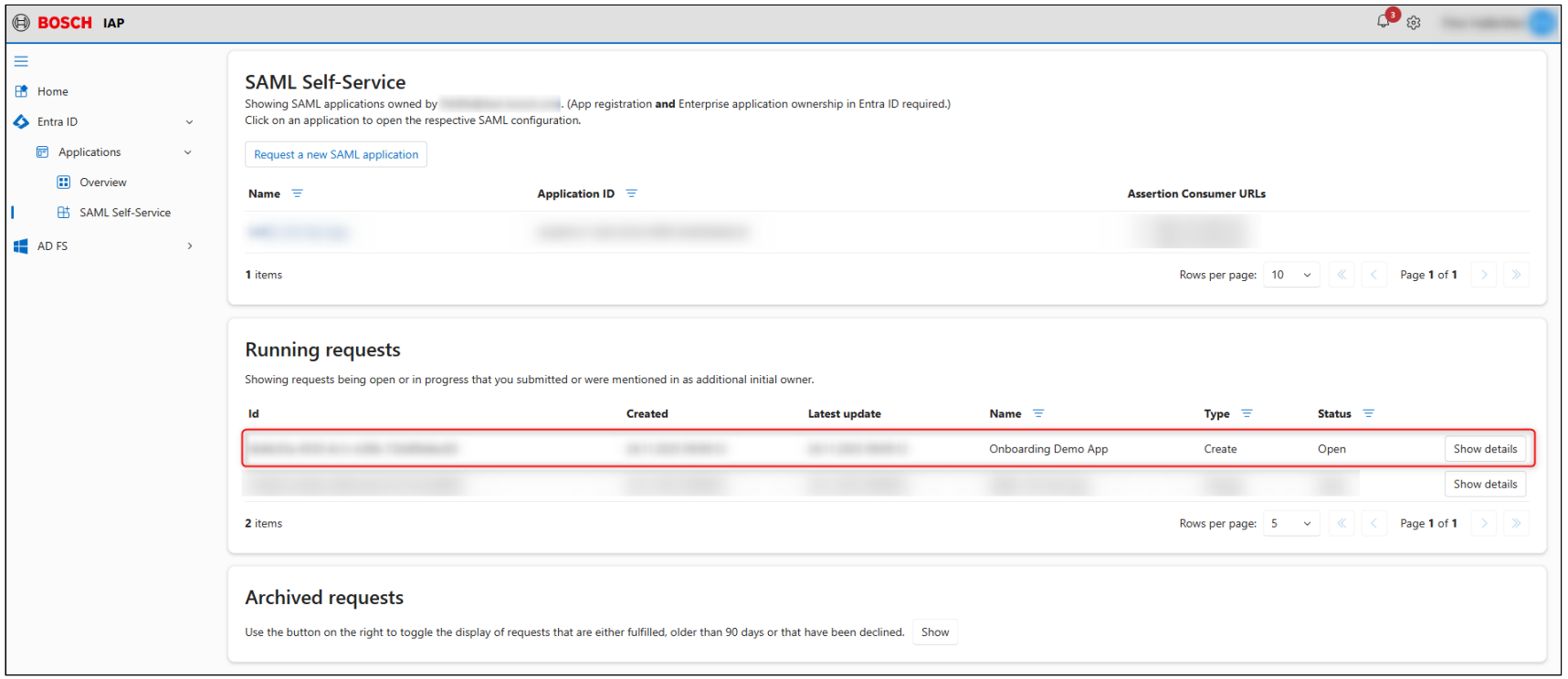
2. Only the above mentioned information needs to be added to the request. All further information, like e.g. Entity ID or claims can be set directly in the Entra ID enterprise app configuration. Once you have entered valid data and filled out all fields, you can send the request by clicking the Submit button.

4.6.2 Step 3 | Waiting for approval

1. Once the request has been sent, you will receive a mail as confirmation that your request has been submitted successfully. It will be checked by our team for plausibility.

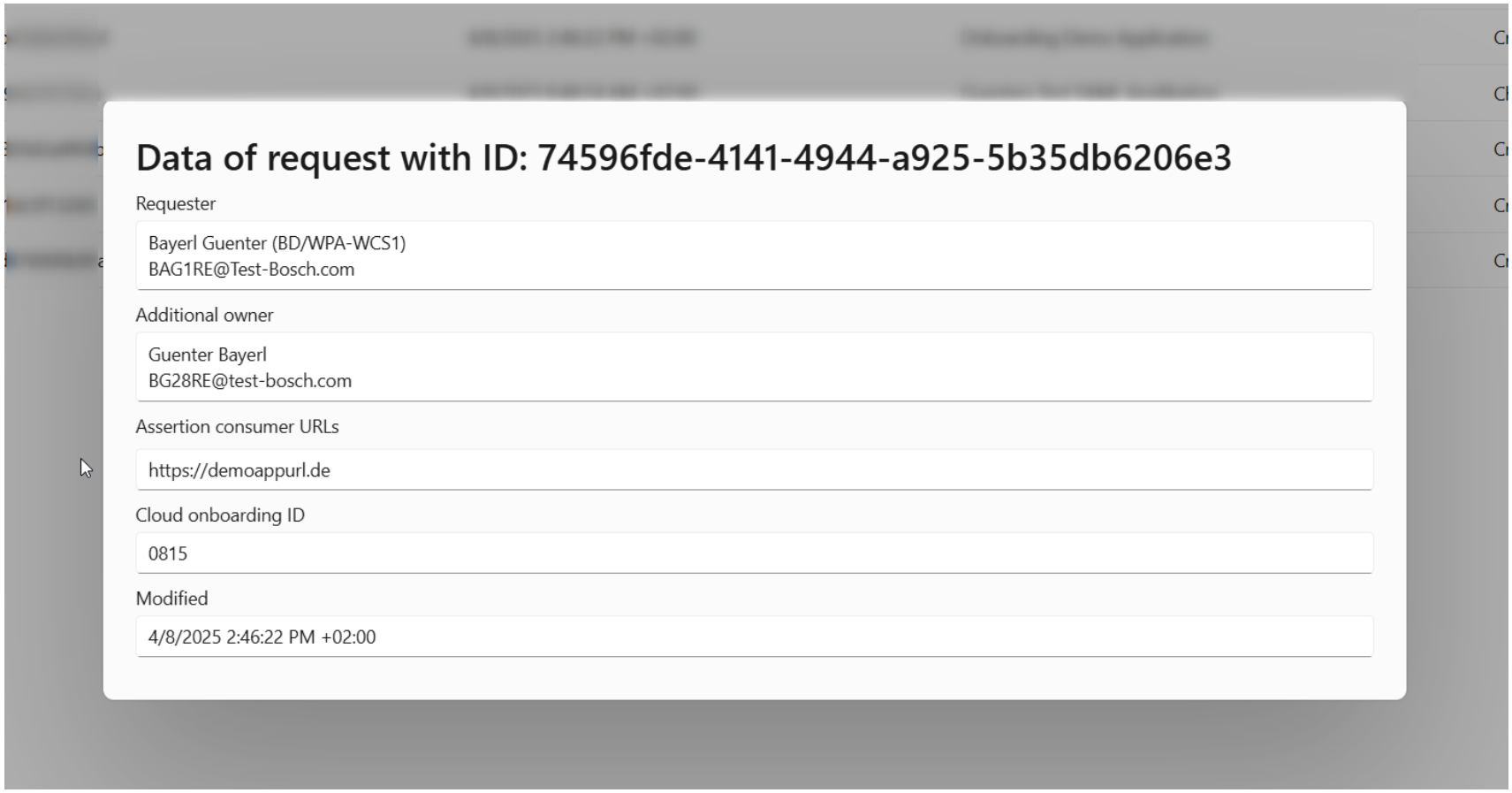
   You can see the status of your request in the "Running requests" overview as you can see in the next screenshot.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



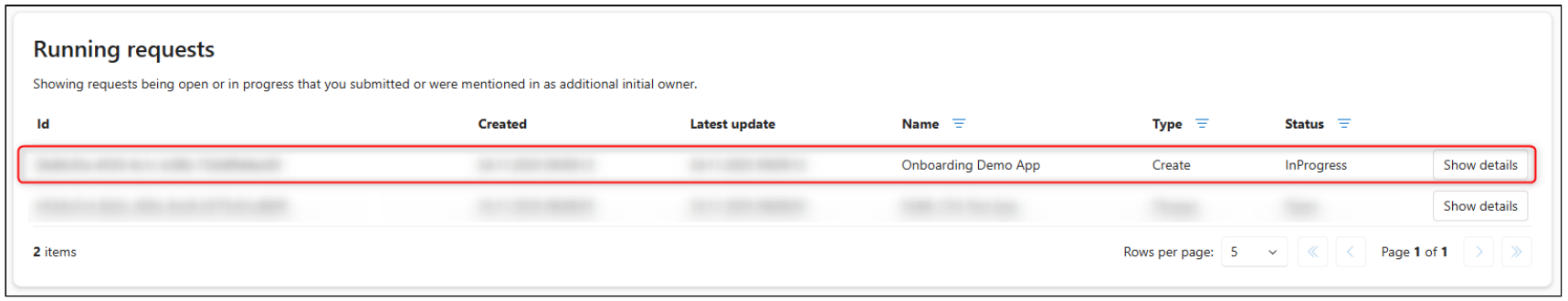
You can see again the details of your request by clicking the Show details button

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



2. In the next step, the team picks your request and perform the checks. The status changes to "In Progress" as you can see in the next screenshot

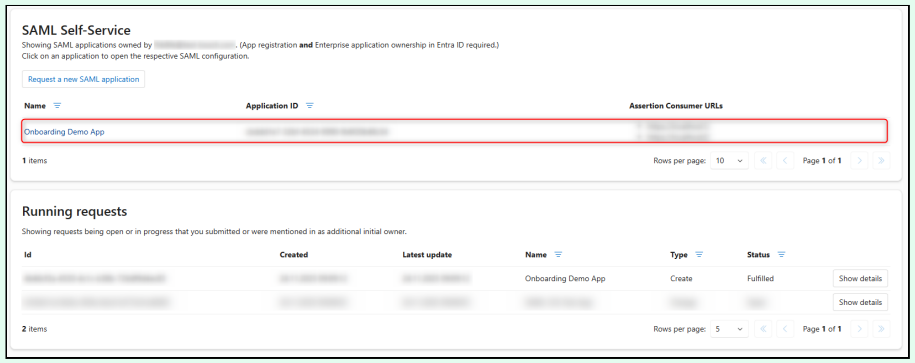
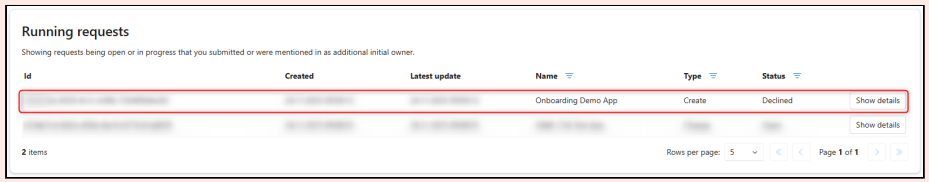
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Once the check is finished, you will get a notification if the request is approved or declined.

Request is approved	Request is declined
In case of an approval, your application appears in the "SAML Self-Service" section and you will receive an Email notification. The onboarding has been finished successfully and from now on you can manage your application by yourself. You will find all links and details by clicking on the name of the applcation.	In case of a decline, the application stays in the "My Requests" section but with the status "Declined". You will receive as well an Email with further details. The onboarding ends here and you are not able to change settings on that request. Please fix the issued based on the information you receive in the mail and start the onboarding process from beginning. You can find a list of possible decline reasons here: https://inside-docupedia.bosch.com/confluence/x/BdRATwE

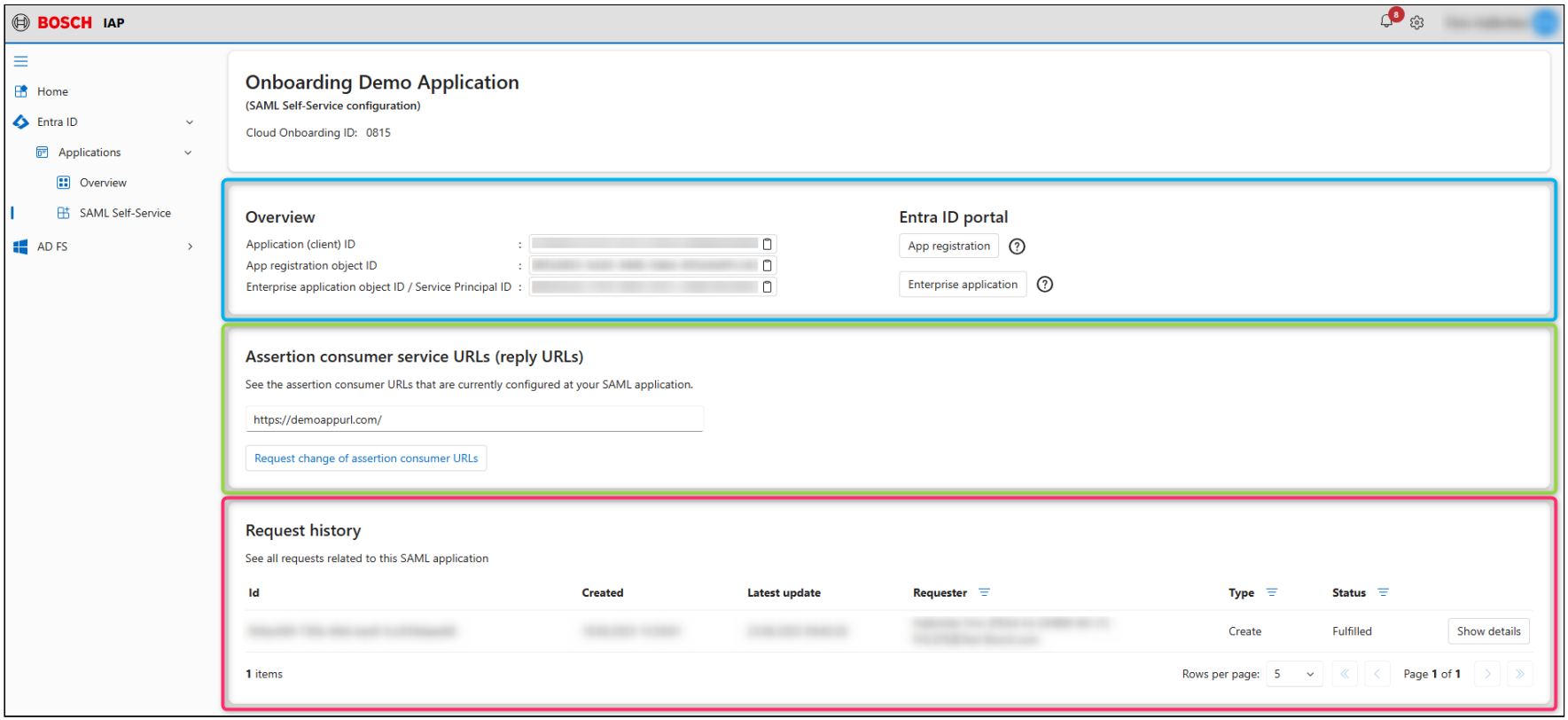
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Request is approved	Request is declined
	

4.6.3 Step 4 | Change SAML settings for your application

From now you can manage your SAML configuration by your own. The entry point to all possible settings you can find within the overview, you can access by clicking the "Show" button in your "My SAML applications" overview. The following screen appears:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



4.6.3.1 Overview

In the section "Overview", you can find some general information, like e.g. application ID. Further you will find two buttons to directly jump into the EntraID pages where you can change the settings. For more details [follow the 2nd part of the guide](#).

To jump to the ***App registration*** (e.g. to configure roles) of your configuration, please click on the button App registration

To jump to the ***Enterprise application*** (e.g. to configure claims and groups) of your configuration, please click on the button Enterprise application

4.6.3.2 Configured assertion consumer URLs

You are not allowed to change the Reply URL (Assertion Consumer Service URL) within the Microsoft EntraID overview due to security reasons. Please use the green section here, to change the URLs. It will be synchronized from IAP to EntraID after the request was checked and approved by our team.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4.6.3.3 Requests related to this application

Here you can find an overview of all requests you or another owner has done for this application. You can see mor details by clicking the Show details button.

4.7 Request new SAML application via Self-Service | Part 2 - EntraID

Step 2: Identity Provider Configuration

The second part of the step-by-step guide will focus on the EntraID part. Here you can manage owners, SAML handshake parameters, like EntityID or SSO logout endpoint or certificates which you need for setting up your SAML configuration. As owner it is technically possible to change all settings on the Enterprise application and the App registration.
A general instruction by Microsoft can be found here: Enable SAML single sign-on for an enterprise application - Microsoft Entra ID | Microsoft Learn

Important
Due to security reasons you are not allowed to change some settings, which are listed below. We will monitor such settings and reset them to the default values or as set in the IAP system. The affected settings are:

- **Reply URL (Assertion consumer service URL)**
  In general it is possible to change the Reply URL in your IAP configuration, as the change needs to be checked and approved by our team. Once it is approved, the setting will automatically overwrite the setting in EntraID.

- **Authentication method**
  The authentication method must be always SAML. All other settings will be overwritten to the default.

- **Activation of SCIM**
  SCIM is not offered by our team. Please have a look to https://rb-oneidm-help.bosch.com/en/data/scim.html and contact the IdM team at Mailbox.IdMIntegration@bosch.com

- Step 2: Identity Provider Configuration
- Open Application Config in Azure
- Manage Owners
- Single Sign-On settings

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

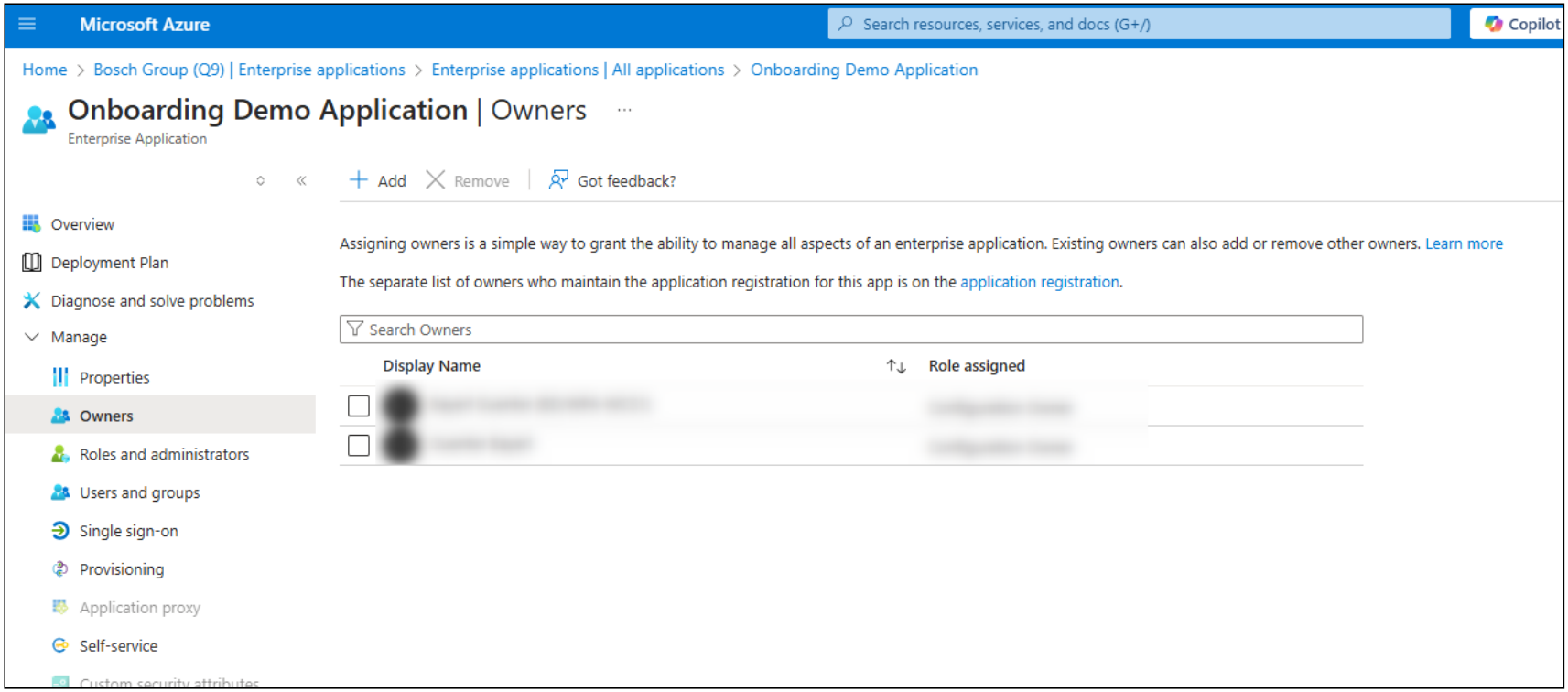
- Basic SAML Configuration
  - Upload Federation Metadata
- Attributes and Claims
- Limit user by groups assignment
- SAML Certificates

4.7.1 Open Application Config in Azure

From the IAP-Portal you can jump to the **Enterprise Application** of your SAML app in Azure. There you can do the settings described on this page:

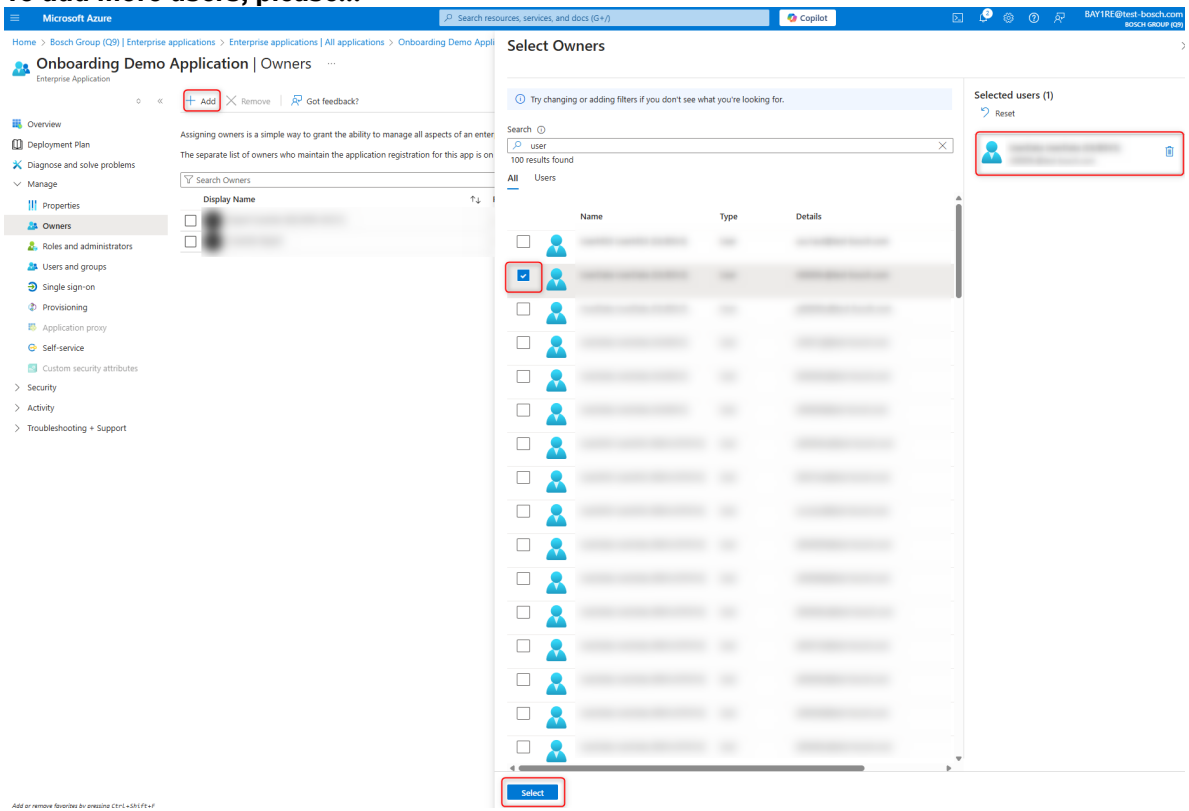
4.7.2 Manage Owners

Owners of the application have full permissions to all settings within the enterprise application. An owner can set and change Single Sign-on settings, like EntityID, claims and manage Users and Groups. In the owner section you can add and remove the owners which should be able to change such settings for your application. Please ensure, that there are always at least a minimum of two owners configured in the enterprise application.
Owners can only be user accounts and no groups!



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

To add more users, please...



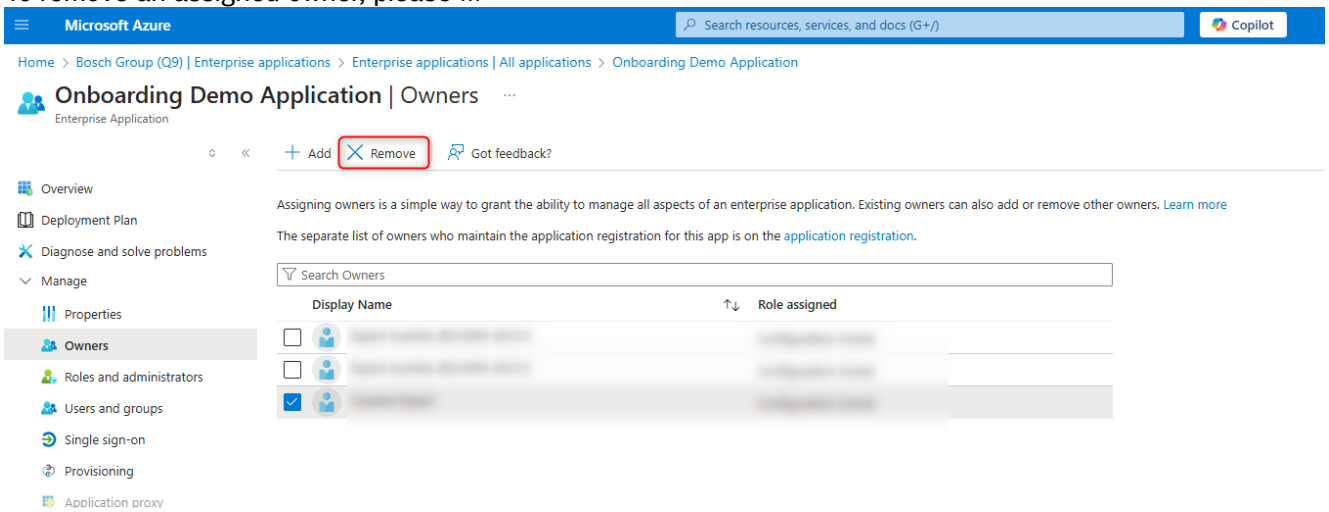
1. click the 

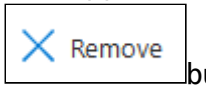
button at the top of the owners overview.
2. search for the username, you want to add in the open dialog and select the user (As soon, you select the checkbox in front of the username, the user appears in the list on the right side.
   You can directly search for another user and add it to the list as well. Do so, as many users you want to add.)
3. If all users are selected, click the 

button on the bottom to add the users to the owners list.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

To remove an assigned owner, please ...



1. select the user(s) in the owners overview by selecting the checkbox in front of the username
2. click the 

button to remove the users from the owners list.

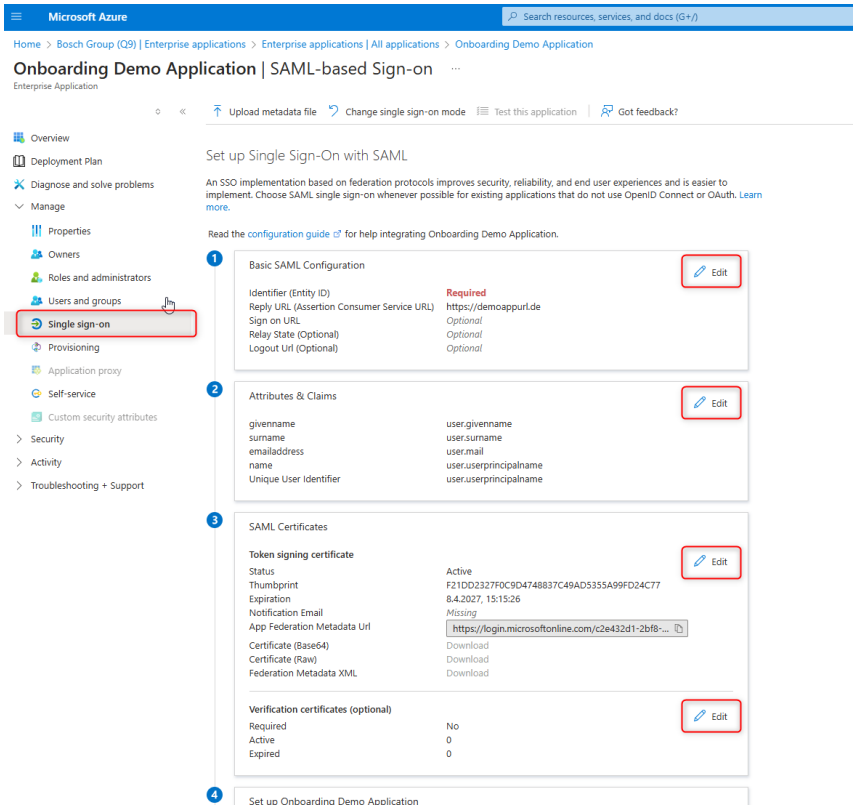
4.7.3 Single Sign-On settings

To add or change the basic SAML settings, like EntityID, Single Logout endpoint, please open "Single Sign-On" in the main navigation. The following screen appears.

To change settings in one of the sections, click 

in the section, to be changed.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



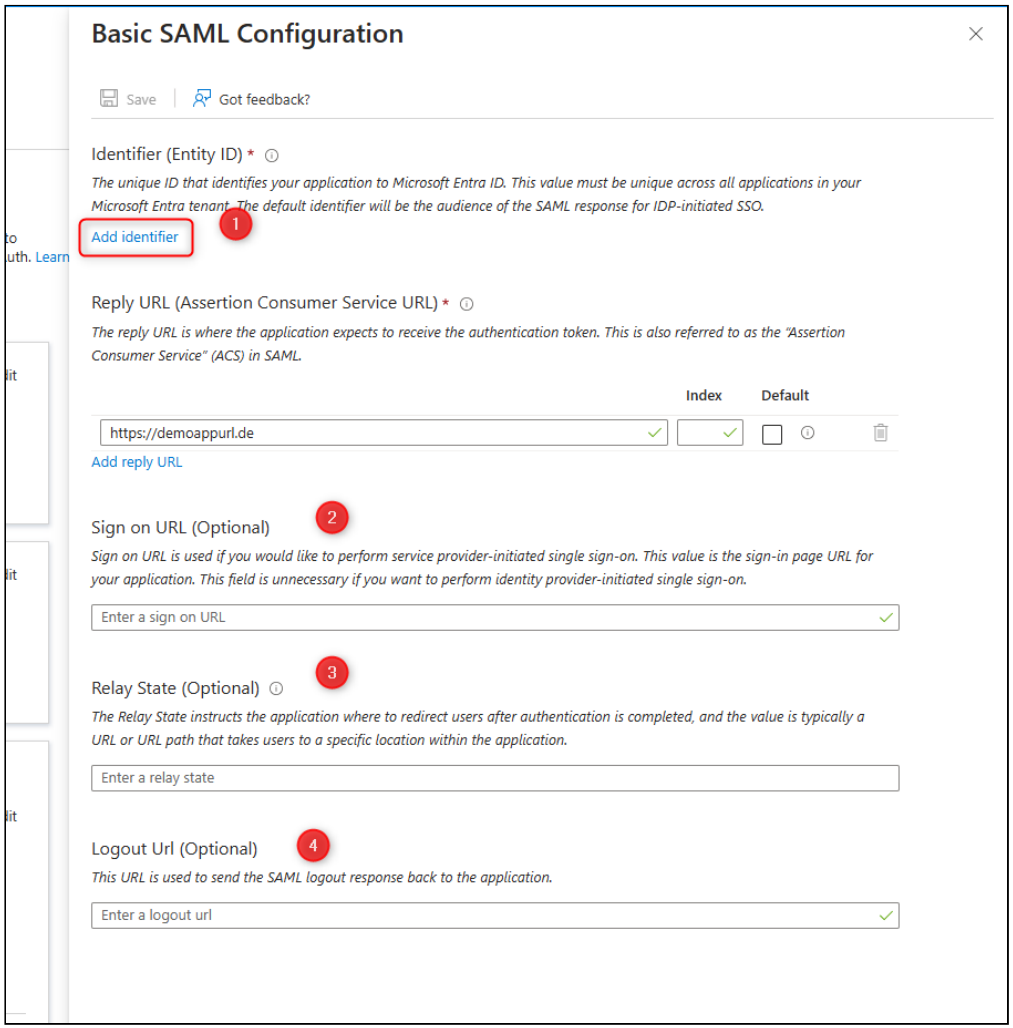
4.7.3.1 Basic SAML Configuration

In this section you can configure the basic technical parameters, like EntityID and SSO endpoints of your application. You can find more details on the Microsoft pages (https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/what-is-single-sign-on).

Important

Please be aware that changing the Reply URL (Assertion Consumer Service URL) is not allowed to be changed here. Please return to the IAP portal and do all changes (see https://inside-docupedia.bosch.com/confluence/x/YJoQWAE). All changes made here, will be overwritten by our service to the settings, stored in IAP.

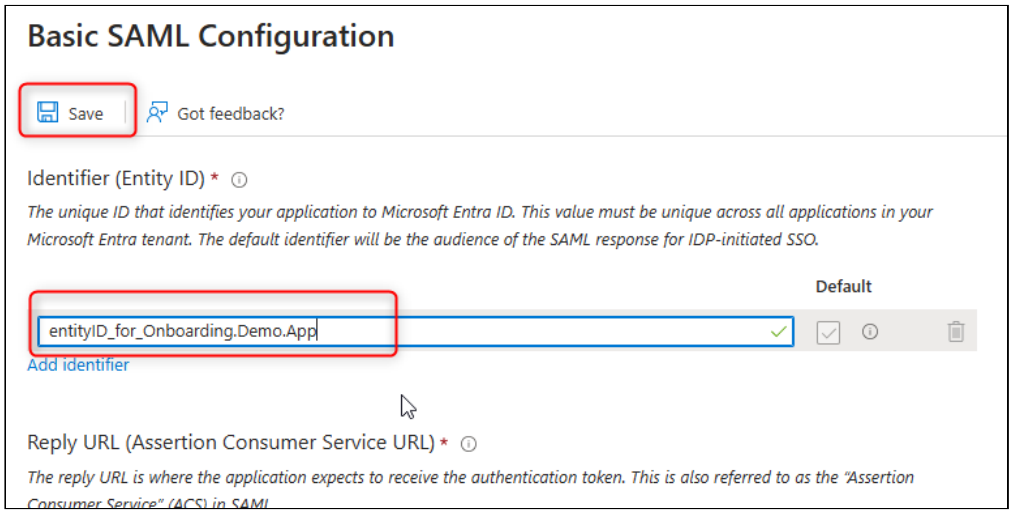
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Identifier (Entity ID) *mandatory

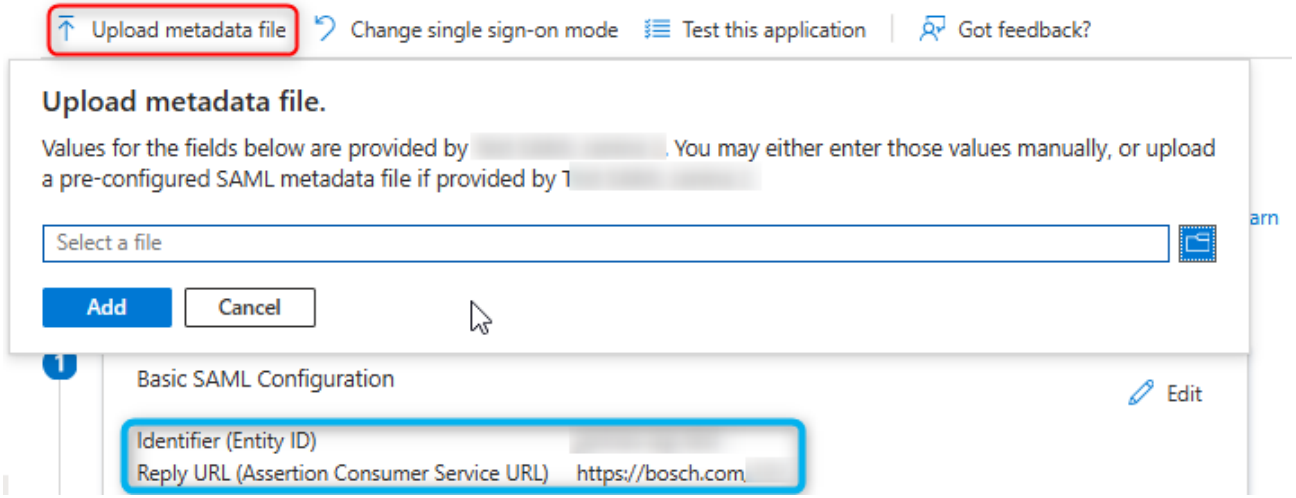
The Entity ID is a mandatory field. It represents the unique identifier within the IdP environment. With the request to authentication, the application provides exactly this value to uniquely identify which configuration must be used to authenticate the user and provide the SAML token. The EntityID id a string and is case sensitive.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



4.7.3.1.1 Upload Federation Metadata

Instead of adding the Entity ID manually, a Service Provider Metadata File (.xml) can be uploaded. If the vendor of the application offers such a file, it can be uploaded in the Azure configuration and it will automatically overwrite settings of the Entity ID and Reply URL. Therefore please make sure that the Reply URL is the same that you requested in the SAML Onboarding Request!



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4.7.3.2 Attributes and Claims

To adopt the claims to the need of the application, you can setup the claim set accordingly. For more detailed information, please have a look to our claims overview, which you can find at Bosch Attributes and Claims - Directory Services - Docupedia. General instructions from Microsoft can be found here: https://learn.microsoft.com/en-us/entra/identity-platform/saml-claims-customization

For more information about group claims, we offer an overview here: Groups and Authorization

4.7.3.3 Limit user by groups assignment

By default the configuration is setup that only users which are assigned to the application in the "users and groups" section will get a SAML token issued by the Entra ID.

Possible Error

If you have no group assigned and the Assignment Required set to "Yes" the **SAML-login will fail** with the error message AADSTS50105 ([...] has configured the application [...] to block users unless they are specifically granted ('assigned') access to the application [...])

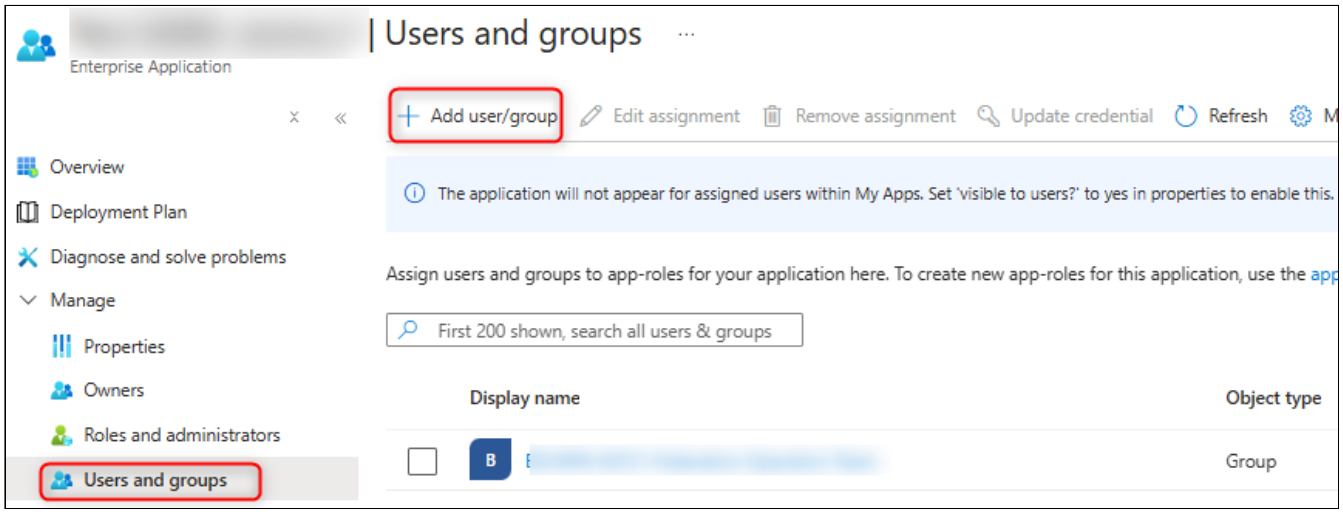


Therefore please follow the steps below (either Option A or Option B) to resolve this

Option A: Assign Groups

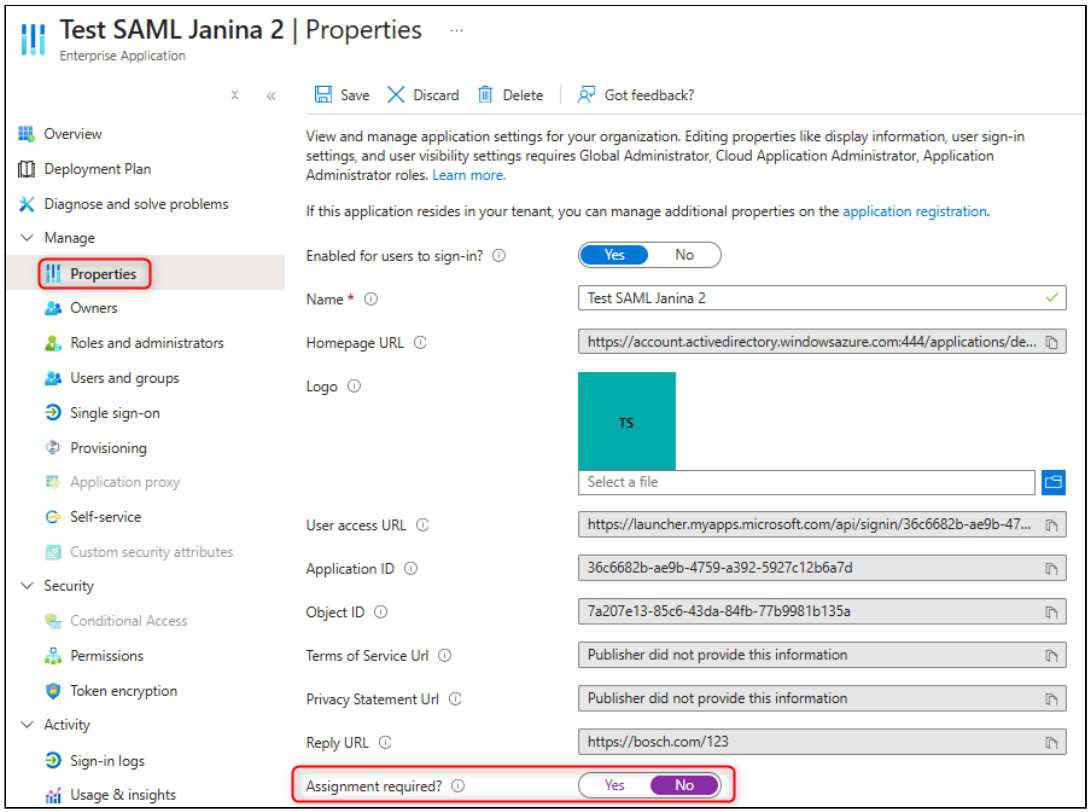
Assign groups to the applications configuration in the section "Users and groups". Please be aware only direct members can be used for this. We recommend to use idm2bcd groups/roles or itsp-managed AD groups for this scenario.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Option B: Remove Restriction
OR: If there is no need for this restriction (for example your authorization concept is built inside the application) you can adapt this in the Properties of your SAML configuration in EntraID by changing the setting "Assignment required" to "No". With this setting every Bosch user will get a SAML token for your application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



4.7.3.4 SAML Certificates

In the SAML certificates section you can manage the token signing certificate for your SAML configuration. You can see and download the current valid certificate and you can also create a new certificate. Furthermore, you can manage the Email addresses which should be notified in case the current token signing certificate is about to expire.

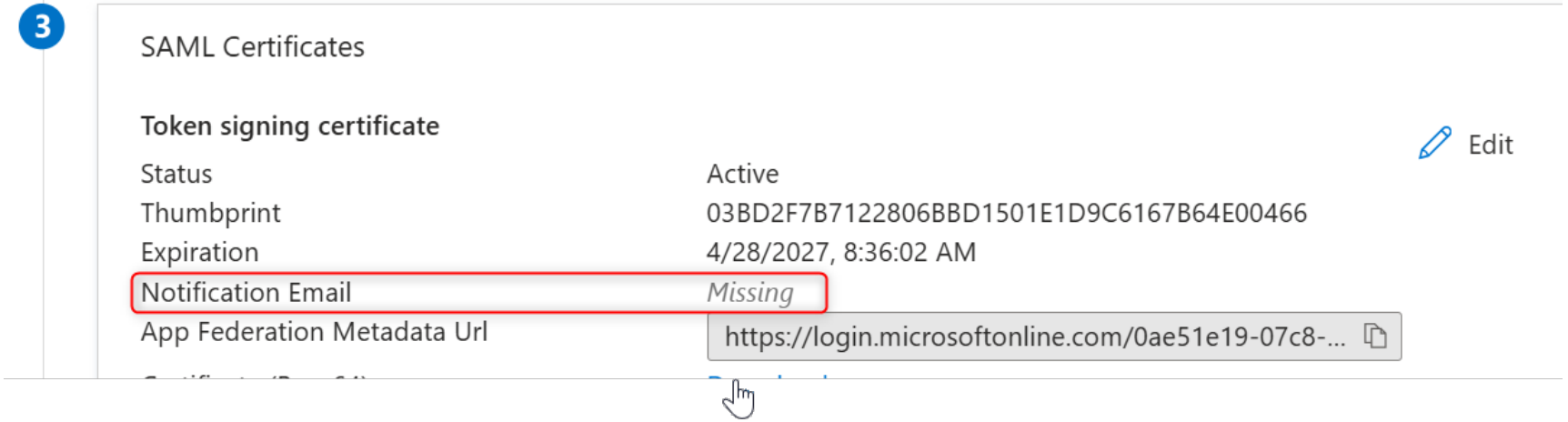
This certificate needs to be replaced regularly. Please update your certificates in time to avoid a service downtime of your SAML application as explained in Change SAML Signing Certificate - Directory Services - Docupedia

Important
Please ensure to meet the EISA security guidelines in terms of exchange of certificates within two years!

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

For more information regarding the security guidelines and contact persons, you can find in the EISA (***EISA-CRY-107.6 - Standards for Asymmetric Cryptographic Key Material)***
https://www.intranet.bosch.com/doku/eisa/EISA-CRY-107.html#ctl$EISA-CRY-107$impl-reqs$6

Manage notification email addresses
To get notifications when the certificate is about to expire, please manage one or more valid Bosch internal email addresses which should be informed. The notification will be sent out approx. 4 weeks before the certificate is about to expire.



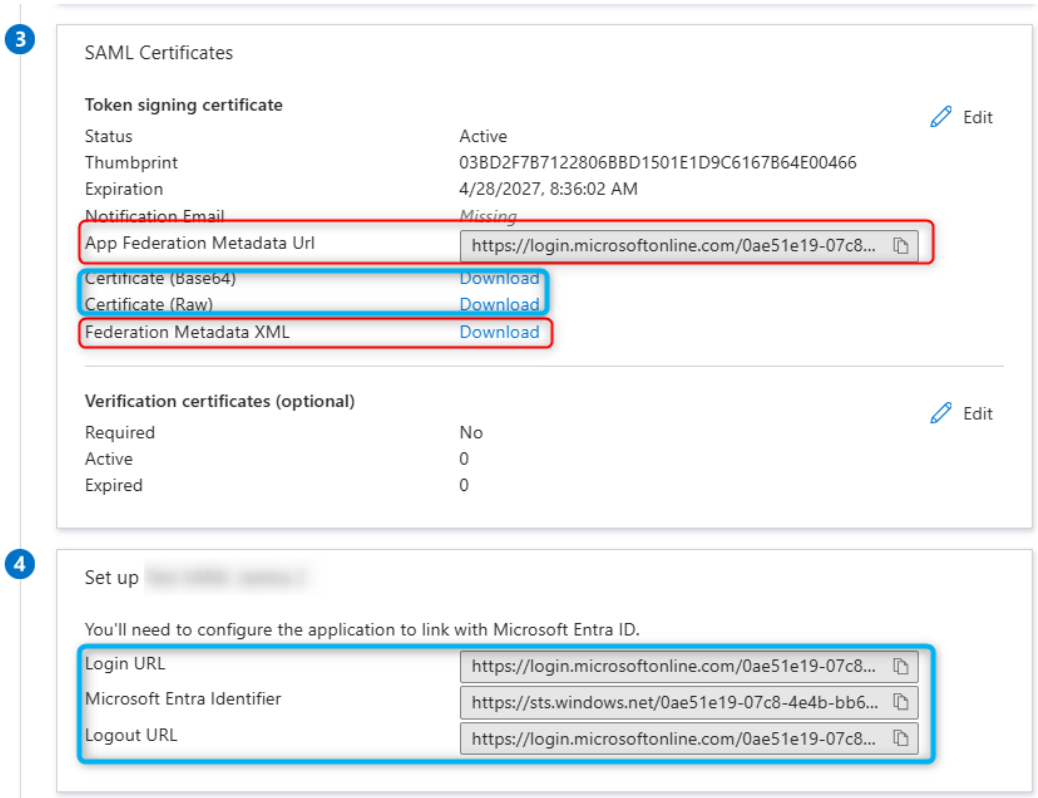
4.8 SAML Configuration | Part 3 - Application

Step 3: Application Configuration

4.8.1 Get the information to configure your application

Finally you need the information, how to setup your application to forward authentication requests to the EntraID and validate the responses.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



4.8.1.1 Federation Metadata XML file

Therefore you need the **federation metadata file**, a standardized xml file where you can find the needed information within.
Many applications support to import or link to the federation metadata xml file to catch all needed information directly. Some of the applications also support an auto update of the information. In case you update the certificate, the federation metadata file on the Idp changes as well. So the application can be always up-to-date.

You have two options (see picture above):

1. Download the URL
2. Copy the link to post it to your configuration

Which option you need, depends on your application

4.8.1.2 SSO-Endpoints and Certificates

Some applications expect the Identity Provider Details as single entries:
The **certificates** can be downloaded from Entra ID directly (see picture above) and you will find them as well in the federation metadata xml file.
Single Sign-On and Single Sign-Out **endpoints:**

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- Microsoft Entra Identifier (EntityID): https://sts.windows.net/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/
- Login URL: https://login.microsoftonline.com/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/saml2
- Logout URL: https://login.microsoftonline.com/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/saml2

The endpoint information can be found in Entra ID (see picture above) and as well in the federation metadata xml

4.9 SAML Request Decline use cases

4.9.1 Decline use cases

When requesting a new SAML configuration for EntraID, you need to fulfill some preconditions which you can find in our Terms and Conditions part at https://inside-docupedia.bosch.com/confluence/x/LoiMY.
Each request will be checked to meet our preconditions. In case, it is not the case, we need to decline the request. We provide you with the link to the section with the reason, so that you are able to correct it and resend the reuqest.

4.9.1.1 Cloud Onboarding

Cloud or SaaS onboarding is a process, not owned by our team. To find more information regarding the process, contacts or if a cloud onboarding is needed for your application, please follow the information at SaaS Onboarding - WorkON - IoT & Digitalization - Docupedia.
In case cloud or SaaS onboarding is needed for your application, you must provide the workon number (RBCLOUD-xxxxx) of the already finished and approved workon process within the request. In case it is missing, not relateable to your application, not yet approved or declined, we will decline the request. We will send you the expanation of the reason by providing the link to the correct sub entry.

4.9.1.1.1 No or wrong Cloud Onboarding workon number provided

Your assertion consumer service URL points out, your application is not installed at the on premesis network but in the cloud. For your application, an approved cloud onboarding is needed. Please follow the link SaaS Onboarding - WorkON - IoT & Digitalization - Docupedia to get more information about the process.
In your request you did not provide a cloud onboarding workon number or a number which is not associated with your application. If you did not start the cloud onboarding process, please follow the process and restart the request, once your cloud onboarding is finished or approved.
If you have already finished the process with an approved workflow, please restart the request as well with the number provided.
If there is no cloud onboarding needed for your application, plaease forward the confirmation mail, you got from the cloud onboarding process owner to proof, for your application, a cloud onboarding is not needed.

4.9.1.1.2 Cloud onboarding process not yet approved or finished

You have already started the cloud onobarding process but it is not finished and approved so far.
To continue the SSO onboarding, a finished and finally approved cloud onboarding is needed. Please resend the request, as soon your Cloud Onboarding process is finished

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

4.9.1.1.3 Cloud onboarding request declined

If your applicaiton needs a cloud onboarding but it has been declined by the cloud onboarding team, we will not onboard your application to SSO. Please come back once you have a valid cloud onboarding and resend the request again.

4.9.1.1.4 Personal-related data set to "No" in Cloud Onboarding

Attribute "personal-related data" is set to No in your cloud onboarding documentation. This is not correct, as with the SSO token, personal data will be sent to and stored inside the application.
We approved your configuration, as you set the attribute "Personal data - ISP" to Yes in LeanIX.
The responsibility of doing security checks and documentation correctly.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5 OIDC Configuration

Overview

- Step 1: Identity Provider Configuration
  - Initial OAUTH/OIDC App registration
  - App registration: Basic Settings
    - Configuration of secrets for confidential clients
    - Configuration of Redirect URIs
  - Manage Owners of the application
  - Additional Claims
  - Scopes
  - Authentication Context and MFA
  - Further information
- Step 2: Application Configuration
- Step 3: Admin Consent Approval

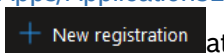
To follow industry standards, we adapt the official OIDC framework which is an Identity layer built on top of the OAuth 2.0 authorization framework RFC 6749 for the SSO integration. OIDC allows third-party applications or services (the one you are building or consuming from another vendor) to verify the identity of the Bosch associate or external partner and to obtain basic user profile information. Whereas OAuth2.0 is about accessing resources and honoring authorization concepts, ODIC is required for the user authentication. Using OIDC protocol and integration provides the benefit to use one single Identity provider - such as the Bosch Entra ID SSO service - to identify and authenticate users across multiple applications and services in a seamless way.
It is important to properly integrate the official OIDC framework for the Bosch SSO to not only be compliant with internal Security Governance regulations but also to follow along industry standards.

5.1 Step 1: Identity Provider Configuration

> Your configuration can be done on Azure portal. There you can create an App Registration

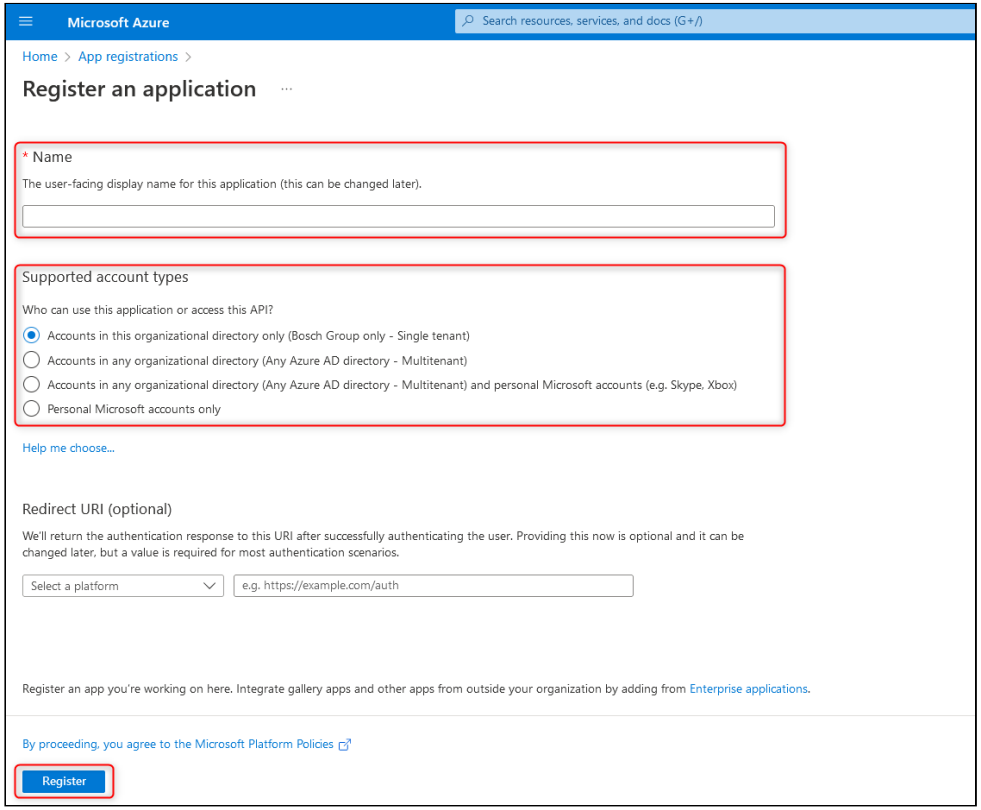
To use the Entra ID identity and access platform to authenticate users for your application you have to register the application initially. Only for registered applications authentication and authorization with the Entra ID accounts is possible.

5.1.1 Initial OAUTH/OIDC App registration

Browse to https://entra.microsoft.com/#view/Microsoft_AAD_RegisteredApps/ApplicationsListBlade/quickStartType~/null/sourceType/Microsoft_AAD_IAM with your Bosch office account to start the registration dialog by clicking the button 

at the top of the page. The following dialog screen will appear...

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Please choose and enter a meaningful and unique **name** for your application and select the correct supported account type. The Redirect URIs will be entered in a later step. Keep this empty for the moment.

Supported account type
In the supported account type section you can define which users are allowed to authenticate for your application. The default setting is "Accounts in this organizational directory only (Bosch Group only - single tenant". Please keep this item selected. It means that only corporate Bosch accounts will be authenticated for this applications.

The options Multitenant or personal accounts are not allowed to be used at BOSCH!

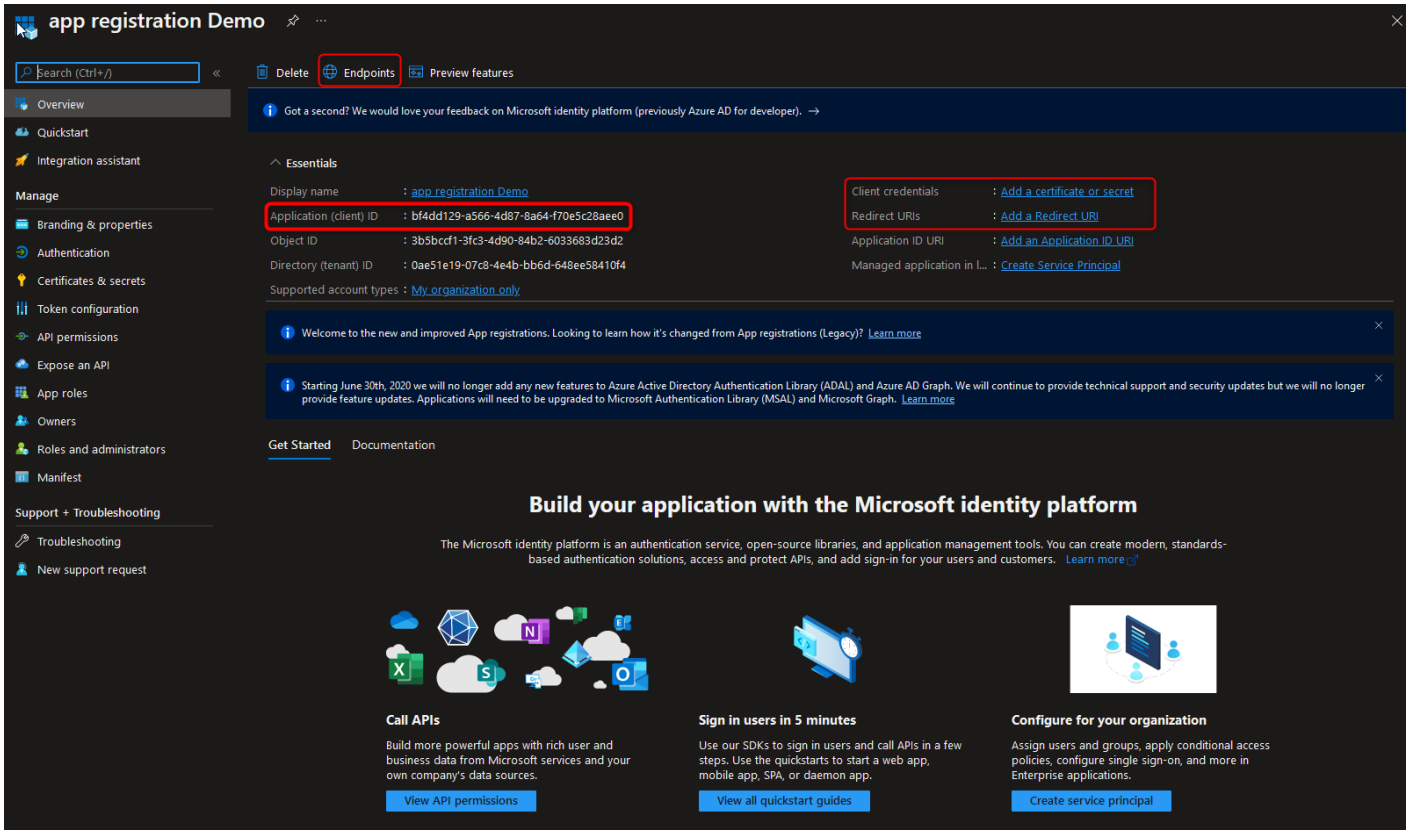
When done click the button **Register** to get your application registered. You will be forwarded to the overview page of your registered application as shown in the next

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

screenshot

5.1.2 App registration: Basic Settings

Here you can find important information like the **Client ID** or the **overview** for the needed endpoint information and you have links to the next needed steps in the registration process. In the screenshot below some important parts are highlighted.



1. **Client ID**
   The client ID is needed in your OAUTH/OIDC configuration. It is used to uniquely identify the application and you have to define it in the settings of your application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

2. **Endpoints**
   With this button you can find the needed Entra ID endpoints for the configuration in your application (e.g. the token endpoint, the authorization endpoint or as well the link to the .well-known/openid-configuration metadata endpoint)
3. **Client Crentials link**
   Follow this link to create a secrete or certificate which are used for confidential client applications. you can use either a certificate and/or a secret (handled like a password) to protect your client.
   Jump to detailed description
4. **Redirect URIs link**
   A redirect URI is an endpoint where the Identity provider redirects the user and issues security tokens after a successful authentication.
   This could be a link/url to the endpoint of your web application or as well another URI like in mobile applications.
   Redirect URIs in the app registration process will be configured based on their platform type (Web application, Single page application, mobile application, ...)
   Jump to detailed description

5.1.2.1 Configuration of secrets for confidential clients

The following steps are for confidential clients e.g. if your application is using the Code Authorization Flow or the Client Credential Flow (more details can be found here). Therefore they are required for most applications, but e.g. should not be set for Single-Page-Applications (SPA)
You will get to this dialog by clicking the link in the applications overview page (described above) or by selecting the "Certificates & secrets" navigation entry in the left navigation bar.
Once you are in the dialog you can select "Certificate" or "Client secrets"

1. **Certificate**
   In this section you can upload a certificate to be used as a "secret". It is recommended to use certificates as they are more secure then secrets!

Certificate Recommendations
There are no special requirements for these Certificates. You can use self-signed (create e.g. via OpenSSL, Powershell, ...), your SSL-certificate (if it is not rotated automatically) or certificates from a well-known certificate authority.
Be aware of the regulations from CD 9000 for Certificates:

- Exchange Certificate within 2 years:
  EISA-CRY-107 - Cryptographic Key Management
- For RSA min 3072 Key Length and SHA-256:
  EISA-CRY-103 - Cryptographic Mechanisms: Algorithms, Key Lengths, and Protocols

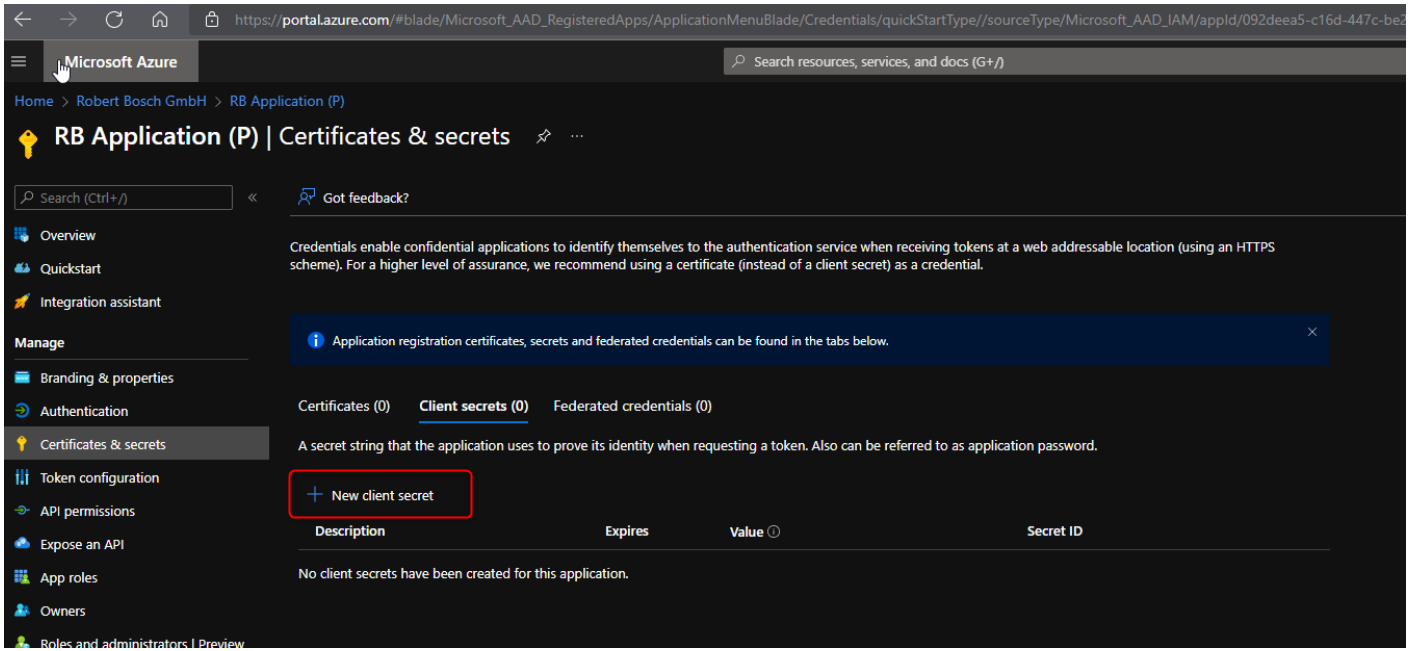
2. Client secrets
To create a new secret for your confidential client you need to click the button "+ New client secret". On the right side a new dialog will appear you you cat create the secret. Give the secret a meaningful name and choose the expiration time. Please ensure to meet the limitiation and rules of the EISA, which you can find

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

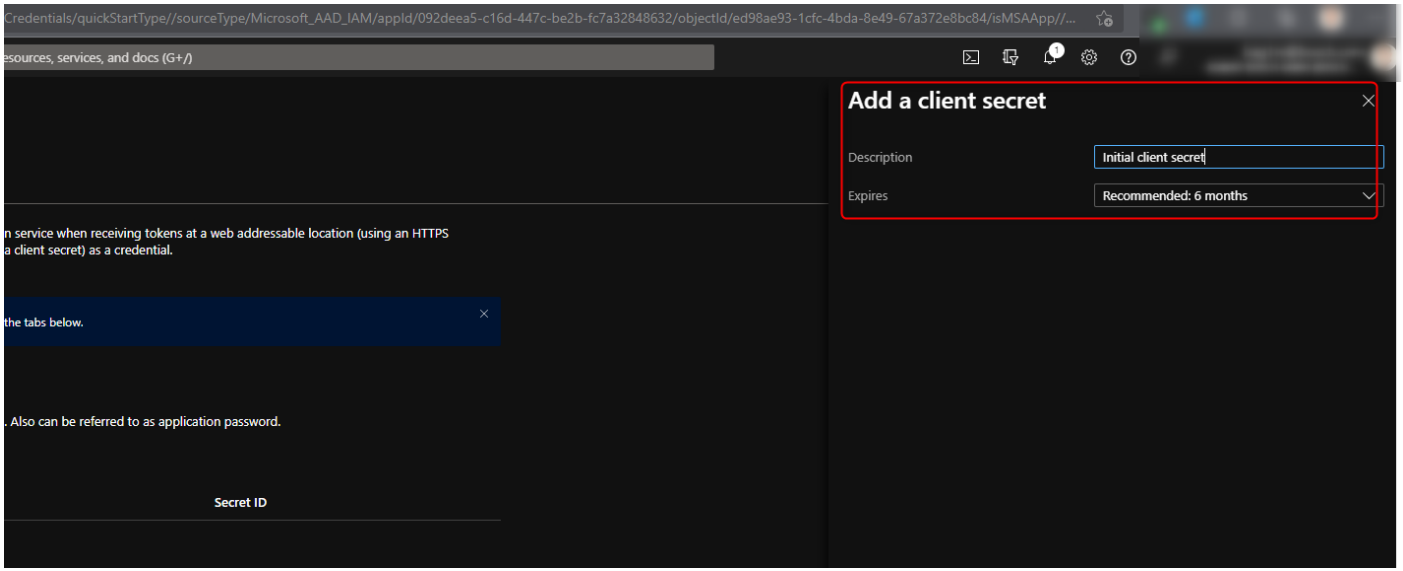
here: https://www.intranet.bosch.com/doku/eisa/EISA-ACC-301.html#ctl$EISA-ACC-301$impl-reqs$6

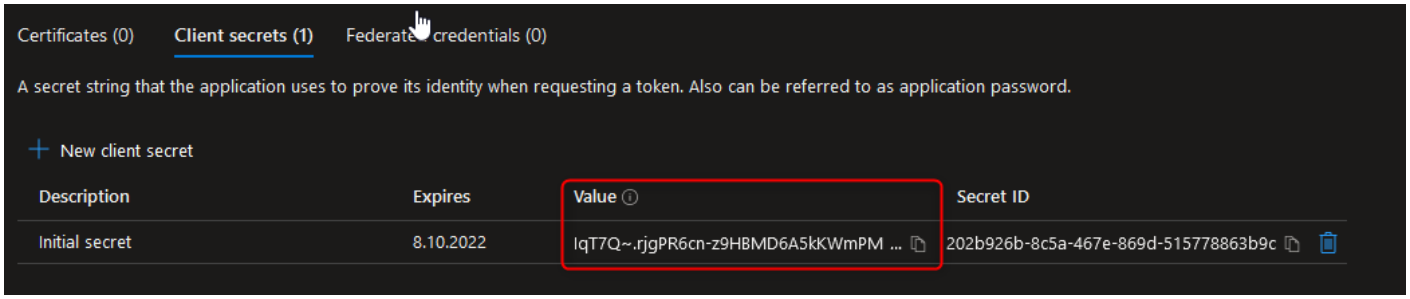
The setting will be set with clicking Add at the bottom of the dialog.

Copy the secret now and store it on a safe place
The client secret will be displayed only once after the creation. It will not be stored and cannot be displayed anymore later on. So please copy the secret (column Value) immediately and save it to a secure place, e.g. RB-PAM, RB-Secrets or a KeePass file.
Treat the secret the same as a password and don't share it with other persons! In case you still need to share it with your team, please ensure to meet the limitiations and rules of the EISA, which you can find here: https://www.intranet.bosch.com/doku/eisa/EISA-ACC-202.html#ctl$EISA-ACC-202$impl-reqs$5



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



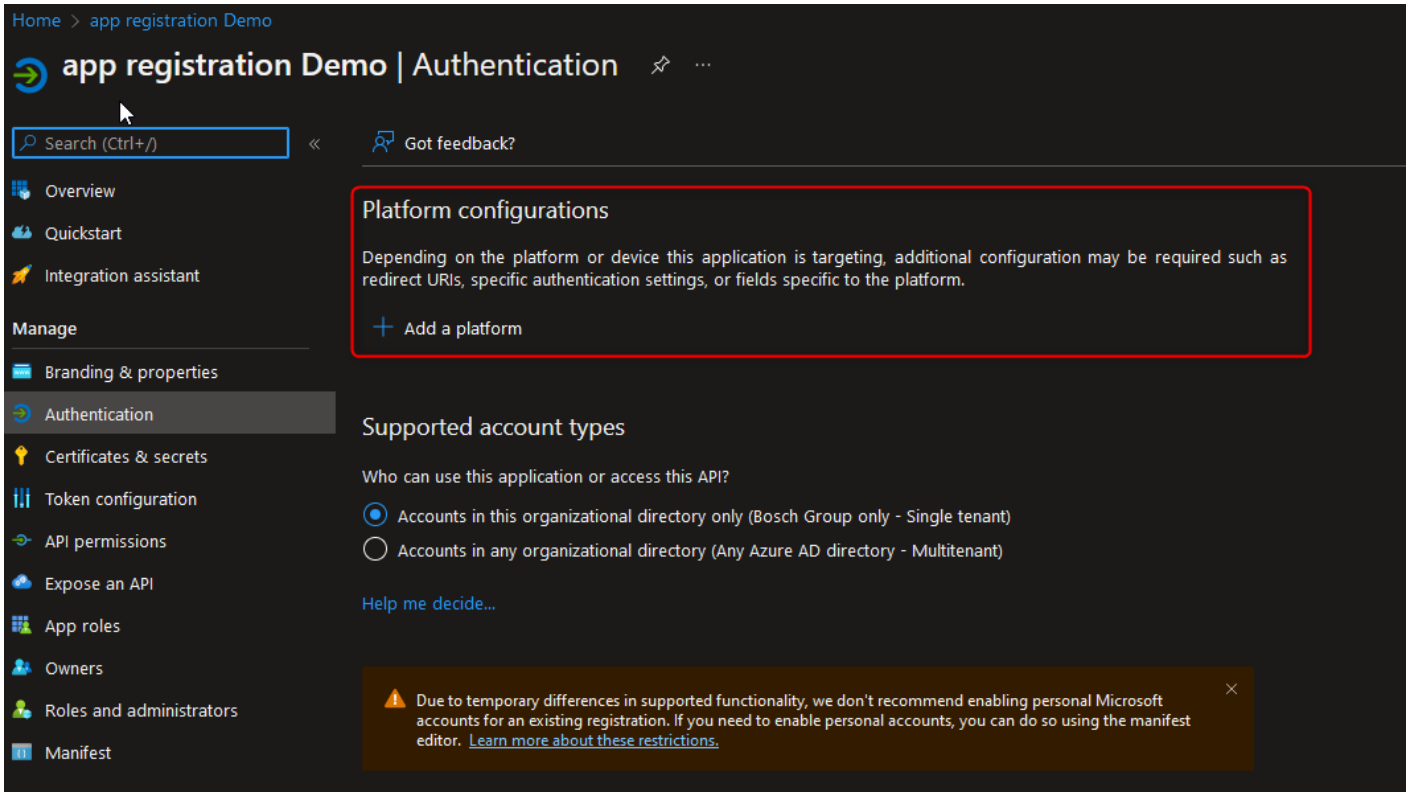


It is possible to build your own **automation** for credential rotation that we are explaining here: Automated Application Credential Management

5.1.2.2 Configuration of Redirect URIs

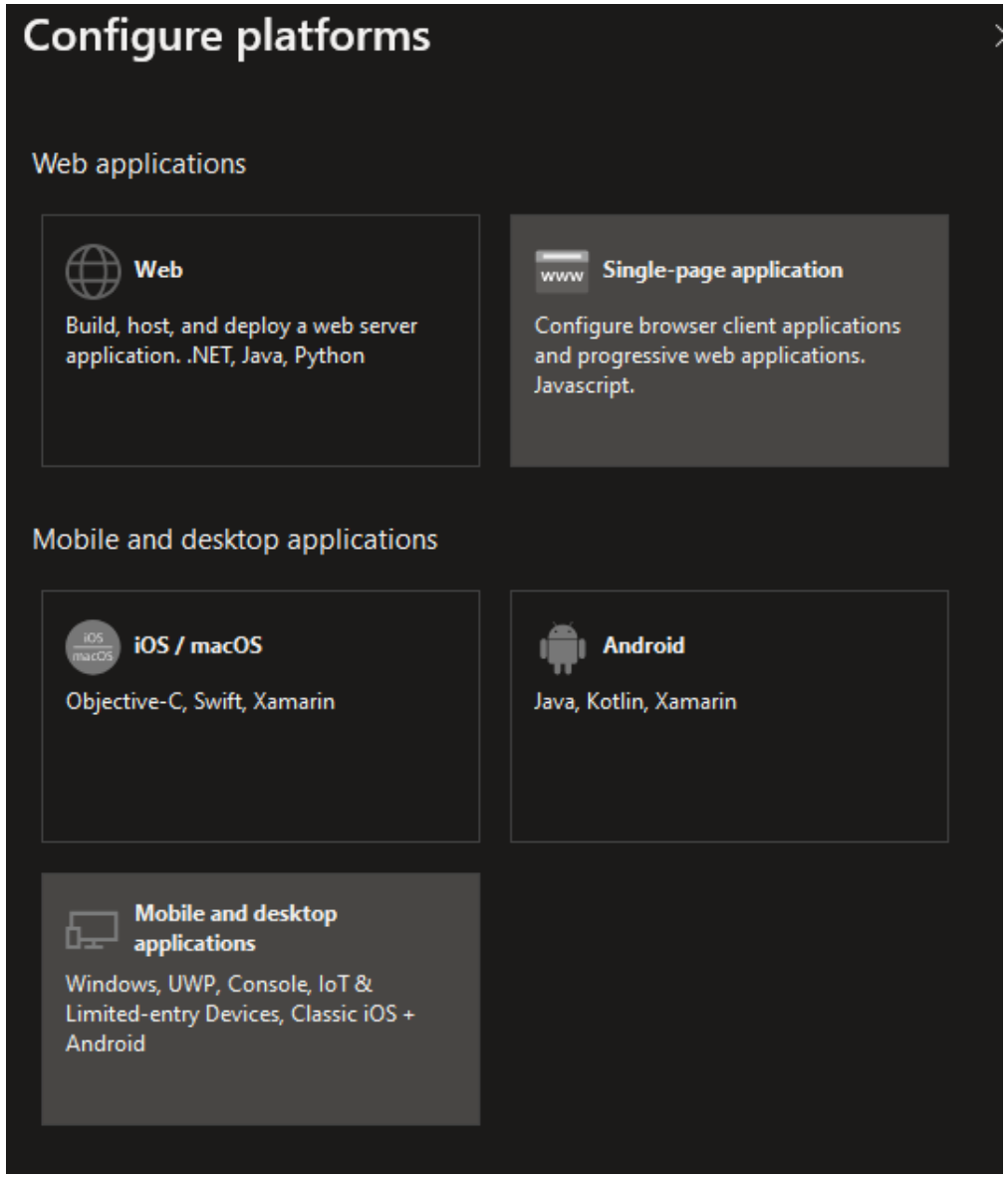
Like described earlier redirect URIs will be configured based on their platform types. You can get to the section by pressing the link in the application registrations overview page or by choosing "Authentication" in the left navigation bar and click the button + Add a platform

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



The following screen appears on the right side ...

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Please choose the item which describes your application and enter the parameters in the upcoming screens.

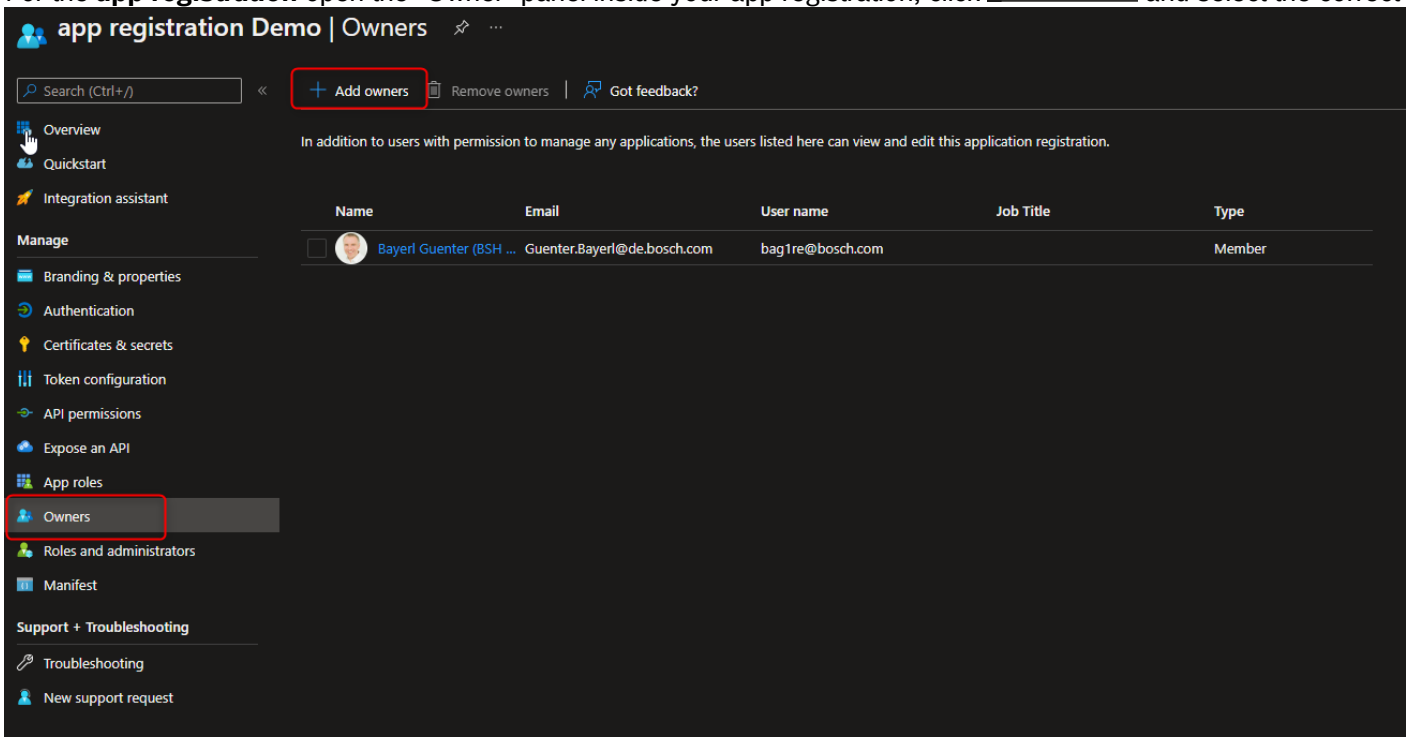
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

A detailed description of the platform types and as well to the other configurations described on this page you can find at the official Microsoft documentations:
https://docs.microsoft.com/en-us/azure/active-directory/develop/quickstart-register-app#configure-platform-settings
After this step your application is registered successfully in Entra ID and can be used to authenticate users for your application with OAUTH/OIDC.

5.1.3 Manage Owners of the application

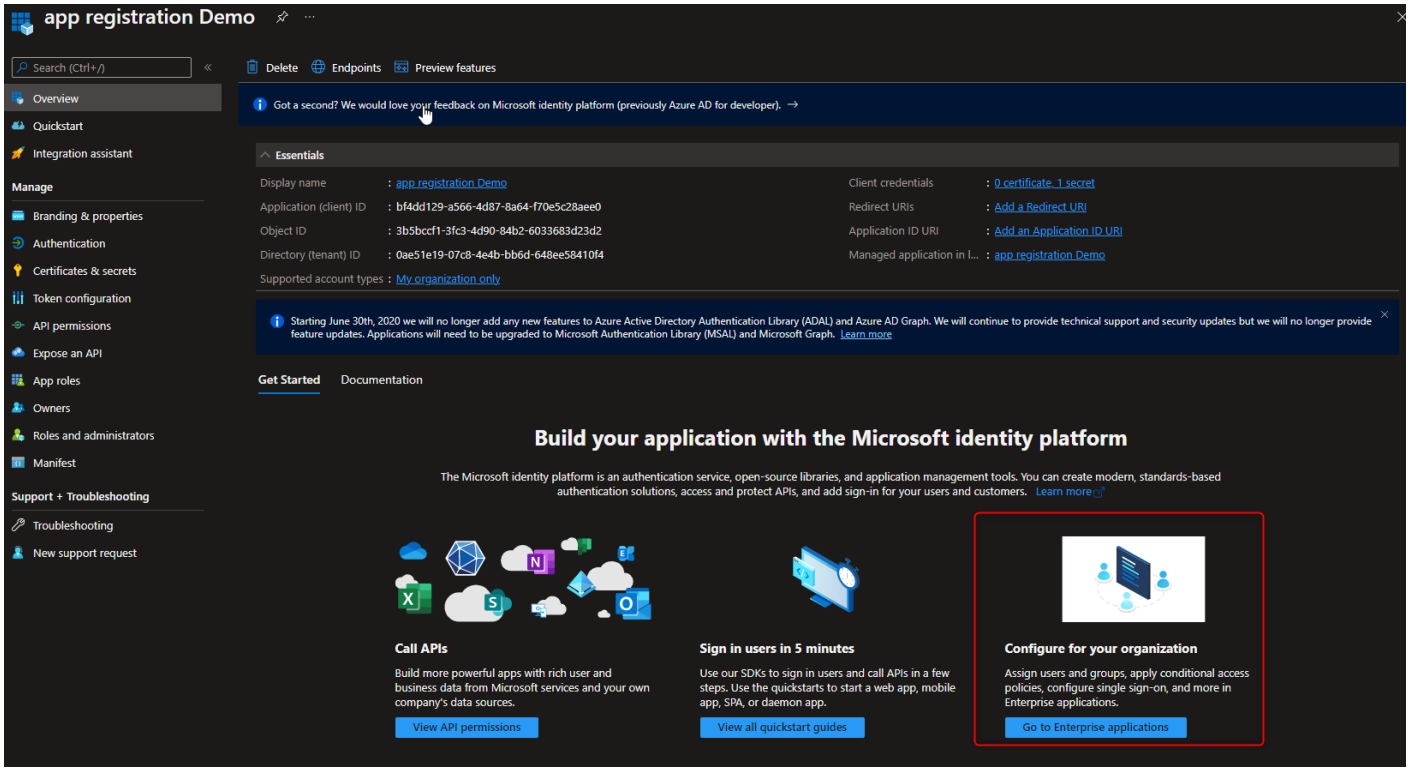
While the initial app registration the current user will be added as the app registrations and enterprise applications owner and so is able to manage all application settings. For every app there is a must to have at least 2 valid owners configured.
An fast an easy option is to set this via the IAP-Portal: Applications - Overview.
But in case you will configure OIDC claims we recommend to set them manually in Entra ID:

For the **app registration** open the "Owner" panel inside your app registration, click + Add owners and select the correct owner.



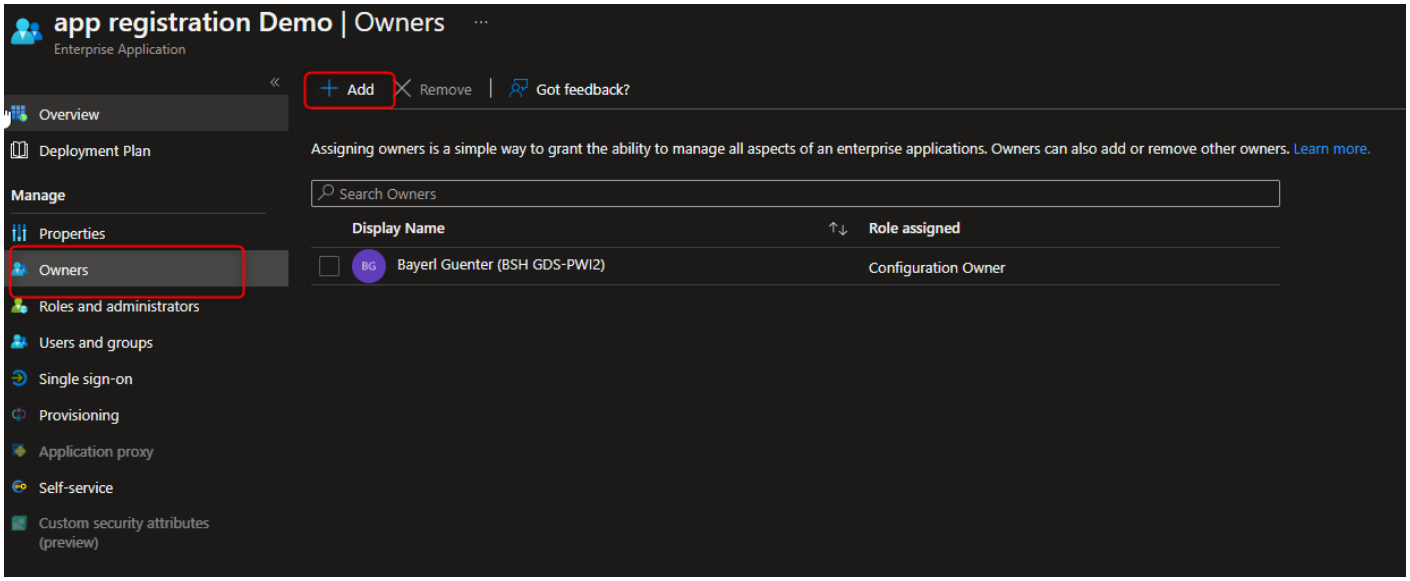
For the **enterprise application (service principal)** you can change this the same way. The easiest way to get to the enterprise application panel, you can go to the Overview of your app registration and click the button to switch to the enterprise application like you can see in below screenshot.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



In the enterprise app as well go to the Owner panel and add at least one additional owner (The account initially registered the app is also already owner of the enterprise application).

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Important information about owner assignment
Ensure the owners are always up to date. As an owner you have the possibility to configure and manage all kind of settings for the application - also the security relevant information like client secret. Therefor it is important to remove all users which doesn't need this permission.
As described above ensure that always at least two owners are in the configurations in case someone is able to maintain the configuration in case of absence or any other reason.

5.1.4 Additional Claims

Claims are Attributes that can be send in a token. An overview about claim configuration from Microsoft can be found here and offers to send UPN (joe1fe@bosch.com) or E-Mail. For **additional claims** there is a preview available, we are providing an instruction for this: Configure Claims in Token
It is possible to send a **group claim** but this is due to restrictions (max number of groups) not recommended. Please check out Groups and Authorization There are a lot of options for **Authorization over SSO** with roles / groups.
To **view your token** you can use the API Client Tool "Bruno" or inspect your token in our IAP Portal: Applications - Overview

5.1.5 Scopes

OIDC standard scopes and permissions
In Order to get Admin Consent Approval (Step 3) you have to do some adaptions in the API permissions tab: Add the standard OIDC-scopes (mandatory is openid) and remove the permissions for User.Read if possible.
More details are explained in our subpage OIDC Scopes and Permissions

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Access Tokens
Default Access Tokens in Entra ID are for Microsoft Graph API. You can recognize this checking the value of the claim "aud" ("00000003-0000-0000-c000-000000000000" or „https://graph.microsoft.com“).
An access token for your application has your clientid as value of the claim "aud" (Your application should always check this claim as part of token verfication). To get this access token you can add the **scope "<yourclientid>/.default"**. Additionally it is possible to set a different Application ID URI (Overview Tab) and define further custom scopes (Expose an API Tab).
More information from Microsoft about this can be found here.

5.1.6 Authentication Context and MFA

An authentication context defines a requirement that allows you to apply **granular policies** to sensitive data and actions at the app level based on your own logic. E.g. there are Options to enforce Multi-Factor-Authentication for certain roles to increase security. Documentation: Auth Context
For **general restrictions** (requesting MFA or restricting access to SAWs) have a look on our page for Multi Factor (MFA) with applications using modern Auth (SAML/OIDC)

5.1.7 Further information

Entra ID Endpoint for P4S permissions: If your application is hosted OnPrem the back-end server might require a **communication with the Entra ID.** How to request the required permission for this communication pattern over Bosch Proxy4Server (P4S)
If you want to use our **Test Entra ID** Environment (different Azure Tenant), then a login with your respective test account is required (e.g. <Q9-UserID>@test-bosch.com)

It is highly recommended to use **Entra ID v2 tokens**. Therefore use the respective endpoints and adapt the Manifest in the App Registration.

```
"requestedAccessTokenVersion": 2
```

Further information for token validation you can find here: OAuth2.0 / OpenID-Connect Token Validation - Directory Services - Docupedia

Links to Micrsoft Documentation
Find more information on the official Microsoft documentation:

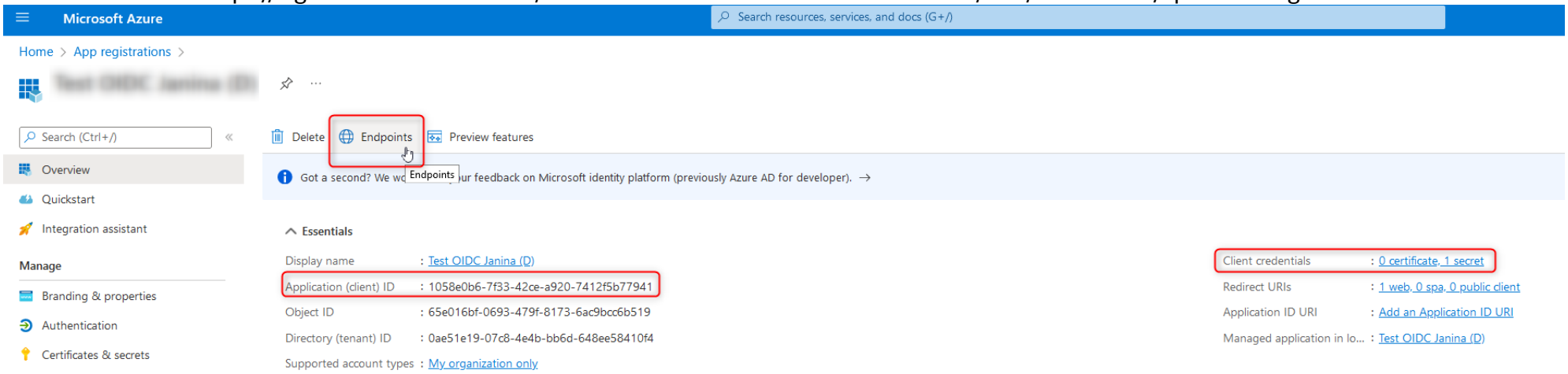
- Quickstart: Register and expose a web API - Microsoft identity platform
- Quickstart: Configure an app to access a web API - Microsoft identity platform
- Provide optional claims to your app
- Microsoft identity platform code samples

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.2 Step 2: Application Configuration

All Information for the Federation Configuration on Application side can be found in your App Registration in Azure Portal

- Additionally the **ClientID** and for confidential clients the **Client Secret** are required
- For OIDC all **endpoints** are included in the "Well known openID configuration file"
  - Bosch: https://login.microsoftonline.com/0ae51e19-07c8-4e4b-bb6d-648ee58410f4/v2.0/.well-known/openid-configuration



5.3 Step 3: Admin Consent Approval

Initiate now the first authentication. Please be aware that the first time you need to request admin consent. Please fill out the dialog and send the request to the responsible team. This will take some time so please be patient and wait for the answer. You can also request it via an Pre-Approval workflow.
For more details about the process feel free to check our our Admin Consent Documentation, You can also check out the most common API declines here

5.4 Configure Claims in Token

It is possible to send Claims (Attributes) in a JWT-Token (ID and Access Token). A popular example would be to send the samAccountName / NTID (e.g. joe1fe) of a User. This page explains how to configure the Claims in the Azure portal.

If you want to configure group claims, we have a dedicated page explaining this in detail: Groups and Authorization

Related Microsoft Documentation: here

- How to configure
- Offered Claims

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

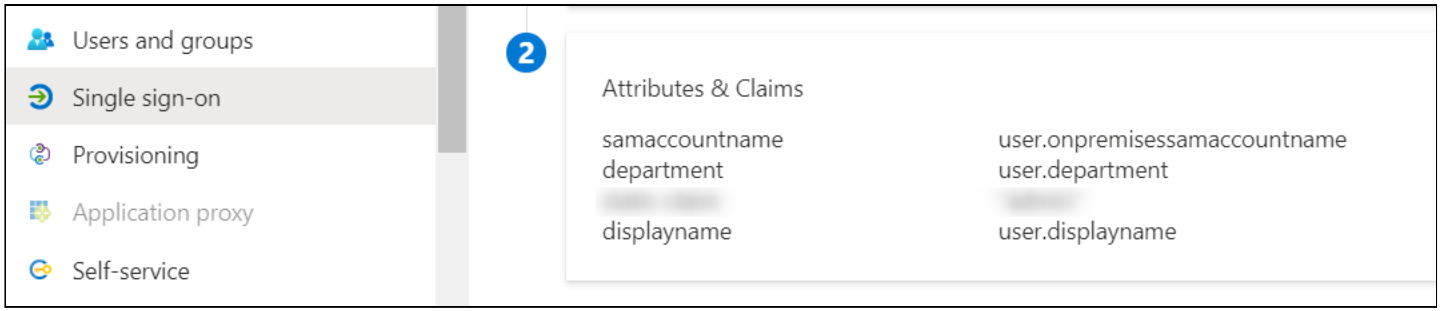
- View Token
- Common Problems

5.4.1 How to configure

Prerequisite:

- You have to be an owner of the app registration and enterprise application. Otherwise, you wont be able to see the claim management experience
- Adapt your "Manifest" in the App registration: "acceptMappedClaims": true,

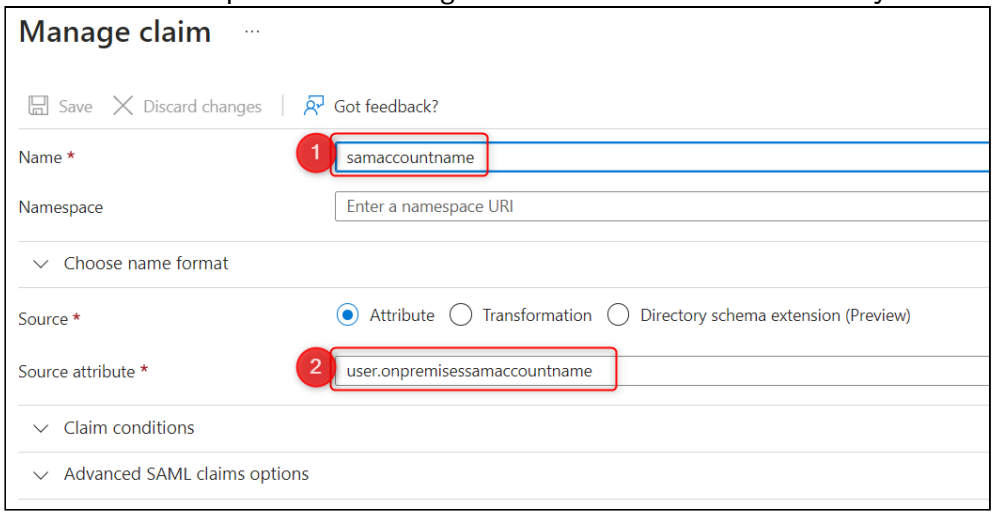
Go to the Enterprise Application of your application (e.g. over Overview > Managed application in local directory). In the Tab "Single-Sign-On" you find the Option to edit "Attributes and Claims"



There you can select "Add a new Claim" and configure your Claims.

1) Is the name of the Claim in the token. You can define this yourself
2) Is the fixed name of the attribute in Azure that you want to have

There are further options available e.g. transformation to lowercase. After you saved the configuration the new Claims will appear in your JWT-tokens.



Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

5.4.2 Offered Claims

It is the same claims as offered for SAML tokens. A list can be found here: Bosch Attributes and Claims

5.4.3 View Token

To **view the attributes in your token** you can use the API Client Tool "Bruno" or inspect your token in our IAP Portal: Applications - Overview

5.4.4 Common Problems

Problem	Solution
Adding / modifying of custom claims in Enterprise Application not possible. "Edit" and "Save" button is greyed out	Owners of the Enterprise Application need to be re-added in Entra ID portal. Please do not remove your access completely so that at least two persons are set! If owners were not added in the Entra ID portal directly might run into this issue (due to a bug in the Microsoft UI in Entra- or Azure-portal, the removal and re-adding of owners is not working for assignments via MS Graph)
"error":"invalid_request","error_description":"AADSTS50146: This application is required to be configured with an application-specific signing key. It is either not configured with one, or the key has expired or is not yet valid	Older Azure Application Configurations might run into this issue. In this case you have to adapt your "Manifest" in the App registration: "acceptMappedClaims": true,
AADSTS501461: AcceptMappedClaims is only supported for a token audience matching the application GUID or an audience within the tenant's verified domains. Either change the resource identifier, or use an application-specific signing key.	You could change the identifierUris in the app's manifest to a verified domain like e.g. api://<AppID>.bosch.com
Claims are not part of the Access Token	Please check that this is the access token for your application. More background information can be found here: OIDC Configuration

5.5 Entra ID Endpoint for P4S permissions

If your application is hosted OnPrem and you plan to integrate a native Entra ID OIDC implementation, the **back-end server might require a communication with the Entra ID IdP** for all OIDC flows. As the Entra ID IdP is hosted as an IaaS model on public Internet powered by Microsoft Azure platform, the token endpoints are public Internet endpoints. Thus, the OnPrem application server must be able to reach those Internet hosted endpoints: For server communication, you need to request **Bosch Proxy4Server (P4S)** access and actually configure the proxy service on the back-end server that needs to reach the Entra ID endpoints.

5.5.1 Proxy4Server (P4S) Access

Your server needs to access to Proxy for Server itself. Therefore a **Firewall rule must be requested** (Template: https://cls.seccom.bosch.com/warp/iptt/14/)
Further information about P4S service offerings and processes can be found here: https://inside-docupedia.bosch.com/confluence/x/5wj0Hg

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The relevant **endpoints (like login.microsoftonline.com) are allowed by default on Proxy4Server.** There is no specific rule on Proxy4Server required.
(See Free-4-All Policy - Network Security Policy Management - Docupedia)

5.5.2 Further information

In the past the rules on Proxy4Server were not default and needed to be requested depending on the usecase. For more technical background information you can have a look on our old documentation:
Click here

5.5.3 Standard Case: Back-end server communication from restricted network zones

If your application is hosted OnPrem and you plan to integrate a native Entra ID OIDC implementation, the **back-end server might require a communication with the Entra ID IdP** depending on the implemented OIDC flow. We do share the following information to provide guidance how to request the required permission for this communication pattern. This is mainly required for Authorization Code Flow as well as if you plan to validate issued tokens by the back-end service.
As the Entra ID IdP is hosted as an IaaS model on public Internet powered by Microsoft Azure platform, the token endpoints are public Internet endpoints. Thus, the OnPrem application server must be able to reach those Internet hosted endpoints. For server communication, one need to apply for the **Bosch Proxy4Server (P4S)** configuration and actually configure the proxy service on the back-end server that needs to reach the Entra ID endpoints. Please make sure that your back-end service can establish a communication via proxy settings and apply for the below mentioned URL as a new request or add the URL to an existing P4S rule.

Endpoints to apply for on Proxy4Server (back-end server communication)
As all Entra ID OIDCv2 endpoints are hosted by the login.microsoftonline.com, it is sufficient to apply the P4S rule for the destination host (internet host) as a P4S host rule.

```
login.microsoftonline.com
```

CRL Endpoints (optional)
If the back-end service also performs CRL check of the login.microsoftonline.com endpoint (SSL), please also apply for the CRL URLs accordingly. This is only needed in very few cases. These URLs are not listed here as they could change based on Microsoft hosting architecture. Thus, please look up the current CRL URLs (e.g. by opening the SSL-certificate in the browser) and add it as an additional P4S rule.

5.5.4 Special Case: Interactive sign-in / user access from restricted network zones

In case you want to access EntraID integrated applications from **client/ end device** hosted in a restricted network zone (e.g. from a dedicated jumphost or from a mobile app on devices connected to a restricted network zone) based on an **interactive sign-in**, access to the EntraID endpoint are as well required. Depending on the restricted zone access and defined framework the EntraID sign-in can be achieved as follows:

- If end devices are allowed to access the standard Bosch proxy for establishing Internet access: One just needs to apply for the standard Bosch proxy firewall access and ensure to set the standard Bosch proxy network configuration on the end devices. No further actions required once the end devices can establish a communication to the standard proxy infrastructure.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

- If end devices are not allowed to use the standard proxy for establishing Internet access, but must use Bosch Proxy4Server: One can leverage Bosch Proxy4Server infrastructure by applying for the firewall rule from the end device network range to the Bosch Proxy4Server (https://cls.seccom.bosch.com/warp/iptt/14/), set the P4S proxy configuration on the end devices as well as apply for the following endpoints in P4S rules:

```
login.microsoftonline.com
login.microsoft.com
aadcdn.msauth.net
aadcdn.msauthimages.net
aadcdn.msftauth.net
aadcdn.msftauthimages.net


stfs.bosch.com -> already available as default
```

Optional
In case the back-end system must reach further APIs like the Microsoft Graph API to access M365 interfaces, please ensure that you apply for those API URLs as well depending on your use case.

5.6 Exception: OIDC with RB-Admin

ADFS

All Information for the **Federation Configuration for OIDC on ADFS@RB-Admin (Identity Provider) side** can be found here. We offer a plattform where you can create and change your OIDC settings yourself.

How to find the Plattform?
Choose in the Table below your Identity Provider and use the respective link.

ADFS	Link	Description

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

ADFS@RB-Admin	https://rb-ada.rb-admin.bosch-org.com/	Special ADFS. Authentication for RB-Admin-Users

Hint: You have to log in with a user from the same Active Directory

- Create Application (Identity Provider side)
- Configure Application (Identity Provider side)
  - Owners
  - Reply URLs
  - Claim Assignments
  - Secrets
  - Scope Grant Management
  - Deletion

5.6.1 Create Application (Identity Provider side)

Under "ADFS > OAuth2 Applications" you can click the "CREATE" button in order to create a new Application Instance on ADFS side.

No	Property	Description	Modifiable later
1	Name	The name of the application. This property has no technical functionality and only exists for documentational purposes. It cannot be empty or exceed 120 characters.	✅
2	Instance	Whether this application represents a productive or a develop/quality application.	❌
3	Type	**This is a very important decision! If your application supports it please create a confidential client.** Whether the application is a public (Implicit Flow, Code Authorization Flow with PKCE) or a confidential client (Code Authorization Flow, Client Credential Flow). See here for an explanation. If you select 'Confidential Client', you will receive a client secret once after the application has been created.	❌
4	Additional Owner	The additional owner of the application, because all applications have to have at least 2 users as owners assigned. You can search for a user by NT user, first name, last name or email address. You will be added as an owner automatically. You can add and remove more owners later, even groups.	✅

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

No	Property	Description	Modifiable later
5	Cloud Onboarding WorkOn Number (Optional)	The Cloud Onboarding WorkOn Number. Only required for Cloud Applications.	✗
6	Terms and conditions accepted	Has to be accepted. The terms and conditions can be accessed here.	✗
7	Subscribed to SPoI	Has to be accepted. For all kind of maintenance, certificate changes or planned downtimes we will inform our customers through the offical process SPoI. The SPoI can be subscribed here.	✗

5.6.2 Configure Application (Identity Provider side)

5.6.2.1 Owners

An owner of an ADFS OAuth2 application serves 2 purposes:

- Contact person for ADFS administrators
- Full access to the configuration of the application in IAP (adding more owners, editing claims, ...)

You can add or delete owners, but at least 2 user as owners are required. Search for the Users by Lastname + First Name (Doe John) or NT-ID (e.g. joe1fe).
Since 19.07.2021, you have to option to add groups as owners. You can add and remove as many groups as you like, but at least 2 users must still be assigned as owners.
Be aware that you can only assign groups that are synced to Azure. You can check in the Azure Portal whether a group is synced or not by searching for it. If you require a groups to be synced to Azure, drop a mail to CI/PWI2-Azure-Application-Administration containing the group domain + name.

5.6.2.2 Reply URLs

Reply URLs are the endpoints on Service Provider / Application side where the token will be send to. For a more detailed definition of Reply URLs, see here.
You can add as many Reply URLs as you like. The following restrictions apply to all Reply URLs configured in IAP:

- A Reply URL has to be a well-formed absolute URI
- A Reply URL cannot start with `http://` (except for `http://localhost`)
- A Reply URL cannot exceed 1024 characters
- A Reply URL cannot contain `?`, `#`, `*` or `,`

You should not use `http://locahost` in your productive system.

5.6.2.3 Claim Assignments

In this section you can define addtional claims or information we should issue with the token to the application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

No	Description
1	Name is the Claim Name / Attribute Name in the token
2	We offer a transformation of the values "TO UPPER" and "tolower". This is important if the application expects case sensitive claim values.
3	We offer 3 different Types: Input Claim, Group Claim and Static Claim. They are described in detail below

Input Claim (LDAP Attribute)
An Input Claim is an attribute of the signed in user and can provide the application with some information (LDAP Attribute) about who the token belongs to. For example, the Input Claim 'samAccountName' represents the NT-User or logon name of the signed in user (e.g. XYZ2FE). Overview of all Attributes:

Claim name	Description	Example
Claims configured by default		
SamAccountName	NT User ID of the user	doj1fe
UserPrincipalName	unique value for the user including NT-ID and the domain in email format	doj1fe@bosch.com
Domain	Domain of the User (emea, de, us, apac, br)	de.bosch.com
Further Claims (A-Z)		
City	Location	Stuttgart-Feuerbach
co	Country name	Germany
c	Country Code	DE

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Claim name	Description	Example
Company	Company name	Robert Bosch Gmbh
Department	Department abbreviation	CI/ISI2
DisplayName	Name as shown in eg Outlook	Doe John (CI/ISI2)
EmailAddress	Email Address(es)	john.doe@de.bosch.com
GivenName	Firstname of the user	John
MobilePhone	Mobile phone number of the user	+49(172) 123 456 78
Office	Room and building number	FE 701/2 J1.01
sn	Last name of the user	Doe
State	State of the User	Baden-Wuerttemberg
StreetAddress	Street of office location	Borsigstrasse 4
telephoneNumber	the office telephone number of the user	+49(711)811-1234
Title	title of the user	Dr.

Group Claim
It is possible to send Active Directory group memberships of a user as a claim in the token. An Application can process this claim and use it for a role concept within the Application.
With "Issue as Sid" the group name in the token will be not the name of the group but it's SID (a unique ID).
You can apply a filter (in Regex) to limit the list to groups that are relevant to your application.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Example:

Name	Filter
roles	Idm2bcd_MyApplication_

Result:
An access token that contains all groups that start with 'Idm2bcd_MyApplication_' where the signed in user is a member of in a claim called 'role'.

More information about possible group types can be found here.

Static Claim
A Static Claim is a static value that will be same for all users in all tokens issued for this applications. It is a fixed Key-Value Pair.
Example:

Name	Value
ApplicationInstance	Development

5.6.2.4 Secrets

> This section only applies to confidential clients, because public clients have no secret. A public Client cannot be converted after the applicationhas been created. To see whether your application is a confidential client, scroll down to the bottom of the application configuration page and look for the 'Type' of the application.

At the top right of the application page, there is a button called 'RESET SECRET'. You can click this button to generate a new secret, if you have lost your current secret or just you want to rotate it. You will then be prompted to confirm the action.

> Be aware that this action cannot be undone.

The new secret will then be presented at the top of the application page. The old secret will stay valid for 2 days, so that you have time to update it in your application(s). We doe not store any secrets, so after you moved away from this page or clicked refresh, you will never be able to see the secret again.
Please take a look at the EISA to check how often you have to rotate your secret. Currently (13.07.2021) you have to rotate it every 180 days, except you fulfill the requirements of EISA-ACC-301.9 - then it is every 2 years.

5.6.2.5 Scope Grant Management

An ADFS Application created in the ADFS Self-Service consists of 2 parts: A client (Public/Confidential) & a Web-API. This setup enables you to sign in users using the client and get a token issued for the corresponding Web-API with the same Id as the client. The resulting access token will contain the the Id of the Web-API in

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

the Audience Claim, which has to be used by it to verify that the access token is really intended for the specific Web-API (See reserved claims). By default, you cannot sign in users for any other Web-API registered in the ADFS.
The Scope Grant Management enables you to granularly define which ADFS Applications are able to access your Web-API with specific scopes. When **granting access for another Application**, you can select one or more of these optional Scopes: Read.All, ReadWrite.All or user_impersonation. The Scopes *openid, profile, email, allatclaims* will be automatically added for all Grants.
You can only grant access for other applications to applications you own. If you want to access an applications that is owned by another person/department, you have to ask the owner of that application to register your application by providing your application id to them.
A registered grant can be revoked by the Owners of both applications. Be aware that you cannot undo this action and you may have to ask the owner of the application you want to have access to to register it again.

5.6.2.6 Deletion

You can find the Delete Buttopn at the top right of the application configuration page. If you click this button you will be prompted to confirm the deletion.
After confirming the deletion, the application will be removed instantly and you won't be able to sign into it anymore

Caution

This Action cannot be undone. A deleted application cannot be restored!

5.7 OIDC Scopes and Permissions

Here you can find more details about Scopes and API permissions for OIDC Applications.

5.7.1 OIDC Standard Scopes

OIDC SSO integration is based on scopes that are introduced in the OAuth 2.0 RFC 6749 and the OIDC scopes are used by an application during authentication to identify the person and receive further profile information of the signed-in user. These OIDC scopes are defined based on an industry standard as follows:

- openid (mandatory)
- email (optional, provide the users primary email address)
- profile (optional, profile information last surname, given name etc)

For the sole SSO purpose, please use these three scopes in the authentication request to obtain the ID token that identifies the signed-in user and provides further user profile information. Please do not rely on the Microsoft Graph scope "User.Read" for SSO integration purposes. The SSO integration must be established using the OIDC standard.

5.7.2 OIDC Authentication Request

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The above introduced OIDC scopes must be part of the authentication request of the application / service that you are either coding or using from a vendor. Depending on the OIDC flow architecture - which you can refer to https://inside-docupedia.bosch.com/confluence/x/ml1KWg - and coding language, the integration may vary but we take the following **example** to highlight the correct scope configuration:

https://login.microsoftonline.com/{tenant}/oauth2/v2.0/authorize?client_id={client-ID}
&response_type=code
&redirect_uri=http%3A%2F%2Flocalhost%2Fmyapp%2F
&response_mode=query
&scope=openid+email+profile
&state=12345
&code_challenge=YTFjNjI1OWYzMzA3MTI4ZDY2Njg5M2RkNmVjNDE5YmEyZGRhOGYyM2IzNjdmZWFhMTQ1ODg3NDcxY2Nl
&code_challenge_method=S256

As you can see - it will be sufficient to add the standard OIDC claims as the scope parameter of the authorization request to Entra ID to correctly implement SSO.

5.7.3 OIDC Consent and API permissions

Using the OIDC scopes requires an initial admin consent which is required on the first integration / request to use SSO and obtain user information (Step 3). This is a one-time activity once you request a scope the first time. Once granted, no further consent requests are required on the next sign-in requests. The consent approval can be triggered via two processes - you only need to use **one** of the presented options:

1. **Built-in Microsoft consent workflow**: https://inside-docupedia.bosch.com/confluence/x/Fo68RQ

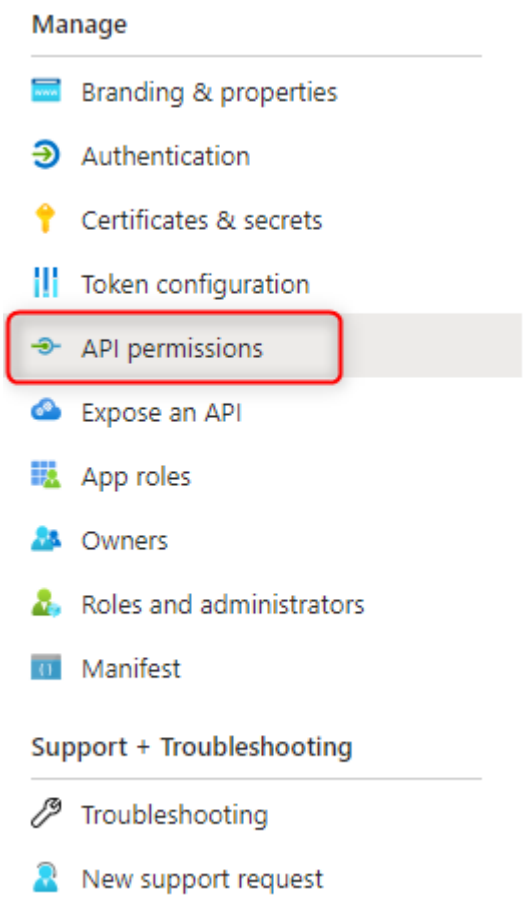
   In this case, all you need to do is adding the OIDC scopes (openid+email+profile) to your authentication request as the scope parameter as outlined above. If these scopes have not been granted beforehand, the outlined built-in workflow will start. Please provide the justification (e.g. implement Bosch SSO in your app) and send the request. Once it gets granted, you will be notified and can use SSO. If you use the built-in consent workflow, you do not need to follow up on the second pre-approval option and outlined tasks below.

2. **Pre-Approval consent workflow**: https://inside-docupedia.bosch.com/confluence/x/ZSUuf

   In case you cannot trigger the built-in workflow or do want to obtain the consent before you ask your customer to sign-in to the application, you can configure the OIDC scopes for SSO upfront in your app. To do so, please go to the Entra ID app registration blade and select the "API permission"

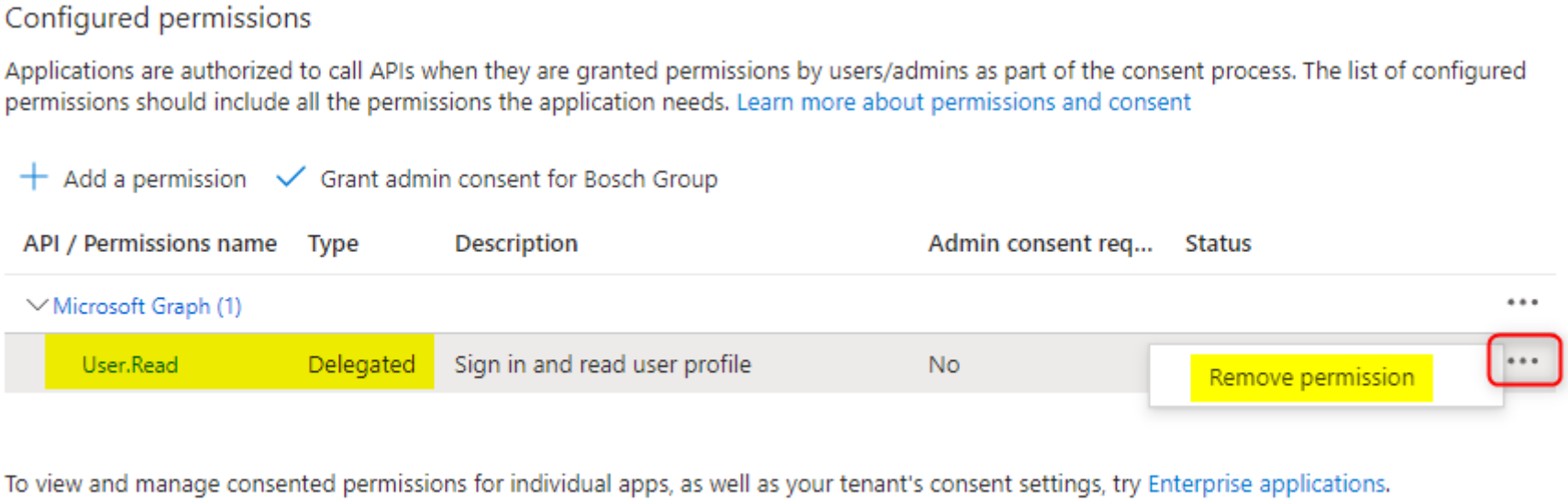
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

area:



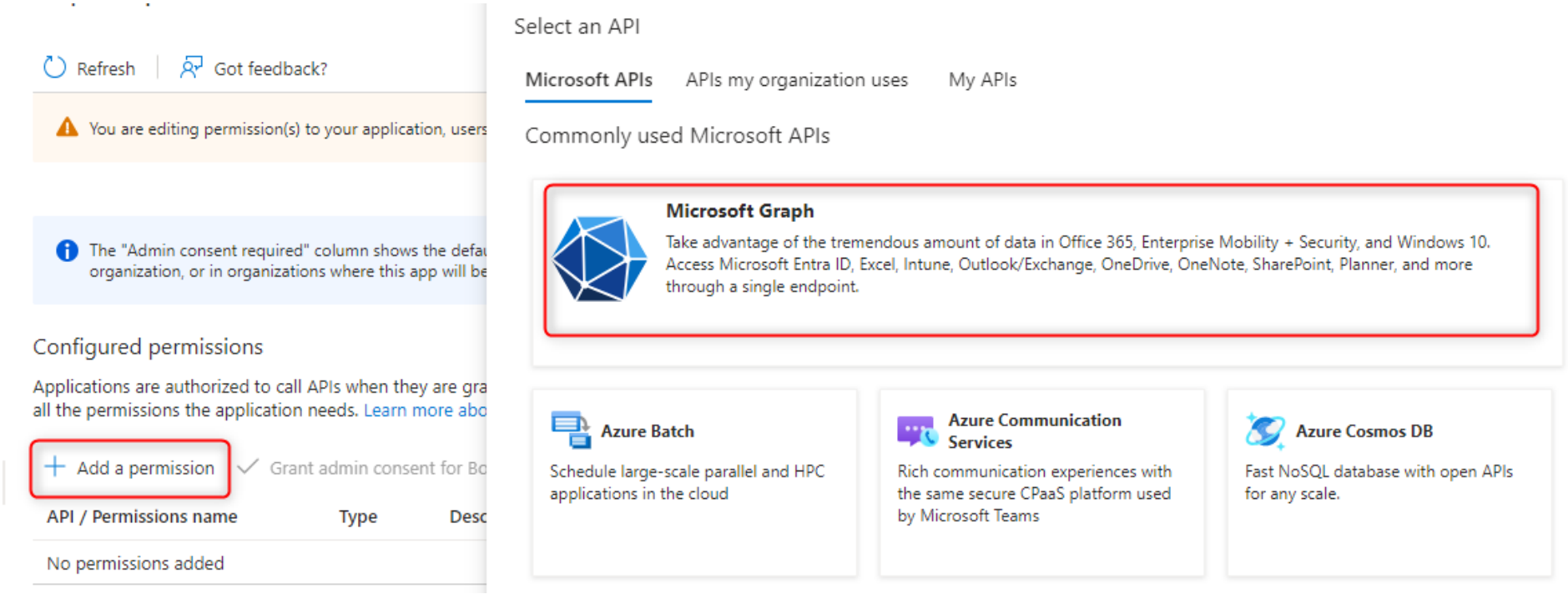
By default the Microsoft Graph API permission of "User.Read" is set on each application. Though this Microsoft proprietary scope can be used to sign-in as well, we do not follow this approach as it neither fulfills SSO industry standard integration nor meets the Bosch IT governance requirements to apply Identity protection mechanisms on the sign-in process. Thus, if you are solely looking into SSO, **please remove the default defined "User.Read" permission** as follows: *(in case you need "User.Read" in addition to the SSO integration you can keep it but you must ensure to always use the standard OIDC claims for your application SSO sign-in)*

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



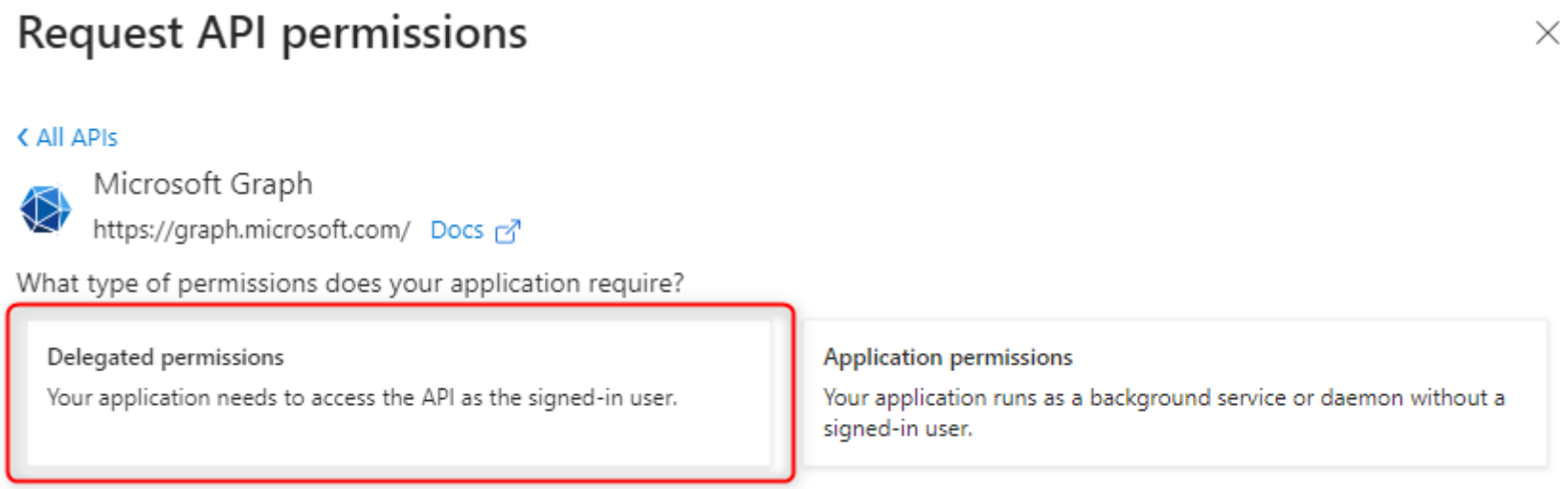
To add the OIDC standard scopes, please select "Add a permission" and confirm the "Microsoft Graph" platform:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



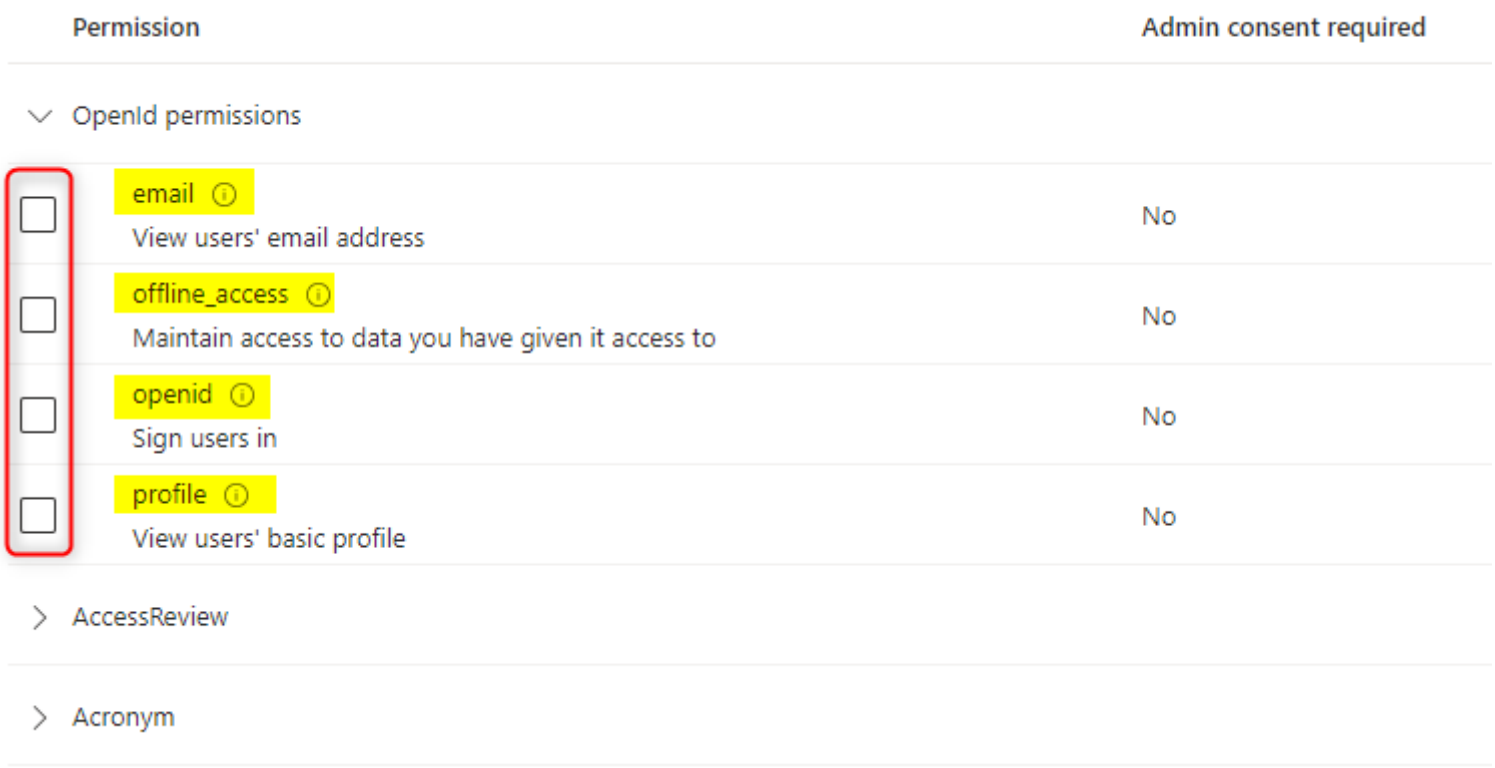
As the SSO sign-in is an interactive flow, please proceed with delegated permissions:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



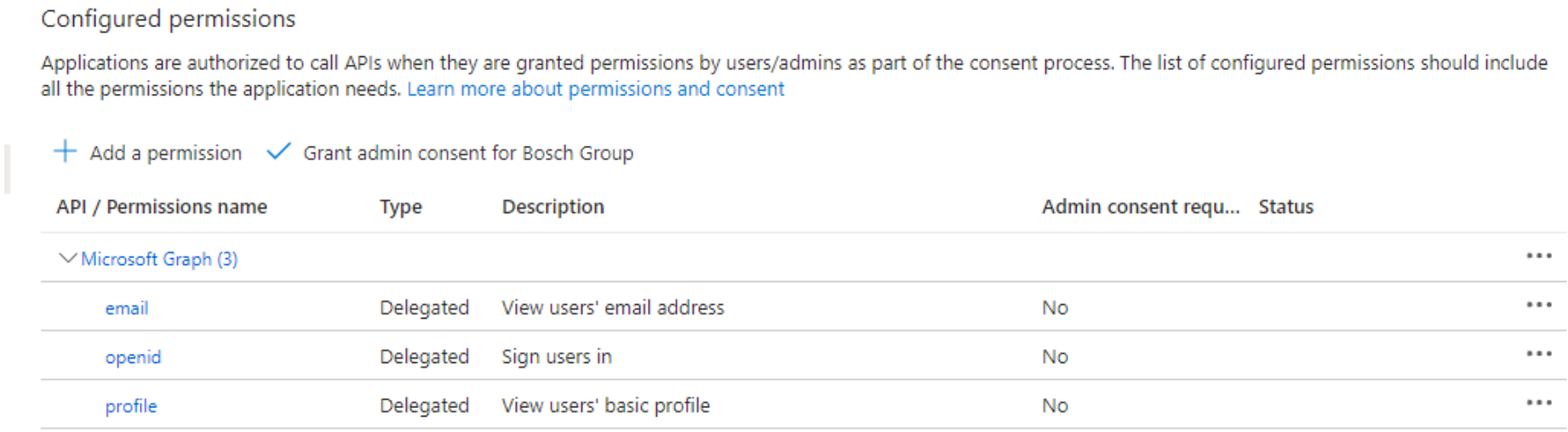
The OIDC SSO scopes will be presented to you as the very first scope options - please mark the check boxes of the OIDC scopes you want to use. At least "openid" is mandatory to complete a SSO integration but you can add the other scopes in addition if you require further information like the primary email address of additional profile information. By requesting profile information, please be aware that your application must be compliant with data regulation requirements (e.g. GDPR) as by receiving user profile information your app processes personal user data. Thus, please only use this scope if the personal user data processing has been clarified for your application. The "offline_access" scope is only relevant and required if you intend to use refresh tokens:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Please continue with "Add permission" at the bottom of the dialog. Now, all selected scopes should be added to the API permission blade e.g.:

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



This is the intended state of API permissions for the OIDC Bosch SSO integration - please keep in mind the personal data processing requirements if the "profile" scope is selected. As the next step, you can go ahead and request the consent of the newly added scopes via T&R Service Desk as outlined in the above mentioned link for the pre-approval process (https://inside-docupedia.bosch.com/confluence/x/ZSUuf).

Return to general instruction for OIDC Configuration here

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

6 Terms and Conditions

Version 1.2 - 06.11.2023

By using the Service you agree to be bound by these Terms. If you disagree with any part of the terms then you may not use the Service.

6.1 General

We offer Single Sign On functionality for applications (on premesis, cloud hosted, SaaS) or publish internet facing applications in a secure way for Enterprise IT use cases. The authentication is based on SAML or OpenID connect.
The user will be authenticated against the on premise Active Directory. Our service will provide a token (XML or JWT) with the authenticated user and other information (claims) to the application.

6.2 Assurances

While developing and integrating new applications to the Bosch IT infrastructure you are ensuring to meet the security and legal requirements of all Bosch regulations. Depending on the architecture and other criterias the respective boards (e.g. DSO or Cloud Onboarding) need to be contacted for approval. There is no additionally approval for the SSO connection needed.

6.3 Preconditions

There are several preconditions which must be fullfilled to be able to use Entra ID (former Azure AD) as the Identiy Provider

- Application is a web based application and HTTPS has to be used
- Identities must be available locally in the application
- Users which access the application need to have an user account in one of our connected Active Directories - depending which environment you have choosen (see above)
- Users can access applications from the Internet (only cloud applications and applications, published to the Internet via our IdP)
    - A seperate authentication on our Identity Provider system is needed
    - User has to authenticate additional with MFA (Multifactor Authentication). Enrollment process can be found here

6.4 Out of our Service Scope

- Configurations on Service Provider / Application side
    - Managing the identities inside the application. This topic has to be handled separate.
      You can find information about how to handle on the Bosch IDM sites or contact via Mailbox.IdMIntegration@bosch.com
    - Regarding SCIM interface, you can as well have a look to https://rb-oneidm-help.bosch.com/en/data/scim.html
    - Application role management
    - Configuration of the federation trust and Development

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

6.5 Customer repsonsibility

- You as the customer are responsible to inform us in case the ownership or contact person changes. The correct process is to request the change via SMT ticket to Directory Services / FEDERATION SERVICE INFRASTRUCTURE OPERATION
  (In case we have no valid contact anymore, we are not able to inform you e.g. about expiring token signing certificates which could lead into an application outage)
- In case a Token Request Signing certificate or a payload encryption certificate is required, you as the customer are responsible to...
  - provide the correct public key during the onboarding process.
  - monitor the validity and expiration of the certificates.
  - inform us about expiration of any of the certificates and organize an appointment to replace with a new valid certificate.
  - ensure the certificates follow all Bosch security and legal requirements.

6.6 Additional rules for SAML self-service

With the hand over of ownership of the SAML EntraID configuration to the customer, you agree to following rules and conditions:

- It is not allowed to change of Single Sign-On mode in the Enterprise application configuration
- It is not allowed to change the Reply URL / Assertion consumer Service (ACS) URL directly in EntraID, but in the IAP Dashboard
- It is not allowed to activate SCIM (Provisioning) in the Enterprise application configuration for authentication. SCIM must be separated from the authentication and requested with the IDM team
- The application owner is responsible to ensure all securtiy guidelines as e.g. the EISA are fulfilled. For example the certificate lifetime is regulated in the EISA.

More details regarding the points you can find on the onboarding documentation pages here: https://inside-docupedia.bosch.com/confluence/x/vvfWTAE

6.7 Terms and Conditions V1.1 - OUTDATED

Version 1.1 - 11.02.2022

> By using the Service you agree to be bound by these Terms. If you disagree with any part of the terms then you may not use the Service.

General

We offer Single Sign On functionality for applications (on premesis, cloud hosted, SaaS) or publish internet facing applications in a secure way for Enterprise IT use cases. The authentication is based on SAML or OpenID connect.
The user will be authenticated against the on premise Active Directory. Our service will provide a token (XML or JWT) with the authenticated user and other information (claims) to the application.

Assurances

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

While developing and integrating new applications to the Bosch IT infrastructure you are ensuring to meet the security and legal requirements of all Bosch regulations. Depending on the architecture and other criterias the respective boards (e.g. DSO or Cloud Onboarding) need to be contacted for approval. There is no additionally approval for the SSO connection needed.

Preconditions
There are several preconditions which must be fullfilled to be able to use ADFS or Azure AD as the Identiy Provider

- Application is a web based application and HTTPS has to be used
- Identities must be available locally in the application (user id must match the unique Identifier of the token)
- Users which access the application have got an user account in one of our connected Active Directories - depending which environment you have choosen (see above)
- Users can access applications from the Internet (only cloud applications and applications, published to the Internet via our IdP)
    - A seperate authentication on our Identity Provider system is needed
    - User has to authenticate additional with MFA (Multifactor Authentication). Enrollment process can be found here

Out of our Service Scope

- Configurations on Service Provider / Application side
    - Managing the identities inside the application. This topic has to be handled separate.
      You can find information about how to handle on the Bosch IDM docupedia sites.
    - Application role management
    - Configuration of the federation trust and Development

6.8 Terms and Conditions V 1.0 - OUTDATED

Version 1.0 - 09.03.2021

> By using the Service you agree to be bound by these Terms. If you disagree with any part of the terms then you may not use the Service.

General
We offer Single Sign On functionality for applications (on premesis, cloud hosted, SaaS) or publish internet facing applications in a secure way for Enterprise IT use cases. The authentication is based on SAML or OpenID connect.
The user will be authenticated against the on premise Active Directory. Our service will provide a token (XML or JWT) with the authenticated user and other information (claims) to the application.

Assurances

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

While developing and integrating new applications to the Bosch IT infrastructure you are ensuring to meet the security and legal requirements of all Bosch regulations. Depending on the architecture and other criterias the respective boards (e.g. DSO or Cloud Onboarding) need to be contacted for approval. There is no additionally approval for the SSO connection needed.

Preconditions

There are several preconditions which must be fullfilled to be able to use ADFS as the Identiy Provider

- Application is a web based application and HTTPS has to be used
- Identities must be available locally in the application (user id must match the unique Identifier of the token)
- Users which access the application have got an user account in one of our connected Active Directories - depending which environment you have choosen (see above)
- Users can access applications from the Internet (only cloud applications and applications, published to the Internet via our IdP)
    - A seperate authentication on our Identity Provider system is needed
    - User has to authenticate additional with MFA (Multifactor Authentication). Enrollment process can be found here

Out of our Service Scope

- Configurations on Service Provider / Application side
    - Managing the identities inside the application. This topic has to be handled separate. You can find information about how to handle on the Bosch IDM docupedia sites.
    - Application role management
    - Configuration of the federation trust and Development

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

7 Application Development

7.1 If you are developing a new application and need support with integrating SSO we have some tips for you:

Protocol: We recommend to use OIDC

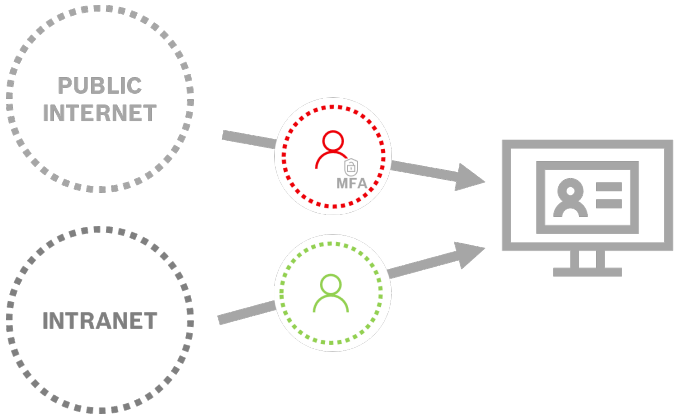
Library: We recommend you to use the MSAL library from Microsoft

Addtioanlly, we have a dedicated guide for Token Validation. All these validation steps are automatically included, when you are implementing MSAL libraries.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

8 Multi Factor (MFA) with applications using modern Auth (SAML/OIDC)

Multi Factor Authentication (MFA) is used to secure the identity of Bosch users for example while logging in to applications using modern authentication (SAML and OIDC).
Further organizational and technical details regarding Microsoft MFA service at Bosch, the enrollment process for internals and externals and other information you can find
on the docupedia site of the MFA service responsible group at https://inside-docupedia.bosch.com/confluence/x/g7QzR.
For the onboarding we offer two different configuration types:

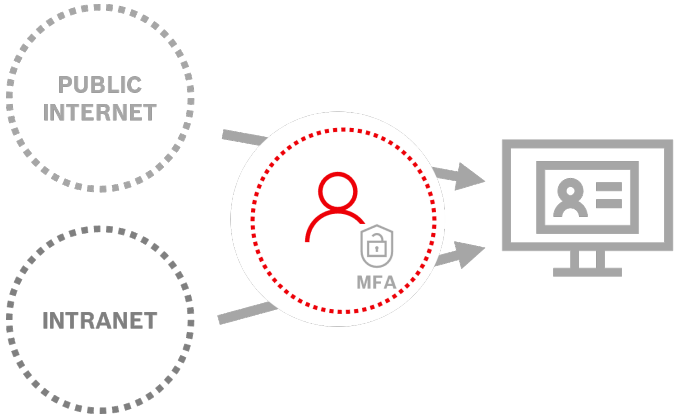


Default MFA setting - Need MFA from **extranet** (public internet) access only

With the default setting, you can authenticate via SAML or OIDC without MFA requirement when accessing the application from a Bosch internal local network (**intranet**). This includes as well clients, which are connected via Cisco Anytime VPN to the internal network like e.g. while working from home.

While accessing the application from **extranet** (public internet), MFA is required when doing the authentication.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.



Optional MFA setting - Need MFA from **intranet** and **extranet** (public internet) access

- MFA everytime
- MFA every 5 hours

This use case can be ordered via the Service Desk Form:

Entra ID App Security Settings

For applications with the requirement to a higher security level we offer to enable MFA authentication as well when accessing the application from the intranet in addition. There are two options:

For Administration at Bosch we have the SAW (Secure Admin Workstation) - a dedicated hardened Client. The access to applications can be enforced to SAWs only:



Optional SAW setting - Need **SAW** (intranet) access only

For applications with the requirement to a higher security level we offer to enable SAW access only, which will only be possible from the intranet (SAW VPN Gateway):

- require SAW

This use case can be ordered via the Service Desk Form:

Entra ID App Security Settings

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

9 Bosch Attributes and Claims

This is an Overview of Claims that can be configured in Enterprise Applications in the Azure Portal (Entra ID). A claim is a piece of information about a user that is sent from the identity provider (Entra ID) to the service provider (your application) in the token. Claims can include details such as the user's name, email address, roles, or other attributes.

Claims Overview

Source Attribute in Entra ID	Attribute name in AD	Description	Example
user.onpremisessamaccountname	SamAccountName	NT User ID of the user	doj1fe
user.userprincipalname	UserPrincipalName	unique value for the user including NT-ID and the domain in email format	doj1fe@bosch.com
user.givenname	GivenName	Firstname of the user	John
user.surname	Sn	Last name of the user	Doe
user.mail	mail	Email Address(es)	john.doe@de.bosch.com
user.department	Department	Department abbreviation	CI/ISI2
user.displayname	DisplayName	Name as shown in eg Outlook	Doe John (CI/ISI2)
user.telephonenumber	telephoneNumber	the office telephone number of the user	+49(711)811-1234
user.streetaddress	StreetAddress	Street of office location	Borsigstrasse 4
user.city	City	Location	Stuttgart-Feuerbach

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Source Attribute in Entra ID	Attribute name in AD	Description	Example
user.state	State	State of the User	Baden-Wuerttemberg
user.country	Country	Country Code	DE
user.comanyname	Company	Company name	Robert Bosch GmbH
user.physicaldeliveryofficename	Office	Room and building number	FE 701/2 J1.01

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

10 Groups and Authorization

SAML and OIDC are designed for Authentication of users. But with a SSO-configuration there also a lot of possiblilities for authorization and role concepts.

For this it is important to use AD groups. We are offering two different compliant group types: ITSP and IDM2BCD

Please make sure that you follow the right steps depending if you have a **SAML** or **OIDC** configuration!

Overview

- Restrictions for nested Groups
- Usecase 1a: Restrict Access to Specific Groups
- Usecase 1b: Send Assigned Groups in Token
- Usecase 2: Send Roles in Token
- Usecase 3: Send Filtered Groups in Token
- Usecase 4: Grant Application Permission to another App
- Usecase 5: SCIM Provisioning
- Common Problems

10.1 Restrictions for nested Groups

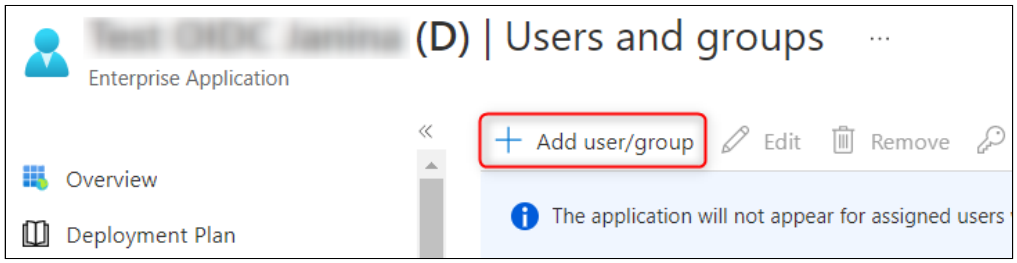
Affects Usecase 1 and 2: For group assignment there is the restriction that groups nested within the directly assigned group won't have access. (Microsoft Documentation) . If you want to use nested groups (e.g. WOM-Groups) for your application Usecase 3 could be the solution. When an app is configured to receive group membership claims in the token, all nested groups in which the signed-in user is a member are included.

10.2 Usecase 1a: Restrict Access to Specific Groups

With this option you can restrict the access to your application directly in Azure. Only members of the assigned groups will get a token.

	Official Microsoft Documentation: here
1	Go to your Enterprise Application in Azure Portal *OIDC-Tip: To find the related Enterprise Application go to the Overview-Tab of the App Registration and follow the link of "Managed application in local directory" or search for the Application Name in "Enterprise Application" Service directly*

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

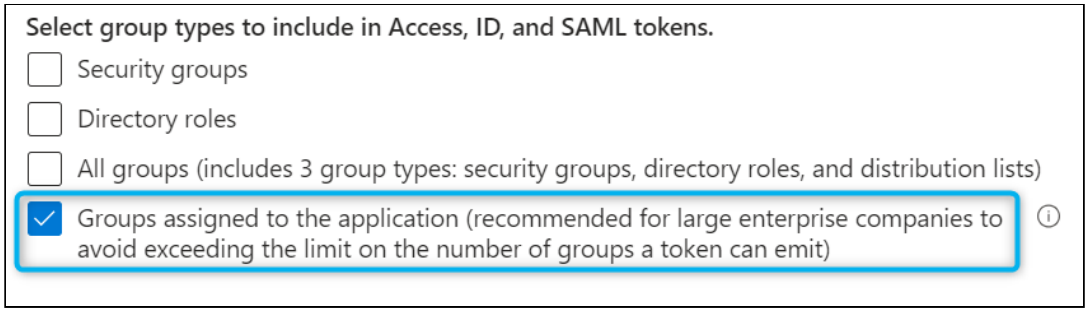
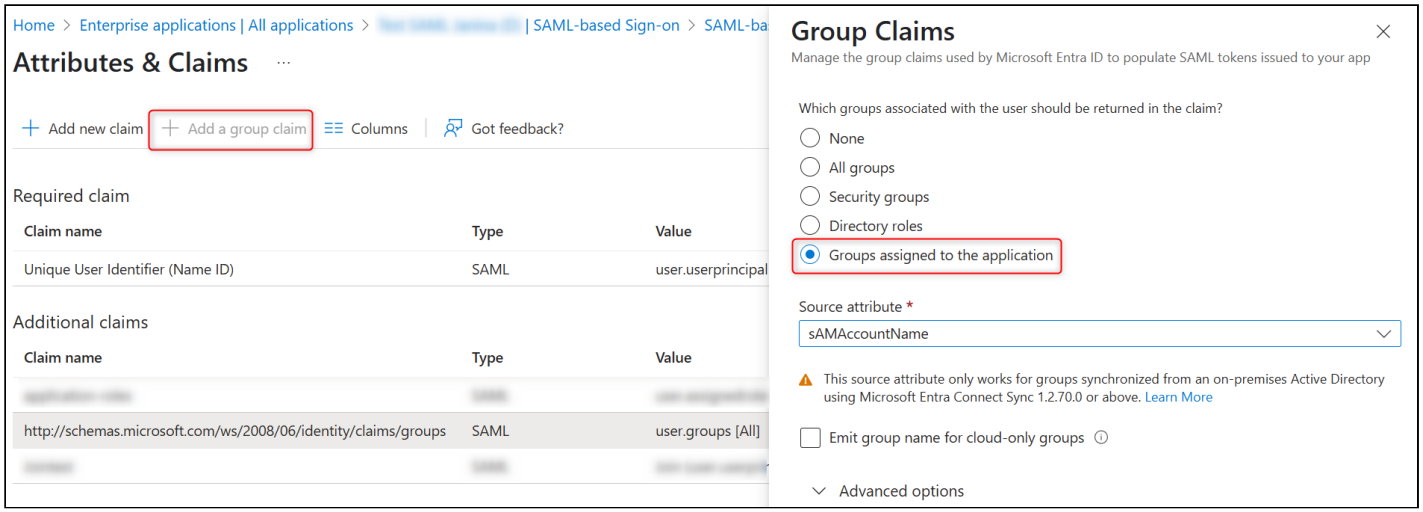
	Official Microsoft Documentation: here
2	Assign the respective groups in the "Users and Groups" section of your Enterprise Application.  *Tip: If you want to assign many groups, you could upload them as well via Script as explained in our documentation*
3	Set "Assignment required?" to Yes in the "Properties" section of your Enterprise Application 

10.3 Usecase 1b: Send Assigned Groups in Token

With this option you can assign groups to the application and send only them in the token. This option can be combined with 1a (recommended)

	Offical Microsoft Documentation: here
1	Assign groups to your Application (see Step 1+2 from 1a)

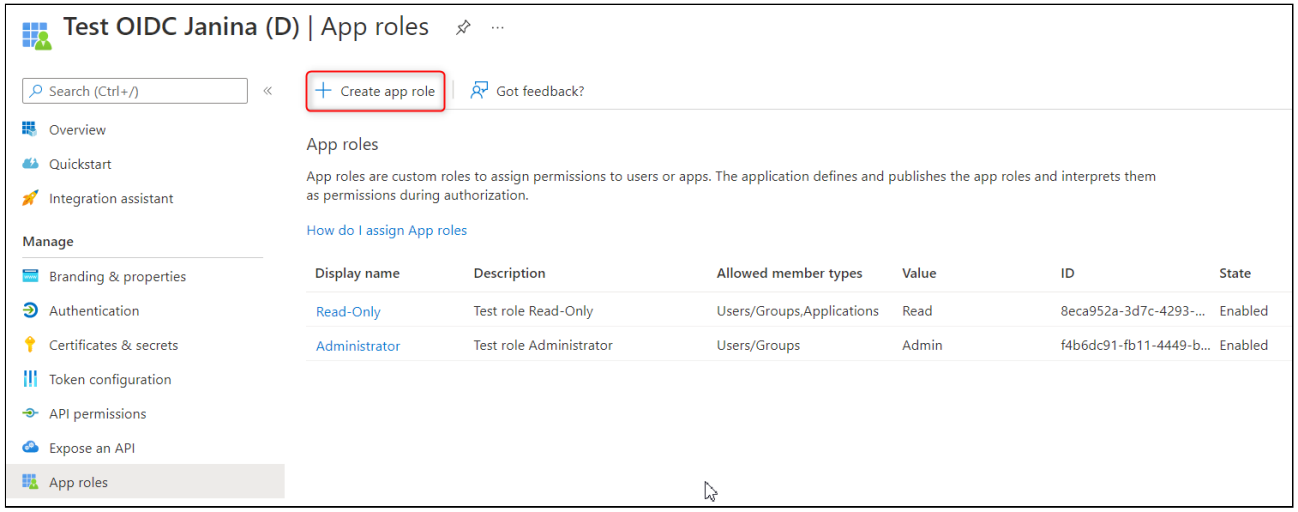
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Offical Microsoft Documentation: here
2 - **OIDC**	Go back to your App Registration and go to "Token configuration" and click "Add groups claim". Select the option "Groups assigned to application"  *Tip: In case the option is not available, delete the currently existing group configuration in Token configuration*
2 - **SAML**	Go to Single-Sign-On > Attributes and Claims and click "Add a group claim" Select the option "Groups assigned to application" and save the claim.  Under advanced options you could rename this claim

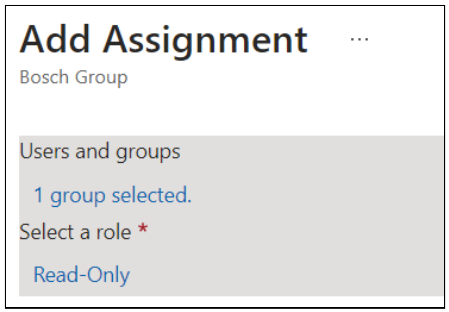
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

10.4 Usecase 2: Send Roles in Token

With this option you can define individual roles, map them to existing groups or users and send them in the token. There is currently a limit of roles per application, we recommend to max 1.000 roles (Service limits and restrictions - Microsoft Entra ID | Microsoft Learn)

	Official Microsoft Documentation: here
1	Go to your App Registration in Azure Portal
2	Add the desired App Roles in the "App Roles" section of your App Registration. For a standard user application it is enough to set Users/Groups as allowed member types. The "Value" is later send in the JWT-token. 

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
3	Add the Users and Groups to respective App Roles in your Enterprise Application (see instruction 1). 
Info **Automation**	If you want to assign many roles and groups, you could upload them as well via Script as explained in our documentation
Info **OIDC**	These assigned app roles are automatically included in the ID tokens. `"roles": [ "Admin", "Read" ],` Special Case for e.g. Client Credential Flow: When your app is the API being called by an app the role assignment of applications is possible over "API permissions" and the roles are included in the access tokens.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

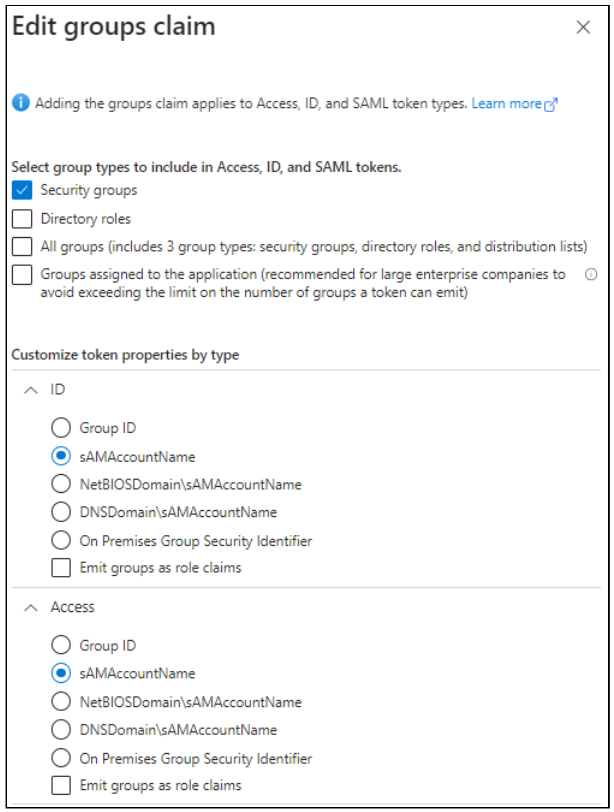
	Official Microsoft Documentation: here

Info
SAML
	The assigned app roles are automatically included in the SAML Response
	`<Attribute Name="http://schemas.microsoft.com/ws/2008/06/identity/claims/role">`
	`  <AttributeValue>Admin</AttributeValue>`
	`  <AttributeValue>Read</AttributeValue>`
	`</Attribute>`

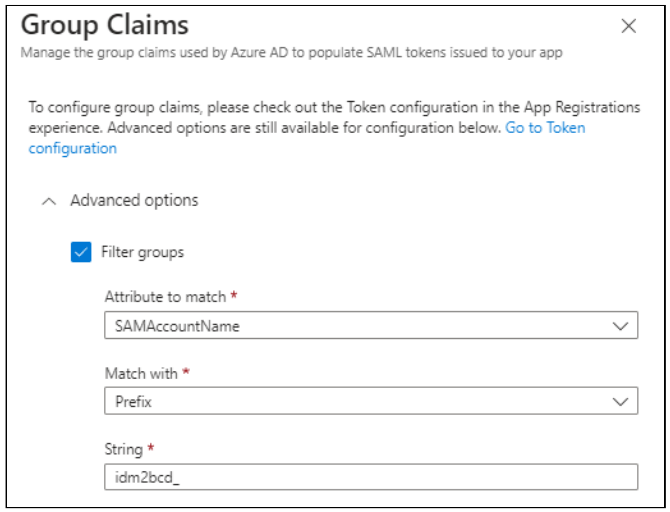
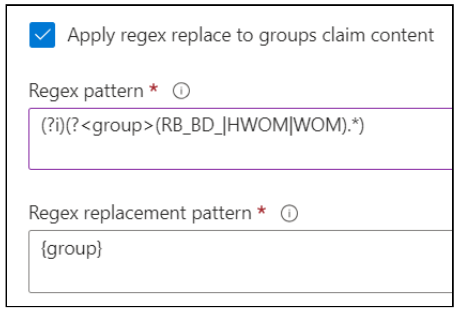
10.5 Usecase 3: Send Filtered Groups in Token

With this option, you can send groups that fit to a certain filter (e.g. IDM2BCD_myapplication). This option is recommended, if you have a large number / very dynamic groups that are relevant for your application. This is because you can exceed the limit of groups that can be send in a token and it is based on a name of a group and not it's unchangeable ID and therefore less secure. Additionally `sAMAccountName` attribute is available only on group objects synced from Active Directory and not on groups created in Entra ID or Office 365.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
1 - **OIDC**	Add Group Claim in Tab "Token Configuration" of your App Registration: Select Security Groups and select sAMAccountName as type for your ID-Tokens and/or Access-Tokens  Then go to the Enterprise Application of your App. In the Tab "Single-Sign-On" edit "Attributes and Claims". There you can "Add a group claim".
1 - **SAML**	In the Tab "Single-Sign-On" edit "Attributes and Claims". There you can "Add a group claim": Select "All groups" and as Source attribute select "SAMAccountName" in the section above. You can customize the name of the group claim if needed.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
2	Select Filter groups and add your desired Prefix-Filter in the field String:  Hint: You may have to some minutes and update the page until it is working to save the configuration in Azure. An alternative could be to select the Regex option below and define a pattern which is the more flexible option, **BUT** as soon as a user is member of more then 150 groups they won't be send in the token at all. Therefore this option is not recommended! 

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
3 **OIDC**	Adapt the Manifest of the App Registration: Microsoft Graph App Manifest (New): ... "api": { "acceptMappedClaims": true, ... "requestedAccessTokenVersion": 2, ... AAD Graph App Manifest (Deprecating Soon): ... "acceptMappedClaims": false, "accessTokenAcceptedVersion": null, ...

10.6 Usecase 4: Grant Application Permission to another App

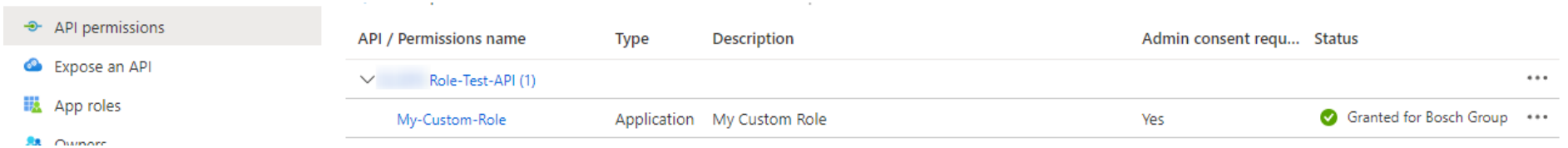
OIDC only!

With this option, you can assign application permissions of apps you own to other apps in the Bosch environment yourself. Unfortunately, Microsofts UI only supports Users and Groups (see Usecase 2) and you need to use the Microsoft graph API to achieve this.

	Official Microsoft Documentation: here
1	Create an App role as described in Usecase 2
2	Use the Microsoft Graph API to assign another application to the role: https://docs.microsoft.com/en-us/graph/api/serviceprincipal-post-approleassignedto The Microsoft Docs currently states that you need the '*Application.Read.All*' or '*AppRoleAssignment.ReadWrite.All*' application permission to list and add assignments in an application context without a user involved. However, that is not true and you will only need the '*Application.ReadWrite.OwnedBy*' application permission to use the following endpoints. The permissions above will not be granted to you, since it would give you access to every single application of Bosch. The calling user/application needs to be defined as an owner of the application that is publishing or providing the role. (Application can be added as Owners in Applications - IAP)

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

	Official Microsoft Documentation: here
3	You can see the assigned application permission in the API permissions overview of the application that was assigned. The permission will have the status Granted



10.7 Usecase 5: SCIM Provisioning

In case your application supports SCIM provisioning of users or groups, they can be automatically synced to your application. For this a separate app registration is required.
More information how to request it can be found here.

10.8 Common Problems

Please check out the common problems for OIDC here: Configure Claims in Token

10.9 How to configure PowerShell for Microsoft.Graph

The intention of this page is help you get up and running with the PowerShell Modules for Microsoft Graph.

- Setting up a local proxy with PX
- Setting up the PowerShell Profile(s)
- Installing the Microsoft.Graph modules

Microsoft has deprecated the "old" Azure / EntraID PowerShell modules and moved to a Microsoft Graph based approach. The new Modules are essentially just a wrapper around the "Microsoft Graph" Rest-API which exists for mostly all Microsoft offerings.
The new Modules are broken in various ways, one of them is properly working with proxy settings. Therefore we have to use a tool called PX to authenticate us against the proxy.

10.9.1 Setting up a local proxy with PX

Please assign "**Microsoft Visual Studio Code with Proxy Configuration (PX) (install)**" to your device via the IT Service Portal. As the Graph modules are less broken in PowerShell 7+ I would recommend also adding "**Powershell Core (install)**" if you haven't already.

*Hint: You can check the version of PowerShell you are running by having a look at the content of **$env:PSVersionTable**.*

Once the packages have been installed you can configure PX to automatically launch at startup using the following command:

```
& 'C:\Program Files\px\pythonw.exe' .\px.exe --install
```

This should result in a console opening up at each reboot.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

10.9.2 Setting up the PowerShell Profile(s)

PowerShell can be used in different applications - called PowerShell Hosts - with each having its own profile script. You can find the appropriate profile script by checking the content of $Profile. To create a new profile script simply execute in Powershell:

Notepad $profile

This will open up an editor with your profile file open, for PowerShell 7+ this should be "C:\Users\<your user>\Documents\PowerShell\Microsoft.PowerShell_profile.ps1".

Add the following lines to the file and save it:

$env:HTTP_PROXY = "http://localhost:3128"

$env:HTTPS_PROXY = "https://localhost:3128"

10.9.3 Installing the Microsoft.Graph modules

With the setup above completed you should be able to install the Graph Modules from the PowerShelll Gallery using:

Install-Module Microsoft.Graph -Scope CurrentUser

10.10 How to create App-roles/ AD-group-Mapping scripted

The intention of this page is to support the creation of app roles and the assignment of groups for SSO in Entra ID as **scripted creation for mass-uploads**

This script and documentation is an example of how you can connect to Microsoft Graph and using Powershell code for this task. IDP-Team is not responsible for the script, it maintenance or coding. In case of any problems with the script assign the roles/ groups manually or check the official Microsoft documentation

Connect MS-Graph
https://learn.microsoft.com/en-us/powershell/microsoftgraph/authentication-commands?view=graph-powershell-1.0
Administrate enterprise application with MS-Graph
https://learn.microsoft.com/en-us/graph/tutorial-applications-basics?tabs=powershell

Microsoft Limitations e.g. max 1.200 Manifest entries, impacting the number of roles per application
Service limits and restrictions - Microsoft Entra ID | Microsoft Learn

10.10.1

- Technical Prerequisites
- Upload Roles and Groups
  - Prepare .CSV File
  - Run the script
- Upload Groups only

10.10.2 Technical Prerequisites

Please refer to our documentation: How to configure PowerShell for Microsoft.Graph.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

The user you are using to connect to Microsoft Graph needs to be the **owner** of the respective enterprise application and app registration.

10.10.3 Upload Roles and Groups

10.10.3.1 Prepare .CSV File

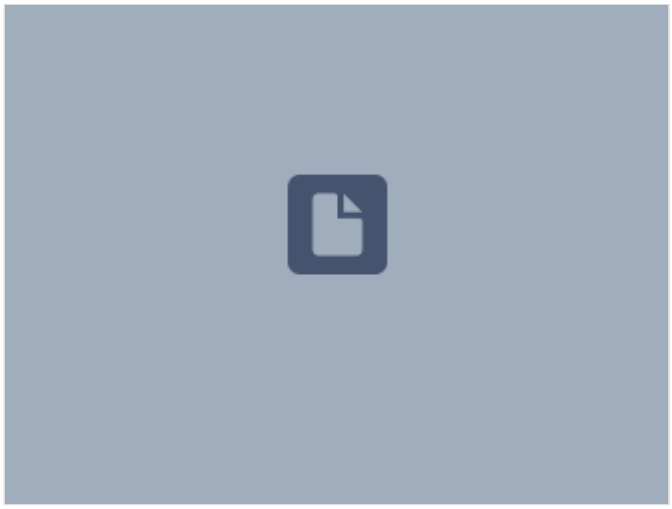
Create a .CSV with the columns Displayname (Groupname), Description, Value, RoleName and insert the values of your groups and roles. The column RoleName is optional.
The script is currently limited so that for each group there must be a different role (value) defined

Example:

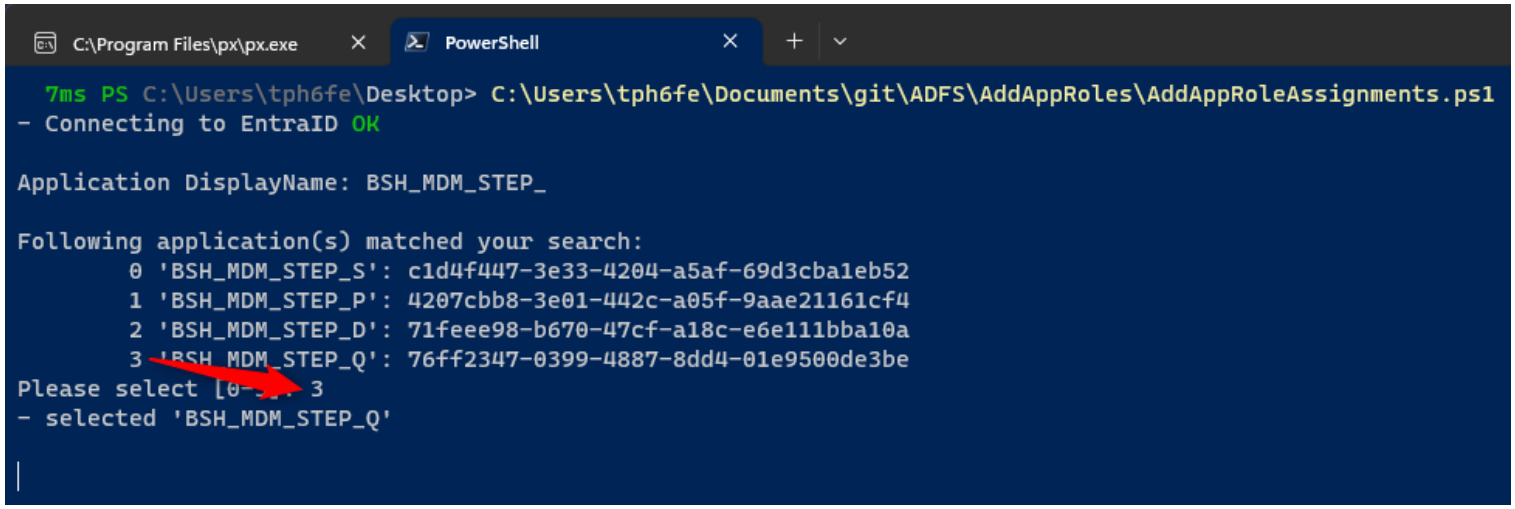
Displayname	Description	Value	RoleName
IDM2BCD_MYAPP_USER	Read Access to MYAPP	Reader	Reader-Role
IDM2BCD_MYAPP_POWERUSER	Admin Access to MYAPP	Admin	Admin-Role
...			

10.10.3.2 Run the script

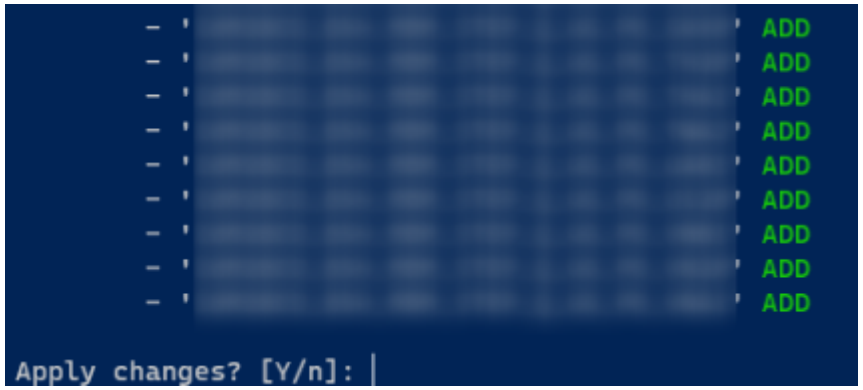
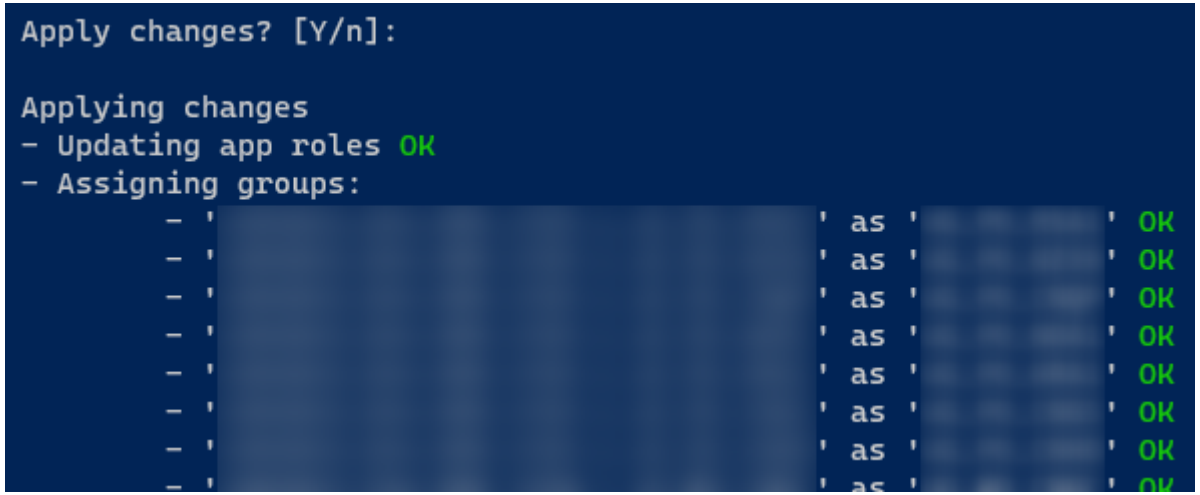
Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
1 - Start Script	 To run the script you can simply drag & drop the downloaded script file into your PowerShell console window and hit enter. Make sure PX is running. You might be redirected to your browser window to sign in to EntraID.

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
2 - Select Application	n the next step you will be prompted for the display name of your application. In case this results in a unique match the script continues, for multiple matches you have to enter the number of the application you intend to update: 
3 - Select .CSV File	The script shows a file open dialog (sometimes in the foreground, sometimes you have to ALT + TAB to find it) select your roles .CSV file

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Step	Description
4 - Confirmation	After you have selected a file you are prompted with the necessary changes:  No changes have been made yet. In case a role already exists you will see a "SKIP" instead of "ADD" here. For a group that does not exist it will state "INVALID GROUP" and skip it. Hit ENTER or "Y" + ENTER to apply the changes.
5 - Processing	The script will now create the necessary new roles in the App Registration and assign/map them to the Enterprise Application accordingly. 

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

Result of Example in Entra ID
1) App Registration → App Roles

Display name	Description	Allowed member types	Value
Admin-Role	Admin Access to MYAPP	Users/Groups	Admin
Reader-Role	Read Access to MYAPP	Users/Groups	Reader

2. Enterprise Application → Users and Groups

Display name	Object type	Role assigned
idm2bcd_[redacted]_poweruser	Group	Admin-Role
idm2bcd_[redacted]_user	Group	Reader-Role

10.10.4 Upload Groups only

Currently the script only supports to add roles and groups:

- Therefore you can manually create a default role in your app registration. Then you can assign all groups to this default role via the script.
- Or you just define a new role for each group and upload everything via the script

Follow the instruction from the chapter above.

10.11 SCIM - Authorization via SCIM interface

10.11.1 What is SCIM?

SCIM (System for Cross-domain Identity Management) is an open standard designed to facilitate the automation of user identity management across different systems and domains. SCIM aims to simplify the process of managing and exchanging identity data such as user profiles, roles, and permissions between cloud services, applications, and IT systems.
More information can be found here: SCIM - oneIDM Help Area

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.

10.11.2 Onboarding

SCIM Onboarding

SCIM is part of the IDM service at Bosch and will be provided by the responsible team.
To get consulting and start the SCIM onboarding process, please **contact the IDM integration mailbox** Mailbox.IdMIntegration@bosch.com

Copyright Robert Bosch GmbH. All rights reserved, also regarding any disposal, exploration, reproduction, editing, distribution, as well as in the event of applications for industrial property rights.